



ESPE
UNIVERSIDAD DE LAS FUERZAS ARMADAS
INNOVACIÓN PARA LA EXCELENCIA



Ciberseguridad: del ciber-crimen a los ataques ciber-físicos

Walter Fuertes, Ph.D., y Mayra Macas, Mgtr.

Ciberseguridad: del ciber-crimen a los ataques ciber-físicos

Walter Marcelo Fuertes Díaz, Ph. D.; Mayra Alexandra Macas Carrasco, Mgtr.

Primera edición electrónica: mayo, 2023

ISBN: 978-9942-765-88-8

Revisión científica:

Dr. Patricio Xavier Zambrano Rodríguez y Mtr. José Vinicio Freire Rumazo

Universidad de las Fuerzas Armadas-ESPE

Crnl. de C.S.M. Víctor Villavicencio A., Ph. D. - Rector

Publicación autorizada por:

Comisión Editorial de la Universidad de las Fuerzas Armadas-ESPE

Cpcb. Rolando Patricio Reyes Chicango, Ph.D. - Presidente

Corrección de estilo y diseño

Lcdo. Xavier Chinga

Imagen de cubierta: <https://acortar.link/pct0fY>

Créditos de imágenes internas: Adrián Burgos Reasco, Alexander Barreto Masache, Ayme Escobar Díaz, Brandon Jiménez Meza, Christian Román Quiroz, Dalton Arévalo Basantes, Daniela Orellana Soriano, Daniela Pilaxi Chisaguano, Diana Barrera Gallo, Diana Caisaguano Ilaquiche, Dominique Salazar Serrano, Edgar Sánchez Ponce, Fausto Vizuite Morales, Hamilton Pérez Zambrano, Harlen Mosquera Coronel, Jimmy Guzmán Cabascango, Karen Tacoaman Soria, Karla Luna Maza, Leydi Villadarez Namicela, Luis Espinoza Meza, Oscar Domínguez Cárdenas, Ricardo Rivadeneira Gómez, Sebastián Torres Tapia, Valery Naranjo Zambrano, Víctor Villamarín López, Yandri Gaona Cumbicus, Jessica Yandún Perengueza y Joyce Castro Zambrano.

Derechos reservados. Se prohíbe la reproducción de esta obra por cualquier medio impreso, reprográfico o electrónico. El contenido, uso de fotografía, gráficos, cuadros, tablas, y referencias es de exclusiva responsabilidad de los autores.

Los derechos de esta edición electrónica son de la Universidad de las Fuerzas Armadas-ESPE, para consulta de profesores y estudiantes de la universidad e investigadores en www.repositorio.espe.edu.ec.



Ciberseguridad: del ciber-crimen a los ataques ciber-físicos.

Walter Fuertes
Mayra Macas



Dedicatoria

A mi amada esposa Silvia, y a mis queridos hijos Walter y Mateo;
A mi madre que está en el cielo;
A mi padre y hermanos;
A mis apreciados estudiantes de grado y posgrado;
A los colegas de profesión, por su vocación y abnegada labor;
A Mayra Macas, PhD©, por su invaluable esfuerzo y dedicación.

Walter

A mis maravillosos padres, quienes siempre han creído en mí y me han animado a seguir mis sueños. Gracias por su sabiduría, fuerza y amor infinito.

A mis hermanas, que incondicionalmente han estado ahí para mí. Gracias por su soporte y cariño.

A Grigorios, mi amado novio y mejor amigo, quién me ha impulsado a seguir adelante para conseguir mis objetivos. Gracias por su apoyo.

A mis profesores y estudiantes, en particular al Ing. Walter Fuertes, PhD, que continuamente me han inspirado a mejorar.

Mayra

Prólogo

Motivación

En la actualidad la sociedad depende de las tecnologías de la Información y comunicación TICs y la Red de Internet para la realización de actividades cotidianas tanto en el ámbito laboral, educacional, de ocio e incluso la defensa del territorio nacional. Esta dependencia hace que la sociedad en todos esos ámbitos, esté expuesta ante varias amenazas originadas en el ciberespacio y los consecuentes escenarios de riesgo negativo, que por un lado impiden el logro de los objetivos de los integrantes de la sociedad y por otro desmotivan y desaceleran la transformación digital.

El hecho de que no se puede garantizar la seguridad total de un sistema de información, aplicación o tecnología, sobre el cual se presta y accede a servicios digitales, hace necesario llevar a cabo una gestión de riesgos de ciberseguridad, que permita establecer un nivel de riesgo adecuado para la realización de actividades derivadas de la misión y visión de las organizaciones, así como de objetivos individuales personales. El resultado de la gestión de riesgos de ciberseguridad es proporcional a la selección de controles eficaces y eficientes. Por lo tanto es de suma importancia el conocer el comportamiento de controles de seguridad disponibles en el mercado, así como también el estado del arte tanto en las tecnologías de la gestión de riesgos de ciberseguridad, así como los enfoques de investigación en áreas específicas de ciberseguridad.

En esta obra se exponen los conceptos teóricos fundamentales asociados a la ciberseguridad y la gestión de incidentes de ciberseguridad, a fin de que el lector pueda tener una clara comprensión de los pilares de la seguridad de la información, así como también los elementos que constituyen un incidente de ciberseguridad y que cada uno de ellos debe ser gestionado integralmente. La obra intelectual hace una exposición de la evolución de varios tipos de amenazas y ataques de ciberseguridad, así como la evolución del enfoque y tecnologías aplicadas para contrarrestarlos.

Cabe señalar que los profesionales de la ciberseguridad y el público en general deben ser conscientes del impacto y las consecuencias que se podrían

derivar de un ciber crimen, de la ciber guerra, o el ciber acoso, que serán expuestos en este libro. Por lo tanto, esta obra fortalecerá el conocimiento sobre las tecnologías de seguridad, especialmente al espectro de amenazas que aprovechan las vulnerabilidades y los escenarios derivados, que incrementan el riesgo de un incidente informático.

Objetivo

El objetivo de este libro es poner en consideración del lector los fundamentos asociados la ciberseguridad con el fin de incrementar la seguridad de la información y coadyuvar en los niveles de madurez en el país en este ámbito.

Para lograrlo, esta obra realiza una exposición del ciber crimen, ciber acoso, ciber guerra, web profunda, ataques de ingeniería social, a las aplicaciones web, de denegación de servicio, culminando con los ataques ciber físicos, dirigidos no solo contra las personas vulnerables en casa, la industria, academia, o empresa, sino también en contra de los sistemas de control de infraestructura esencial, incluidos la energía eléctrica, salud, educación, banca, entre otras. La exposición comprende casos icónicos a nivel internacional, casos ocurridos en el Ecuador, medidas de control aplicadas usualmente, y el estado del arte respecto de propuestas innovadoras para la gestión de incidentes. La obra presenta recursos complementarios a lo largo de varios capítulos de tal manera que el lector pueda obtener información estadística de los tipos de incidentes relacionados a ciber crímenes, así como la experimentación respecto al uso de mecanismos de control.

¿A quién va dirigido este libro?

El libro está dirigido a investigadores, estudiantes de pregrado y postgrado y profesionales inmersos en el ámbito de la gestión de ciberseguridad que deseen conocer las características específicas de incidentes de ciber seguridad en el espectro de ciber crímenes y ataques ciber físicos, así como también el estado del arte tanto en las tecnologías de ciberseguridad y las metodologías propuestas para análisis e investigación. Esta obra además está dirigida al público en general para que inicie su entrenamiento y concienciación sobre estos temas delicados que incrementan cada día en complejidad y frecuencia y que están siendo sancionadas por las leyes ecuatorianas y a nivel mundial. Este libro puede ser usado como referencia inicial para la investigación más profunda de cada uno de los tipos de incidentes expuestos y que forman parte las amenazas del día a día contra los usuarios de las tecnologías de la información y comunicaciones TICs y la Red de Internet.

Estructura del Libro

Con la finalidad de cumplir con el objetivo planteado, el libro se encuentra estructurado de la siguiente forma.

El **Capítulo 1** presenta los fundamentos esenciales de la seguridad de la información, ciberseguridad y ciberdefensa. También analiza los pilares de la seguridad de la información y los elementos de un incidente de seguridad. Luego, en el **Capítulo 2** se describen los tipos de ataques y atacantes que forman el espectro de amenazas en las actividades ilícitas del ciber crimen. En el **Capítulo 3** se describen las acciones de acoso que son realizadas a través de la Red de Internet y se exponen sitios web con información actualizada relacionada a tendencias y mejores prácticas. De manera especial se muestra los riesgos existentes en las redes sociales. En el **Capítulo 4** se aborda a la ciber inteligencia como el proceso que permite lograr un mejor nivel de ciberseguridad respecto a una infraestructura tecnológica y organización específica. Se analiza la ciber inteligencia y su interrelación con actividades de defensa y seguridad nacional como lo son el ciberespionaje, ciberterrorismo y cibersabotaje. En el **Capítulo 5** se describen las amenazas y oportunidades que brinda la Deep Web respecto de la ciberseguridad, así como herramientas necesarias para su uso.

En el **Capítulo 6** se describen varios ataques de ciberseguridad que su éxito depende de la interacción humana, es decir la Ingeniería Social, como lo son phishing y ransomware; y que hoy en la actualidad son el mayor vector de ataque y el incidente con mayor crecimiento a nivel global respectivamente. En el **Capítulo 7** Se describen las técnicas para ciber ataques orientados a actividades de fraude contra los nombres de dominio de las organizaciones, así como también mecanismos de control orientados a la identificación y autenticación de usuarios. En el **Capítulo 8** se describen las técnicas utilizadas por los ciber atacantes en contra de la disponibilidad de los sistemas de información, DoS/DDoS. En el **Capítulo 9** se describen protocolos y procedimientos para garantizar la confidencialidad de la información en los estados de almacenamiento, procesamiento y transmisión. En el **Capítulo 10** se describen las técnicas actuales de los ataques a redes inteligentes sobre las cuales las ciudades inteligentes prestan servicios a la ciudadanía de forma eficaz y eficiente.

José Vinicio Freire Rumazo

Ing. Electrónico en Telecomunicaciones.

Master en Derecho y Gestión de las Telecomunicaciones.

Master en Gerencia de Seguridad y Riesgo.

Master en Seguridad Informática.

Oficial de Seguridad de la Información.

Prefacio

La Seguridad Cibernética o Ciberseguridad es un conjunto de tecnologías y métodos que se esfuerzan por proteger las redes informáticas, los sistemas finales, los programas y los datos de ataques, accesos no autorizados, cambios o daños. Los mecanismos de defensa cibernética existen a nivel de host, red, aplicación y datos. Una plétora de herramientas, como firewalls, software antivirus, sistemas de detección de intrusos y sistemas de protección contra intrusos funcionan sigilosamente para evitar ataques y detectar brechas de seguridad. Sin embargo, los adversarios aún tienen ventaja porque solo necesitan encontrar una vulnerabilidad en los sistemas bajo protección. A medida que aumenta la cantidad de sistemas conectados a Internet, los ataques cibernéticos también aumentan en tamaño, sofisticación y costo.

La principal razón que motivó la escritura de esta obra es justamente la protección frente a un ataque cibernético o un delito informático. Los ataques cibernéticos son consecuencia lógica del incremento constante de las amenazas en el ciberespacio. Las amenazas aprovechan las vulnerabilidades de los sistemas informáticos, que utilizan tanto los internautas, empresarios y gobernantes, así como los niños y adolescentes que, por su ingenuidad y desconocimiento, son el eslabón más débil e inseguro. Esta inseguridad trae como consecuencia fraudes, acceso no autorizado, robos, pérdidas económicas, ciberacoso, decremento de la productividad e inestabilidad.

Frente a esta problemática, y sobre la base de varios años de investigación y docencia en este transcendental tema de actualidad, es una preocupación de los autores presentar esta obra que tiene como objetivo, educar, capacitar, concienciar y difundir los fundamentos de la Seguridad Cibernética, con el fin de coadyuvar con una cultura de seguridad que permita incrementar los niveles de madurez de ciberseguridad en casa, la oficina y en la sociedad a la que nos debemos. Otro aspecto fundamental que originó la escritura de este libro ha sido las consecuencias provocadas por el distanciamiento social por el uso obligatorio del teletrabajo, teleeducación y telesalud en época de la pandemia provocada por el COVID-19. Esto sin duda fomentó el incremento en la

complejidad y frecuencia de los ciber ataques y los ciber delincuentes.

Para todos es conocido, que a los ciber criminales no les importa interrumpir un servicio en línea, dañar o robar los datos de una empresa, usuario o gobierno, intimidar o acosar a un adolescente, robar su dinero o divulgar la información confidencial o reservada de alguien. Para lograr su propósito, los ciber delincuentes utilizan una variedad de técnicas que van desde la ingeniería social, el ciber acoso, la ciber guerra, los ataques a las aplicaciones Web, los ataques de denegación de servicio, la Web profunda, el análisis del tráfico encriptado e inclusive los ataques ciber-físicos.

Esta obra, estimado lector, ofrece información de las técnicas descritas en el párrafo anterior, cómo se caracterizan, funcionan y ejecutan, la manera de cómo detectarlos, prevenirlos y/o mitigar estos ciber ataques. Cabe señalar que los autores no renuncian a la profundidad técnica de los temas que se presentan en este libro. No obstante, intentan explicar de manera didáctica y sencilla los elementos de la seguridad cibernética, lo que lo convierte en un libro fundamental en este campo, y que puede ser utilizado por adolescentes, estudiantes de secundaria y universidad, así como por profesionales de diversas ramas y especialistas en este campo de conocimiento.

Walter Fuertes y Mayra Macas

Walter Fuertes

wmfuertes@espe.edu.ec

Es profesor investigador titular principal del Departamento de Ciencias de la Computación de la Universidad de Fuerzas Armadas - ESPE de Sangolquí-Ecuador. Es además Coordinador del Grupo de Investigación en Sistemas Distribuidos, Ciberseguridad y Contenido (RACKLY) de la misma universidad.

Se graduó como Ingeniero de Sistemas e Informática en la Escuela Politécnica del Ejército (ESPE). Luego, obtuvo su maestría en Informática, mención Redes, en la Escuela Politécnica Nacional de Quito-Ecuador (EPN), su maestría en Docencia Universitaria en la ESPE y su grado de Doctor (Ph.D.) con honores, en Ingeniería Informática y de Telecomunicación en la Escuela Politécnica Superior de Informática de la Universidad Autónoma de Madrid, España.

Desde el 2006 ha participado y ha dirigido alrededor de 15 proyectos de investigación enfocados en la aplicación de las tecnologías de Virtualización, Sistemas Distribuidos, Evaluación de Prestaciones, Seguridades en sistemas Computacionales, Ciberseguridad, Analítica de datos, Inteligencia Artificial, Seguridad cognitiva, Internet de las Cosas, Inteligencia de Negocios y Video juegos educativos. Ha sido ponente en varios congresos nacionales e internacionales y ha publicado en varios journals y revistas nacionales, internacionales y en conferencias en diferentes países del mundo. Además, ha sido autor y coautor de libros y capítulos de libros académicos arbitrados.

Mayra Macas

mayramacas@ieee.org

Mayra Macas recibió su título en Ingeniería en Sistemas Computacionales de la Escuela Superior Politécnica de Chimborazo (ESPOCH), Ecuador, en 2013, es magíster en Gestión de Sistemas de Información e Inteligencia de Negocios de la Universidad de las Fuerzas Armadas-ESPE, Ecuador, en 2017 y magíster en Visual Analytics and Big Data de la Universidad de La Rioja, España, en 2023.

Actualmente, es candidata a Ph.D. en la Universidad de Zhejiang con la Facultad de Ciencias y Tecnología Informática, Hangzhou, China y miembro del laboratorio y grupo de investigación de redes avanzadas e inteligentes NGNT. Recibió la Beca del Gobierno Chino para sus estudios de doctorado. Es miembro del Grupo de Investigación en Sistemas Distribuidos, Ciberseguridad y Contenido (RACKLY) de la Universidad de Fuerzas Armadas - ESPE de Sangolquí-Ecuador. También, ha estado trabajando en la industria a nivel nacional e internacional de TI durante alrededor de ocho años. Sus intereses de investigación incluyen la ciberseguridad inteligente, la gestión de la seguridad de la red con agentes inteligentes, así como la seguridad y privacidad de Big Data. Ha sido ponente de varias conferencias internacionales al rededor del mundo y ha escrito para journals de alto impacto sobre las área de Ciberseguridad e Inteligencia Artificial. Además, ha recibido varios reconocimientos internacionales de empresas y organizaciones como TCS, AWS, IEEE y Women in Cloud.

Índice

Capítulo I - Fundamentos de la Ciberseguridad	23
Introducción	25
Seguridad de la Información	25
Ciberseguridad	26
Cadena de destrucción de seguridad cibernética	28
Ciberdefensa	29
Seguridad de las Infraestructuras de misión esencial	30
Comando de Ciberdefensa (COCIBER)	32
Retos o pilares de la Seguridad de la información	33
Confidencialidad	34
Integridad	34
Disponibilidad	35
Autenticación	35
Irrenunciabilidad	35
Trazabilidad	35
Elementos de un incidente informático	35
Amenaza	36
Vulnerabilidad informática	36
Riesgo informático	37
Incidente informático	38
Impacto informático	38
Resiliencia	38
Sitios de Interés	40
Capítulo II - Ciber Crimen	41
Introducción	43
Delitos cibernéticos	44
Tipos de ataques cibernéticos	45
Malware	48
Ataques de Denegación de Servicio	50

Ataques a las Aplicaciones Web	50
Ataques de Escaneo de Puertos	51
Tipos de ciber atacantes	51
Crackers	53
Hackers	53
Hacktivistas	53
Phreakers	54
Amenaza interna (insider Threat)	54
Crimen organizado cibernético	55
Sitios de Interés	55
Capítulo III - Ciber Acoso	57
Introducción	59
Acoso cibernético, ciber acoso o Cyberbullying	60
Definición	60
Características	60
Tipos de ciber acosadores	63
Cybergrooming	63
Cyberstalking	64
Cybersexting	66
Sitios de Interés	68
Capítulo IV - Ciber guerra	69
Introducción	71
Ciberinteligencia	73
Ciberinteligencia: Recopilación y Análisis	74
Ciberdaño	75
Ciberespionaje	75
Ciberterrorismo	76
Cibersabotaje	76
Sitios de Interés	78
Capítulo V - Web profunda	79
Introducción	81
Navegadores	82
Recursos	85
Precauciones	86
Sitios de Interés	88

Capítulo VI - Ataques de Ingeniería Social	89
Introducción	91
Ataques de Phishing	91
Definición	91
Tipos of Phishing	93
Fases de un ataque de Phishing	95
Cómo detectar y protegerse de un ataque de phishing	97
Ransomware	98
Baiting	100
Scareware	100
¿Cómo protegerse de un ataque de ingeniería social?	101
Sitios de Interés	102
 Capítulo VII - Ataques a las aplicaciones Web	 103
Introducción	105
Algoritmos de generación de dominios y detección de botnets (DGA)	107
Detección de fraude	110
Filtrado de spam	112
Identificación y autenticación del usuario	114
Autenticación biométrica	116
Autenticación conductual	118
Sitios de Interés	121
 Capítulo VIII - Ataques de Denegación de Servicio	 123
Introducción	125
Caracterización	126
Fases, tipología y herramientas para ejecutar ataques de DoS y DDoS	128
Mecanismos de detección y mitigación de ataques DoS y DDoS.	130
Sitios de Interés	132
 Capítulo IX - Análisis de tráfico encriptado	 135
Introducción	137
Website fingerprinting	138
Identificación de Protocolo/Aplicación	139
Sitios de Interés	143
 Capítulo X - Ataques Ciber-Físicos	 145
Introducción	147

Sistemas Ciber-Físicos o CPS 148

 Sistemas de control industrial (SCI) 148

 Red Inteligente (RI) 149

 Sistemas de Transporte Inteligentes (STIs) 149

Modelos y aspectos de los CPS 150

Seguridad en los CPS 156

 Sistemas de control industrial (SCI) 156

 Red inteligente 159

 Sistemas de transporte inteligentes 162

Sitios de Interés 165

Índice de figuras

I.1	Alcance de la Seguridad de la Información.	26
I.2	Alcance de la Ciberseguridad según la norma ISO/IEC 27032:2012.	28
I.3	Cadena de destrucción de seguridad cibernética	29
I.4	Mapa conceptual de la Ciberdefensa.	30
I.5	Infraestructuras consideradas de misión crítica.	31
I.6	Definición conceptual de la Ciberdefensa.	32
I.7	Comando de Ciberdefensa de FF. AA. del Ecuador	33
I.8	Efigie de un ciber soldado	34
I.9	Pilares de la Seguridad de la Información.	34
I.10	Elementos que intervienen en un incidente informático.	36
I.11	Fuentes de amenazas a la Seguridad de la Información.	37
I.12	Impacto o efectos que pueden producirse por un incidente in-	
	formático.	39
II.1	Ciber delincuente o ciber atacante (hacker!).	43
II.2	Clasificación del ciber crimen.	47
II.3	Tipos de Malware.	48
II.4	Efigie de un hacker	54
III.1	El acoso cibernético.	59
III.2	El acoso cibernético o cyberbullying.	61
III.3	Formas de acoso cibernético (cyberbullying).	62
III.4	Pasos en un ataque de cyber-grooming.	64
III.5	Elementos del cyber-stalking	66
III.6	Elementos del cyber-sexting	67
IV.1	Resumen de ciberguerra.	73
IV.2	Ejemplos de cibersabotaje.	77
V.1	Capas de Internet.	82
V.2	Estructura del cifrado de la red TOR.	83

VI.1 Tipos de ataques de Ingeniería Social.	92
VI.2 ¿Cómo se ejecuta un ataque Phishing?	93
VI.3 Fases de un ataque de Phishing.	95
VI.4 Caracterización y funcionamiento de un ataque de Ransomware.	100
VII.1 Ciclo de vida típico de un botnet. (1) inyección (es decir, propagar bots mediante inyección), (2) comando y control (es decir, los bots están listos para recibir comandos y lanzar un ataque), (3) ataque (es decir, el botmaster envía el comando para lanzar un ataque), y (4) liberación (es decir, el botmaster elimina su huella o código fuente distribuido).	107
VII.2 Una descripción general de las credenciales para la autenticación e identificación de usuarios y sus aplicaciones.	115
VII.3 Ejemplo autenticación conductual.	118
VIII.1 Ataques de DoS y DDoS.	126
VIII.2 Fases de un ataque de DoS/DDoS, tipos y objetivos.	129
VIII.3 Mecanismos de detección y mitigación de un ataque DDoS/DoS.	131
IX.1 Ejemplo de un modelo de clasificación de tráfico encriptado basado en DL.	138
IX.2 Modelo de amenazas de WF.	139
X.1 Abstracción de alto nivel de cualquier CPS.	150
X.2 Aspectos de los CPS.	151
X.3 Aspectos de los CPS en los SCI.	153
X.4 Aspectos de los CPS en redes inteligentes.	154
X.5 Aspectos de los CPS en transporte inteligente.	155
X.6 Esquema de la arquitectura de un SCI y posibles vectores de ataque.	157
X.7 Dominios de redes inteligentes.	160
X.8 Dos ejemplos de diferentes tipos de mala conducta en sistemas inteligentes de transporte.	163

Índice de tablas

II.1 Tipos de ciber delitos: Fraude digital. Fuente: CIBERPOL	45
II.2 Tipos de ciber delitos: Incidentes Informáticos. Fuente: CIBERPOL	45
II.3 Tipos de ciber delitos: Violencia Digital. Fuente: CIBERPOL . .	46
II.4 Tipos de ciber atacantes.	52
V.1 Resumen de navegadores y precauciones de la web profunda. .	87
VIII.1Matriz de Comparación entre DoS y DDoS.	127
IX.1 Ventajas y limitaciones de los estudios seleccionados centrados en métodos de seguridad basados en DL para análisis de tráfico cifrado.	142



CAPÍTULO I

Fundamentos de la Ciberseguridad

Introducción

Con el progreso vertiginoso de la Informática, microelectrónica, telecomunicaciones y telefonía celular en estas dos últimas décadas, iniciaba también un nuevo problema para la humanidad, la proliferación de criminales cibernéticos y los delitos informáticos perpetrados en el ciberespacio. Como un aspecto agravante, dentro de las consecuencias de la pandemia provocadas por el COVID-19 a inicios del 2020, se modificaron los modelos a teletrabajo, teleeducación, telesalud, entre otros, lo cual exigió a la población de manera obligatoria utilizar los sistemas computacionales mediante conexiones sincrónicas y asincrónicas. Esto sin duda provocó el incremento exponencial de diversos tipos de ataques cibernéticos, sea en contra de las organizaciones, a las personas vulnerables y hasta la soberanía del Estado.

Frente a este contexto, la industria, el gobierno y la academia tienen la responsabilidad de buscar procedimientos o mecanismos para formar, capacitar, concienciar a toda persona que utilice un dispositivo electrónico y a generar soluciones en el ámbito de la seguridad de la información y la ciberseguridad. Este libro tiene como objetivo general el proporcionar a los lectores conocimientos teóricos y prácticos, así como herramientas que le permitan desarrollar habilidades, destrezas y aptitudes, y la aplicación de las mejores prácticas dentro de la empresa y la industria para incrementar los niveles de seguridad de la información.

En este capítulo se describen los fundamentos esenciales de la ciberseguridad, definiciones y terminología necesaria para una mejor comprensión del libro.

¡Bienvenidos!

Seguridad de la Información

De conformidad con la ISO/IEC 27001, la seguridad de la información es una disciplina que protege la integridad, confidencialidad y disponibilidad de la información almacenada en diferentes formatos, tales como electrónicos, documentos en papel, audio y vídeo [Mirtsch et al. \(2021\)](#). Puede referirse a la protección en cuatro niveles: lógico, físico, procedural y legal de diversos ataques, algunos de ellos tipificados como delitos informáticos [Papoutsakis et al. \(2021\)](#).

La Seguridad de la Información incluye a la seguridad informática y a la

ciberseguridad. La primera que es la encargada de proteger los sistemas digitales de amenazas externas e internas. La ciberseguridad en el ciberespacio [Martins et al. \(2022\)](#). La Figura I.1 es una abstracción visual que explica su alcance.

Figura I.1: Alcance de la Seguridad de la Información.



La seguridad de la información utiliza diversos estándares internacionales que establecen las mejores prácticas para identificar los riesgos y garantizar la privacidad de los usuarios a través de la inclusión de controles, barreras o herramientas apropiadas para reducir la inseguridad. Además, involucra la búsqueda de mecanismos de protección en donde la información sea el activo primario. Estos mecanismos podrían ser la instauración de políticas, controles de seguridad, dispositivos electrónicos especializados y procedimientos para detectar amenazas y vulnerabilidades que podrán ocasionar graves incidentes de seguridad con un impacto devastador en los ingresos, productividad e imagen de las empresas; he allí su importancia.

Ciberseguridad

La Ciberseguridad se define como la práctica de proteger la información que se transmite mediante los servicios en las aplicaciones del Internet, redes celulares, redes de datos, de telecomunicaciones e infraestructuras de misión crítica, frente a diferentes ataques maliciosos que son perpetrados por parte de los delincuentes cibernéticos en el ciberespacio [Furnell \(2021\)](#).

El **ciberespacio** es un dominio formado por la interacción de personas, equipos electrónicos, enlaces, servicios y aplicaciones en Internet que se conectan mediante las redes de telecomunicaciones distribuidas a nivel mundial. Dada la inmensidad de este dominio, existen diferentes problemas de inseguridad que no están cubiertos dentro de las mejores prácticas actuales de seguridad de la información. Por esta razón, en el 2012 surgió la norma internacional **ISO/IEC 27032:2012 Tecnologías de la información, Técnicas de seguridad y Directrices para la ciberseguridad**, que aborda la seguridad del ciberespacio von Solms and van Niekerk (2013).

La ISO/IEC 27032 provee orientación técnica para abordar los riesgos comunes de Ciberseguridad, tales como ataques de ingeniería social, hackeo, la proliferación de código malicioso (malware), software espía y otro tipo de software potencialmente no deseado. Además proporciona un sinnúmero de controles para minimizar los riesgos informáticos, tales como (i) Prepararse para ataques de malware, ciber delincuentes individuales u organizaciones criminales en Internet; (ii) Detección y seguimiento de ataques cibernéticos; (iii) Respuesta a los ataques; (iv) el intercambio de información, (v) coordinación, y manejo de incidentes von Solms and van Niekerk (2013).

Cabe destacar que esta norma Internacional brinda orientación para mejorar los niveles de Ciberseguridad en aspectos tales como: (i) Seguridad de información; (ii) Seguridad de la red; (iii) Seguridad en Internet, (iv) Seguridad en las aplicaciones, y (v) Protección de la infraestructura de misión crítica de los estados von Solms and van Niekerk (2013). La Figura I.2 es una representación visual de la interrelación de los elementos señalados.

La Ciberseguridad tiene el firme propósito de proteger la información, dispositivos de networking, y procesos de personas o negocios y se enfoca en la protección de la infraestructura computacional Asbaş and Tuzlukaya (2022). La Ciberseguridad no solo se centra en lo tecnológico para resolver amenazas y vulnerabilidades del ciberespacio, sino también en la percepción humana, tanto desde las personas más vulnerables en casa, como desde una perspectiva organizacional y de soberanía nacional Andrade et al. (2022). Para este fin, es necesario disponer tanto de mecanismos técnicos, procedimientos, estándares, técnicas, métodos, regulaciones, leyes y herramientas para evitar el acceso de personas no autorizadas, lo cual permite incrementar los niveles de seguridad de la información.

Figura I.2: Alcance de la Ciberseguridad según la norma ISO/IEC 27032:2012.



Cadena de destrucción de seguridad cibernética

(Cyber Security Kill Chain) es un conjunto de pasos que rastrean las etapas de un ataque cibernético desde su inicio hasta que se produce el ciberataque. Se trata de un modelo o marco de trabajo que explica el procedimiento típico que los delincuentes cibernéticos adoptan cuando realizan un ciberataque exitoso [Diogenes and Ozkaya \(2022\)](#). El marco tiene como propósito ayudar a comprender y combatir todos los tipos de ataques tradicionales, ya sea phishing, fuerza bruta, código malicioso, ransomware, ataques persistentes avanzados (APT), la mayoría de ellos, analizados en este libro.

Para una mejor comprensión, en esta obra se emplea el marco más conocido y utilizado en la industria que fue desarrollado por **Lockheed Martin**. Este marco es derivado de otros modelos de ataques militares y trasladado al mundo digital para ayudar a los equipos a comprender, detectar y prevenir amenazas cibernéticas [Diogenes and Ozkaya \(2022\)](#).

La Figura [I.3](#) muestra el funcionamiento de la cadena. Como se puede apreciar son siete pasos, que van desde el reconocimiento que a menudo es la primera etapa de un ataque, pasando por el movimiento lateral por la red para obtener acceso a más datos hasta la exfiltración u recolección de datos. Aunque no todos los ataques cibernéticos utilizan los siete pasos del modelo, la gran mayoría de los ataques utilizan desde el paso 2 al 6.

Figura I.3: Cadena de destrucción de seguridad cibernética

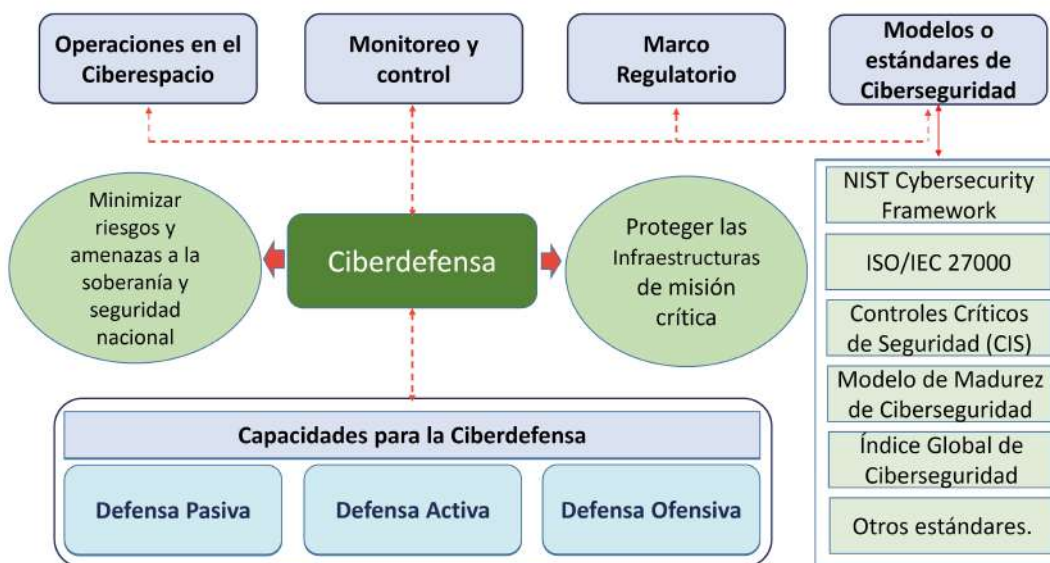


Ciberdefensa

La ciberdefensa o defensa cibernética es un conjunto coordinado de acciones preventivas, reactivas, ofensivas y de resistencia, implementadas para proteger la seguridad de la información en los sistemas, las redes, las infraestructuras de misión crítica y el uso propio del ciberespacio de un determinado Estado, país o región, en contra del ciber delito, ciber crimen o ciber guerra que pueden perturbar la soberanía de una nación [Watin-Augouard \(2021\)](#).

La ciberdefensa ha adquirido relevancia a nivel mundial en las últimas décadas dado el incremento de ciberataques en el mundo [Solar \(2020\)](#). La Ciberdefensa utiliza las técnicas y métodos proporcionados por la Ciberseguridad y otras doctrinas militares. Se ha convertido también hoy en día, en una prioridad para los gobiernos de todo el mundo, ya que proteger la información, así como los sistemas y las redes informáticas, es vital para el funcionamiento, la estabilidad de una nación y el sustento de su gente. La Figura [I.4](#) muestra un mapa conceptual de la ciberdefensa, sus elementos, requisitos, posibles estándares y capacidades de ciberdefensa.

Figura I.4: Mapa conceptual de la Ciberdefensa.



Seguridad de las Infraestructuras de misión esencial

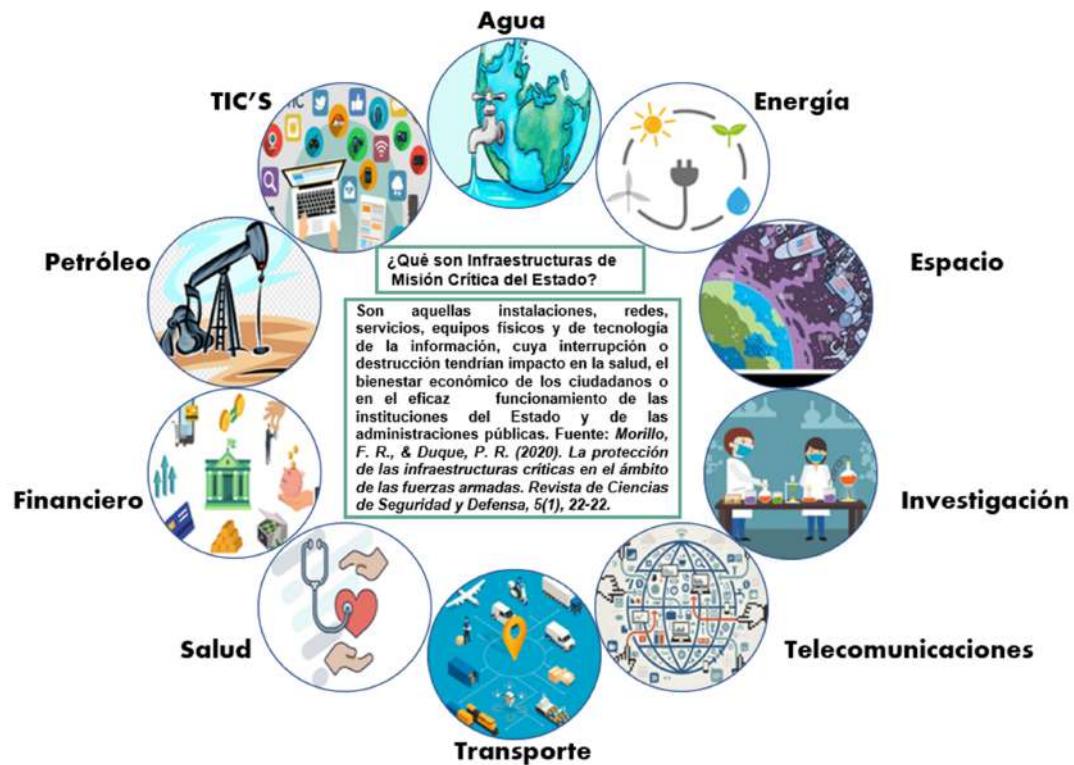
La ciberdefensa es la responsable de minimizar los riesgos y amenazas a la soberanía nacional y es la encargada de proteger la infraestructura de misión crítica del estado, considerada indispensable por los gobiernos para la articulación de una sociedad y economía que requiere de una defensa especial para la seguridad nacional [Gillard \(2020\)](#).

Las infraestructuras de misión crítica son todas aquellas instalaciones de networking, equipos, aplicaciones y servicios donde se procesa información de las áreas estratégicas como son la banca, petróleo, salud, transporte, telecomunicaciones, bienes energéticos, agua, entre otros, cuya interrupción o destrucción causarían un severo impacto en la estabilidad de una nación (Morillo y Racines, 2019) ¹. La Figura [I.5](#) explica algunas infraestructuras consideradas esenciales para el Estado.

La Ciberdefensa otorga la capacidad de neutralizar los ataques cibernéticos en tiempo real a través de las operaciones en el ciberespacio, el monitoreo y control, un marco regulatorio y un sin número de estándares de la ciberseguridad internacionalmente aceptados. Por ello es imperativo incrementar sus capacidades de defensa pasiva, activa y ofensiva, lo que implica implementar una infraestructura tecnológica, humana, procesos, mecanismos, controles y buenas prácticas que defenderán una red, sus datos y nodos del acceso o ma-

¹<http://geol.espe.edu.ec/wp-content/uploads/2018/12/5art1.pdf>

Figura I.5: Infraestructuras consideradas de misión crítica.

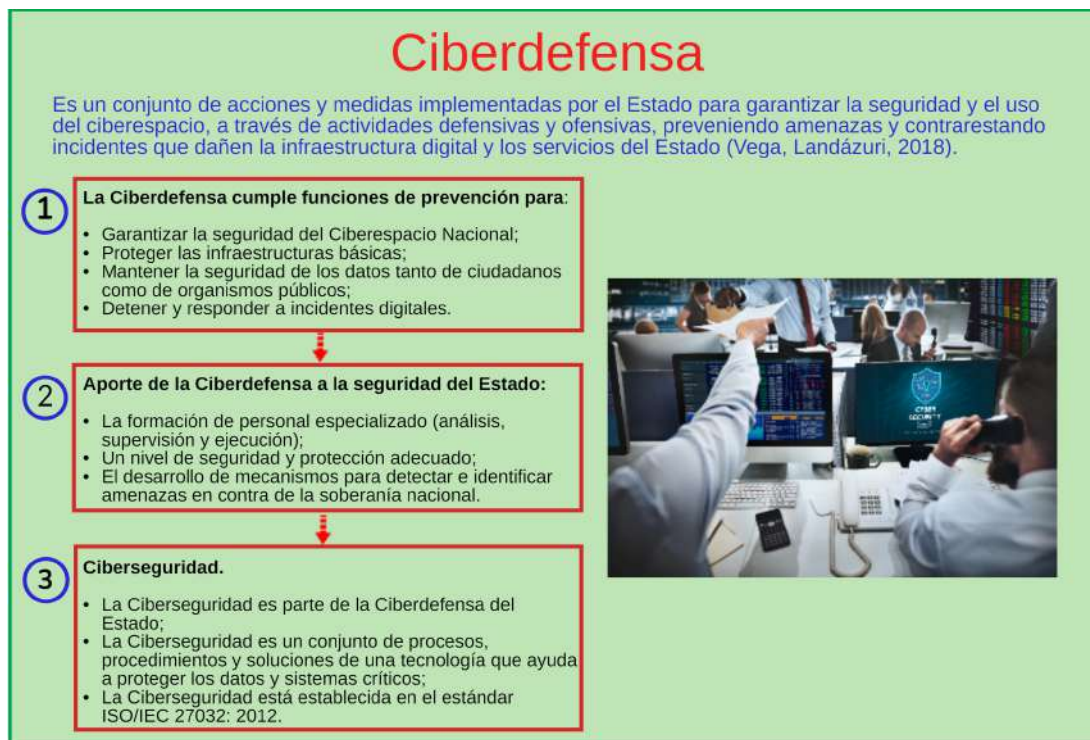


nipulación no autorizados. La Figura I.6 muestra las funciones de prevención para asegurar el ciberespacio, su aporte en la soberanía nacional y un conjunto de acciones, mecanismos, normas y procedimientos proporcionados por la Ciberseguridad, que se enfoca en la protección de la infraestructura computacional, y la seguridad de la información de las redes e Internet.

Las actividades de defensa cibernética más comunes incluyen Goethals and Hunt (2019) Creado and Ramteke (2020):

- Instalar o mantener una infraestructura tecnológica y procedimental que disuada a los delincuentes informáticos.
- Analizar, identificar y mitigar las vulnerabilidades del sistema e implementar inteligencia de amenazas.
- Fortalecer y regular tanto los sistemas nacionales de información como de las infraestructuras de misión crítica.
- Fortalecer la seguridad de los ciudadanos en el ciberespacio.
- Desarrollar las capacidades de ciberdefensa para proteger servicios públicos

Figura I.6: Definición conceptual de la Ciberdefensa.



- Fortalecer la ciberseguridad del Estado a través de la cooperación internacional.
- Incrementar la investigación, el desarrollo tecnológico y la innovación en el campo de la ciberseguridad con el fin de diseñar e implementar soluciones que incrementen los niveles de ciberdefensa.

Comando de Ciberdefensa (COCIBER)

En el ámbito de la ciberdefensa, en el 2014 las Fuerzas Armadas de Ecuador implementaron un comando de ciberdefensa con el que se viene otorgando seguridad a entidades estratégicas que están manejadas por sistemas de información denominado **COCIBER**². Este organismo fue creado para neutralizar los ciberataques, la ciberguerra y el ciber espionaje a las infraestructuras consideradas de misión críticas que pudieran ser objeto de un ciber ataque desde cualquier parte del mundo. Su misión, dependencia organizacional y principales funciones o actuaciones se explican en la Figura I.7.

La ciberdefensa emplea los mecanismos y algunos procedimientos establecidos por la ciberseguridad, especialmente aquellos destinados a contrarrestar

²<https://cociber.ccffaa.mil.ec/>

Figura I.7: Comando de Ciberdefensa de FF. AA. del Ecuador



las amenazas que puedan perjudicar a la soberanía nacional. En este contexto, los actores responsables del planeamiento y la ejecución de las acciones concernientes a la ciberdefensa de las redes, sistemas de información y telecomunicaciones esenciales son los ciber soldados, profesionales militares que están preparados para realizar operaciones defensivas y ofensivas en el ciberespacio Ron et al. (2018) Alsmadi (2023). La Figura I.8 muestra su efígie.

Retos o pilares de la Seguridad de la información

La seguridad de la información según la ISO-27000 tiene como retos el proteger la confidencialidad, integridad, y disponibilidad (CIA) de la información. El CIA establece principios básicos que permiten que la información que maneja cada entidad o persona no sea vulnerable hacia agentes externos y no sea accesible sin la debida autorización. Sin embargo, existen otros pilares propuestos por otros estándares conocidos como la autenticación, el no repudio y la trazabilidad. La Figura I.9 muestra un resumen de estos pilares. A continuación se presenta una leve descripción de los mismos.

Figura I.8: Efigie de un ciber soldado

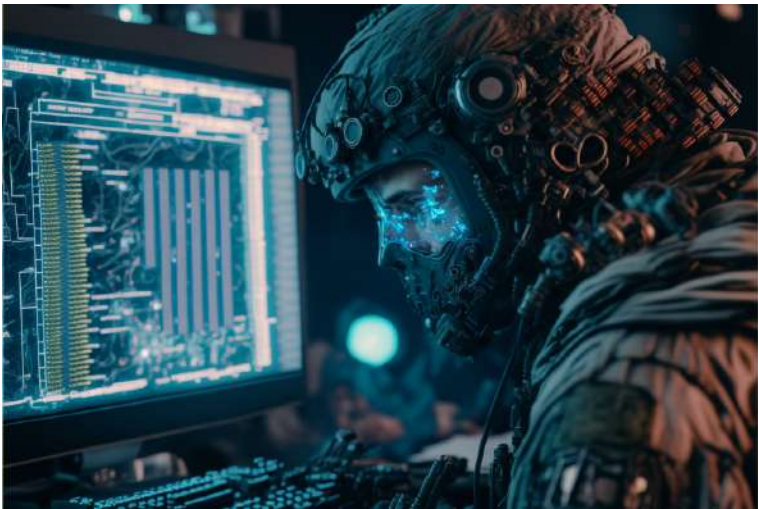


Figura I.9: Pilares de la Seguridad de la Información.

Confidencialidad	Integridad	Disponibilidad	Autenticación	No repudio	Trazabilidad
Consiste en mantener en secreto la información almacenada y que no pueda ser de fácil acceso de personas no autorizadas	Se refiere a la propiedad de salvaguardar la exactitud y completitud de los activos. La información debe ser exacta, no manipulada ni modificada.	Consiste en mantener segura la información y disponible cuando el usuario lo necesite sin importar la ubicación de donde este almacenada, sin interrupciones y de forma segura	Permite asegurar que la identificación de un usuario de un sitio web o alguna aplicación de software sea auténtico.	Permite probar la participación de las partes en una comunicación. Tanto el emisor como receptor no se puede negar que envió o recibió porque el destinatario o emisor tienen pruebas de la recepción y envío.	Consiste en reconstruir el histórico o ruta de un procedimiento informático que pueda mostrar los eventos ocurridos en sus distintas etapas.

Confidencialidad

Consiste en mantener en secreto la información almacenada y que no pueda ser de fácil acceso a personas no autorizadas, con el fin de evitar cualquier tipo de hurto de dicha información. Según Aminzade (2018), la confidencialidad es la necesidad de ocultar o mantener en secreto información determinada, claves o demás recursos con el fin de evitar la divulgación no autorizada de la misma.

Integridad

La integridad de datos se refiere a la propiedad de salvaguardar la exactitud y completitud de los activos. La información debe ser exacta, no manipulada ni modificada Aminzade (2018). El propósito de la integridad de la información es que esta no sea modificada, eliminada o destruida por entidades o

personas no autorizadas.

Disponibilidad

Consiste en mantener segura la información y disponible cuando el usuario lo necesite, sin importar la ubicación de donde este almacenada. Además, debe estar siempre accesible a los usuarios que se encuentren autorizados sin interrupciones y de forma segura [Aminzade \(2018\)](#).

Autenticación

Es un pilar de la seguridad de la información que permite asegurar que un usuario de un sitio web o alguna aplicación de software sea auténtico. Por lo tanto, permite verificar los atributos de un usuario relacionados con su identificación de acceso.

Irrenunciabilidad

La irrenunciabilidad (también conocida como no repudio), es un pilar de la seguridad de información que permite probar la participación de las partes en una comunicación. Por tanto, el emisor no puede negar que envió porque el destinatario tiene pruebas del envío. De la misma forma, el receptor no puede negar que recibió el mensaje porque el emisor tiene pruebas de la recepción [Peng et al. \(2020\)](#).

Trazabilidad

La trazabilidad consiste en reconstruir el histórico o ruta de un procedimiento informático y que pueda mostrar los eventos ocurridos en sus distintas etapas [Peng et al. \(2020\)](#), [Dubey et al. \(2022\)](#). Este término ha sido adaptado al ciclo de vida de la información como un activo de la empresa de conformidad con la ISO/IEC 25012 relacionado con los sistemas de calidad de datos [Calabrese et al. \(2021\)](#).

Elementos de un incidente informático

No se puede criminalizar el Internet porque es un mundo de inmensas oportunidades. Sin embargo, se debe potenciar las capacidades de identificación, protección, detección, respuesta y recuperación frente a la delincuencia

Figura I.10: Elementos que intervienen en un incidente informático.



en el ciberespacio. La Figura I.10 muestra los elementos que componen un incidente informático. A continuación se describen brevemente a cada uno de ellos.

Amenaza

Se refiere a cualquier causa potencial de un incidente que puede causar daños a un sistema de información o a una organización. Las causas potenciales pueden ser de origen natural, humano, industrial o procedimental que puede modificar, interrumpir, interceptar o destruir la información de un sistema. Las amenazas se presentan en contra de entidades públicas o privadas que almacenan grandes bases de datos. Las amenazas podrían surgir del descuido u omisión de usuarios vulnerables. Por tanto, una amenaza podría aprovechar dichas vulnerabilidades para perpetuar el ataque cibernético. Se dice que el crecimiento de las amenazas informáticas va a la par con el desarrollo tecnológico. La Figura I.11 muestra un mapa conceptual de las fuentes de las amenazas a la Seguridad de la Información. Sin duda, las principales son las causas de origen humano no accidental.

Vulnerabilidad informática

Es una debilidad en el software o en el hardware que permite a un atacante comprometer la integridad, disponibilidad o confidencialidad de la información. Las vulnerabilidades se deben a la falla de diseño o configuración que

Figura I.11: Fuentes de amenazas a la Seguridad de la Información.



permite que una amenaza pueda colapsar a un sistema. Así por ejemplo, puertos lógicos abiertos, aplicaciones no actualizadas, sistemas operativos no parcheados, etc.). Algunas causas de la presencia de vulnerabilidades se deben al diseño mismo del Internet desde su génesis, así por ejemplo:

- Internet desarrollado sin seguridad o atacantes maliciosos en mente.
- Desarrollado con fines de investigación por ingenieros de telecomunicaciones.
- Internet es una red que no tiene espacio, ni tiempo, no saben donde están, entran en el anonimato.
- Direccionamiento IP, Control de Congestión, QoS, Seguridad
- Desarrollado con fines de investigación.

Riesgo informático

Se define como la probabilidad de ocurrencia de que una amenaza actúe sobre una vulnerabilidad. El riesgo, es el resultado del producto de una amenaza por la vulnerabilidad. Por lo tanto, el riesgo informático es el grado de incertidumbre que existe por la posible realización de un incidente informático relacionado con la amenaza de daño respecto a los bienes o servicios que otorgan valor agregado a las empresas.

Incidente informático

Según la Organización Internacional de Normalización - ISO 27035:2016 [Shahjee and Ware \(2022\)](#), se define a un incidente de seguridad de la información como un indicador de la ocurrencia de uno o una serie de eventos indeseados o inesperados que atentan contra la confidencialidad, integridad, disponibilidad, no repudio, autenticación, y trazabilidad de la información y que pueden violar las políticas de Seguridad de la Información de una organización. Estos eventos exigen una respuesta oportuna basada en una revisión técnica de un grupo de profesionales con el conocimiento necesario para enfrentar la problemática. De esta manera para la resolución del incidente es importante tener evidencias del hecho que ayuden a entender el caso expuesto. Durante el proceso de atención el equipo técnico presentará un informe detallado de su revisión y de la solución implementada que solventaría el incidente.

Un incidente es un problema que se presenta de forma inesperada cuando el riesgo es alto y cuando se produce el cibere ataque. Es por tal motivo que las organizaciones y empresas deben disponer de un proceso de respuesta ante incidentes informáticos, esto ayudará a solventar de una manera ágil los casos presentados. Además, registrar una correcta documentación de los incidentes permitirá generar una base de conocimientos que servirá de guía para la resolución de incidentes basados en experiencias anteriores.

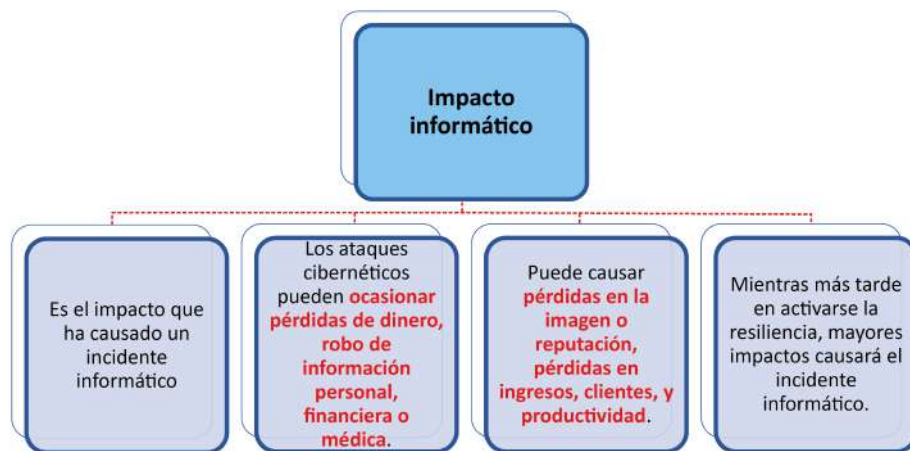
Impacto informático

Cuando ocurre un incidente informático se debe medir el impacto que ha causado. Los ataques cibernéticos pueden ocasionar pérdidas de dinero, robo de información personal, financiera o médica. Estos ataques pueden generar pérdidas en la imagen o reputación, pérdidas en ingresos, clientes, y productividad. Mientras más tarde en activarse la resiliencia, mayores impactos causará el incidente informático. La Figura [I.12](#) muestra un resumen del impacto informático.

Resiliencia

Es la capacidad de una organización, empresa, estado, entidad etc., a resistir y a recuperarse rápida y efectivamente de un ataque. En psicología se dice que resiliencia es la necesidad de una persona a recuperarse ante situaciones problemáticas y continuar con su vida. Actualmente en la era digital, la mayoría de empresas están implementado la ciber resiliencia ya que sus usuarios

Figura I.12: Impacto o efectos que pueden producirse por un incidente informático.



han incrementado sus actividades en el ciberespacio. Con esto tendrían grandes ventajas ante sus competidores y estarán vistas en el mercado de una mejor manera. Entre las ventajas que tendrían las empresas que mantengan un sistema con resiliencia podemos enumerar: mejora de la seguridad del sistema, reducción de pérdidas financieras, cumplimiento de requisitos legales, mejora de la cultura en seguridad informática y el proceso interno.

Lecciones aprendidas. En este capítulo se explicó la cadena de destrucción de la ciberseguridad, que es un modelo orientado a rastrear las etapas de un ataque cibernético desde su inicio hasta que se produce el ciber ataque. Según la ISO-27000, la seguridad de la información tiene como retos el proteger la confidencialidad, integridad, y disponibilidad (CIA). El CIA establece principios básicos que permiten que la información que maneja cada entidad o persona no sea vulnerable hacia agentes externos y no sea accesible sin autorización. Además, se señalaron otros desafíos como la autenticación, identificación, no repudio y trazabilidad, establecidos por otras normas aceptadas como el marco de trabajo de Ciberseguridad de la NIST. También se analizaron los elementos que componen un incidente informático, tales como amenazas, vulnerabilidades, riesgo, incidente, impacto y resiliencia. Finalmente, se estableció a la ciberdefensa como la responsable de minimizar los riesgos y amenazas a la soberanía nacional, la cual además es la encargada de proteger la infraestructura de misión crítica del Estado.

Sitios de Interés

1. **BID, Banco Interamericano de Desarrollo.** Reporte de Ciberseguridad 2020: riesgos, avances y el camino a seguir. URL: <https://doi.org/10.18235/0002513>
2. **NIST,** Cybersecurity Framework. March, 2023. URL: <https://www.nist.gov/cyberframework>
3. **KARSPERSKY,** Mapa en tiempo real de las ciber-amenazas <https://cybermap.kaspersky.com/es>



CAPÍTULO II

Ciber Crimen

Introducción

Existen diferentes tipos de ciber ataques, ciber delincuentes y delitos cibernéticos en Internet, en redes de datos, de telecomunicaciones y redes celulares, que forman parte del cibercrimen, de la ciberguerra y del ciber acoso en contra del usuario vulnerable, las organizaciones e inclusive de la soberanía de las naciones. La Figura II.1 es una representación de un ciber delincuente que es la persona que buscará vulnerabilidades en las redes para aplicar distintas técnicas que le permitan perpetuar ciber delitos.

Figura II.1: Ciber delincuente o ciber atacante (hacker!).



Una de las causas del incremento de Ciberdelitos sin duda es la proliferación de los tipos de ataques cibernéticos (Denegación de Servicio, Ingeniería Social, ataque a las aplicaciones Web, Fuerza Bruta, Escaneo de Puertos, ciberspionaje, entre otros). Detrás de estos ciberataques se encuentran delincuentes informáticos, causantes de pérdidas financieras, suplantación de identidad, acoso sexual, ciberterrorismo, etc., (crackers, hackers, spammers, phishers, hactivistas, phreakers, lammers, ciberterroristas).

Los ciber delitos son incidentes delictivos caracterizados por el uso indebido de las Tecnologías de la Información y comunicación (TICs), incluidos la infraestructura de hardware y software, para cometer uno o más fraudes,

falsificaciones, dolos, robos, hurtos, sobornos o desfalcos [Creado and Ramteke \(2020\)](#).

Este capítulo proporciona detalles específicamente de los llamados delitos cibernéticos (ciber delitos), los tipos de ataques cibernéticos y los tipos de ciber atacantes. Los fundamentos esenciales, tipología, causas, definiciones, leyes o reglamentos, instituciones en contra del ciberdelito, son expuestos a continuación.

¡Bienvenidos!

Delitos cibernéticos

De acuerdo a [Furnell \(2021\)](#) un ciber delito es todo aquel acto ilegal realizado por un ciber-delincuente ocurrido en el ciberespacio, utilizando las redes de comunicaciones y diversos dispositivos móviles. Dichos actos ilegales pueden atentar en contra de la integridad, disponibilidad y confidencialidad de los datos y de los sistemas informáticos.

De conformidad con el estándar ISO 27035, cuando un ataque o ciberdelito ha sido consumado, este toma la característica de un incidente de seguridad de la información. Un incidente puede ser generado por uno o más eventos informáticos indeseados o inesperados, que tienen una probabilidad de comprometer las operaciones de negocio y en consecuencia la ciberseguridad de las empresas o personas [Tøndel et al. \(2014\)](#).

En diversos países se cuenta con Leyes que sancionan los ciber delitos con penas de privación de libertad. En el caso particular del Ecuador, en el Código Orgánico Integral Penal (COIP) ^I, del Artículo 178 hasta 234 se encuentran tipificados los ciber delitos. El COIP establece penas y sanciones a aquellos que atenten mediante la revelación ilegal de datos, fraudes financieros, robo de información, accesos no autorizados, entre otros. Algunos de los ciberdelitos más delicados y tipificados pro el COIP son: Pornografía infantil, violación del derecho a la intimidad, revelación ilegal de información, interceptación de comunicaciones, ingeniería social, fraude informático, ataque a la integridad de sistemas informáticos, delitos contra la información pública reservada legalmente, acceso no consentido a un sistema informático, entre otros [Martins et al. \(2022\)](#).

Las Tablas [II.1](#), [II.2](#) y [II.3](#) listan las estadísticas registradas de los delitos de

¹https://www.defensa.gob.ec/wp-content/uploads/downloads/2021/03/COIP_act_feb-2021.pdf

Fraude Digital, Incidentes informáticos, y Violencia Digital, respectivamente, según la Unidad Nacional de Ciberdelitos (CIBERPOL), de la Policía Nacional del Ecuador al 19 de marzo de 2022.

Tabla II.1: Tipos de ciber delitos: Fraude digital. Fuente: CIBERPOL

DESCRIPCIÓN	CANT.
Art.190 Apropiación fraudulenta por medios electrónicos	896
Art. 186 Estafa	212
Art. 323 Captación ilegal de dinero	3
Art. 231 Transferencia electrónica de active patrimonial	17
Subtotal	1218

Tabla II.2: Tipos de ciber delitos: Incidentes Informáticos. Fuente: CIBERPOL

DESCRIPCIÓN	CANT.
Art. 234. Acceso no consentido a un Sistema informático, telemático o de telecomunicaciones.	78
Art 232. Ataque a la integridad de sistemas informáticos.	32
Art 230. Interceptación legal de datos.	11
Art. 229. Revelación legal de base de datos.	6
Art.212 Suplantación de identidad.	58
Art. 178 Violación a la intimidad.	228
Subtotal	407

Cabe señalar, que la Fiscalía General del Estado Ecuatoriano, en el Registro Oficial Nro. 86, publicó el 8 de junio de 2022 la creación de la Unidad Nacional Especializada en Investigación de Ciberdelito², que tiene la función de investigar delitos tipificados en el COIP.

En este mismo contexto, mediante Acuerdo Ministerial N° 0080, del 08 de marzo de 2019, en el Estatuto Orgánico de la Policía Nacional de Ecuador, se creó la Unidad de Delitos Tecnológicos, hoy Unidad Nacional de Ciberdelito³.

Tipos de ataques cibernéticos

Existen diversos tipos de ataques cibernéticos en Internet como virus, troyanos, gusanos, espías, de ingeniería social, código malicioso (malware), de

²<https://www.fiscalia.gob.ec/transparencia/2022/julio/a3/RESOLUCION-034-FGE-2022.pdf>

³<https://www.policia.gob.ec/wp-content/uploads/downloads/2019/06/ACUERDO-MINISTERIAL-0080.pdf>

Tabla II.3: Tipos de ciber delitos: Violencia Digital. Fuente: CIBERPOL

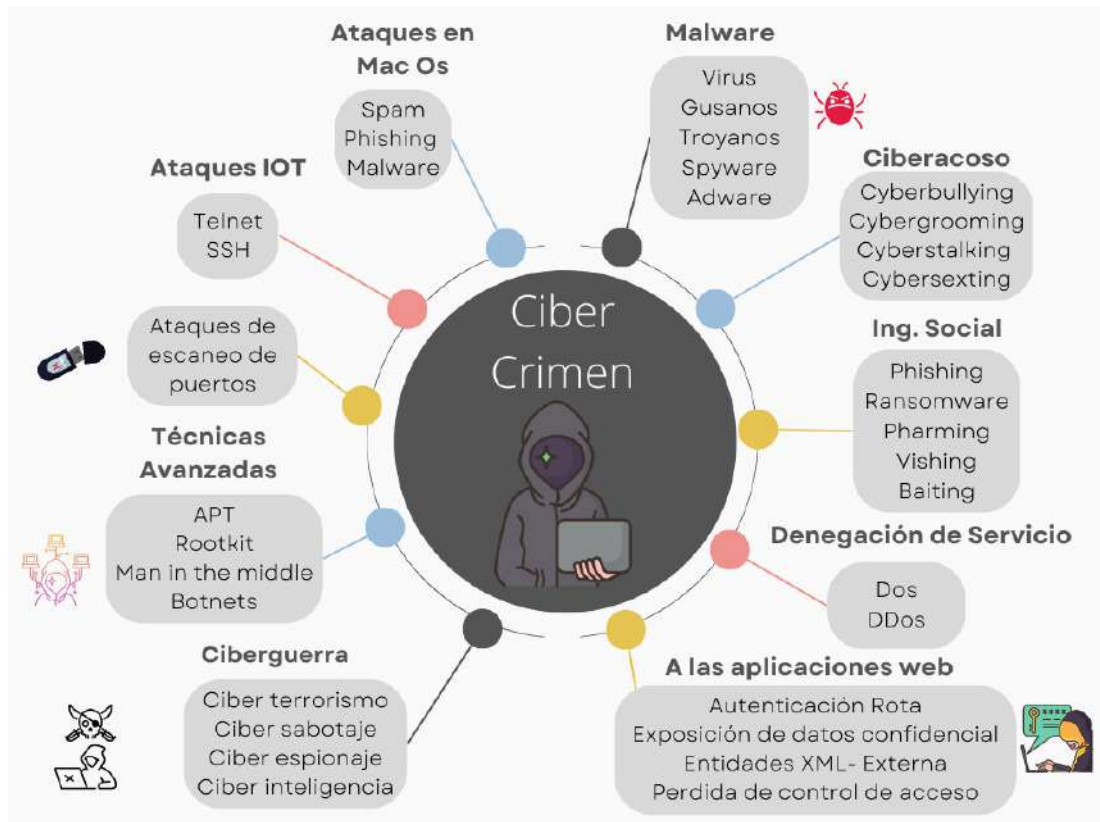
DESCRIPCIÓN	CANT.
Art. 166 Acoso sexual.	18
Art. 104 Comercialización de pornografía con utilización de niñas, niños o adolescente.	7
Art 173 Contacto con finalidad sexual con menores de dieciocho años por medios electrónicos.	18
Art 100 Explotación sexual de personas.	1
Art 174 Oferta de servicios sexuales con menores de dieciocho años por medios electrónicos.	2
Art 103 Pornografía con utilización de niñas, niños o adolescentes.	66
Art 91 Trata de personas	228
Art 172 Utilización de personas para exhibición pública con fines de naturaleza sexual.	4
Art. 170. Abuso sexual.	3
Art 154. Intimidación.	73
Art 168 Distribución de material pornográfico a niñas, niños y adolescentes.	228
Subtotal	197

escaneo de puertos, entre otros [Cazares et al. \(2021\)](#). Estos ataques pueden introducirse en un equipo llegando a obtener accesos de usuario o administrador e inclusive a colapsar al sistema computacional [Rath et al. \(2021\)](#). Así, los atacantes cibernéticos, podrán controlar y conseguir información valiosa, como datos almacenados y contraseñas previamente registradas, siendo información atractiva para el ciber atacante [Davidson \(2021\)](#).

Hoy en día el objetivo más común de los ataques cibernéticos es la información sensible de las empresas; debido a la validez e importancia que posee, que suele ser confidencial y solo disponible para personas autorizadas [Khazargarov et al. \(2021\)](#). Es por ello que se debe tener en cuenta ciertas medidas que puedan evitar la violación de la seguridad de la información, es decir, detectar y mitigar los diferentes tipos de ataques. Algunos de ellos incluyen externalizar servicios, contar con antivirus y su suscripción que garantice la protección, capacitar y concienciar a los usuarios, mantener actualizado el software, proteger contraseñas, entre otras medidas. Todo ello forma parte de las técnicas, mecanismos y estrategias en las que se apoya la Ciberseguridad.

Los ataques cibernéticos son una fuente de constantes amenazas, pues a más de atacar a los usuarios vulnerables, también arremeten en contra de las infraestructuras críticas de los países, lo cual puede afectar de forma directa y

Figura II.2: Clasificación del ciber crimen.



simultánea a millones de personas [Amaral \(2014\)](#). El tema se ha transformado en un tema público a través de varios casos divulgados. Así por ejemplo, el ataque contra sitios web de Estonia en 2007 (infraestructuras de misión crítica como la banca, salud, energía eléctrica, ministerios) [Donner \(2007\)](#); los ciber ataques mediante el malware Stuxnet en 2010 recibidos por las centrifugadoras nucleares iraníes en Natanz [Sibai et al. \(2020\)](#); las filtraciones realizadas por WikiLeaks; las infiltraciones de ciber espionaje global que realizó Edward Snowden en 2013 [Goedeker \(2021\)](#), o el ataque realizado a través del ransomware WannaCry en 2017 que afectó a más de 150 países (Rusia, EE.UU., Reino Unido, China, Italia, etc. 2014) [Furnell and Emm \(2017\)](#); los 40 millones de ciber ataques sufridos en Ecuador por la salida de Julián Assange de la Embajada del Ecuador en Londres en abril de 2019, según el Diario el Comercio de Quito, Ecuador, entre otros.

La Figura [II.2](#) es una infografía de los principales tipos de crímenes cibernéticos establecidos en el mundo. Una leve descripción se presenta a continuación.

Malware

La palabra malware viene de la unión de dos palabras en inglés **malicious software**. Se trata de un código de programa, artefacto de software o de una aplicación cuyo objetivo es hacer daño al dispositivo en el que se ha conseguido alojar, instalar o infiltrar sea un computador, dispositivo electrónico móvil o un sistema informático.

El malware es un código malicioso y malintencionado que se ha diseñado para ocasionar daños o realizar acciones no deseadas en un sistema informático. Algunos ejemplos de malware incluyen virus, gusanos, troyanos, espías (spyware), adware, entre otros. La Figura II.3 es una infografía de los principales tipos de malware. Una leve descripción se presenta a continuación.

Figura II.3: Tipos de Malware.



Sea cual sea el tipo de malware, todos siguen el mismo patrón básico que inicia cuando el usuario descarga o instala involuntariamente el malware, que infecta el dispositivo. Cada tipo de malware utiliza diferentes técnicas o métodos que van desde camuflarse como una aplicación normal, engañar al usuario para instalarlo, o ser instalado por otra aplicación diferente.

- **Virus informático.-** Es un tipo de malware destructivo, escrito intencionadamente, que se centra en alterar el correcto funcionamiento de un sistema computacional sin el permiso o el consentimiento del usuario para lograr fines perversos sobre el dispositivo. Un virus precisa ser puesto en ejecución por el usuario, quien asume que se trata de una aplicación legítima que puede utilizarse sin imaginarse que ésta puede infectar el equipo.
- **Gusano informático.-** Es un malware que no necesita de la intervención del usuario ni modificar ningún archivo existente. Puede reproducirse, replicarse y propagarse a sí mismo y enviar copias a otros equipos conectados a la red. Son programas maliciosos que toman el control de un equipo infectado (botnets, zombis, etc.). Pueden actuar de forma simultánea cuando un ejecutor le ordena enviar SPAM masivamente, propagar código malicioso, o transmitir diferentes tipos de ataques informáticos.
- **Troyano.-** Es un código malicioso que se disfraza dentro de un programa de software legítimo para alojarse en el interior de un sistema computacional varios guerreros infectados, en el mismo contexto que el Caballo de Troya. Un troyano se muestra al usuario como un programa legítimo que trata de pasar desapercibido mientras accede a un dispositivo con la intención de ejecutar acciones ocultas para brindar a un ciber atacante acceso remoto al dispositivo contaminado. Estos no se propagan a sí mismos.
- **Spyware.-** Es un código malicioso que se instala en un equipo electrónico por sí sólo o mediante la interacción de una segunda aplicación que lo coloca. Se caracteriza porque viene ininteligible adjunto a otros programas malignos que se instalan de manera regular, lo que dificulta su detección. Un spyware suele operar a escondidas intentando no ser detectado para recolectar información sobre el usuario u organización dueña de un sistema de forma no autorizada para enviarla a terceros.
- **Adware.-** El término está compuesto por dos palabras en inglés: advertising o publicidad y software. Es un programa o aplicación de software publicitario malicioso que es introducido en un dispositivo con el fin de mostrar publicidad de manera automática mientras el usuario navega por Internet. Normalmente se alberga en los equipos durante el proceso de instalación de otras aplicaciones. De esta manera, el fabricante del

software o de diversos productos obtiene ingresos generados por estas publicidades.

- Rootkit.- Un rootkit es un programa o artefacto de software malicioso que le otorga a un ciber atacante acceso remoto y control sobre una computadora u otro sistema. Los rootkits desactivan el software antivirus y antimalware con el propósito de infiltrarse y robar datos, vulnerar equipos, extorsionar y exigir un rescate o realizar otras acciones ilícitas.

Ataques de Denegación de Servicio

Un ataque de denegación de servicio tiene como objetivo inhabilitar el uso de un sistema, una aplicación de software o un dispositivo conectado a una red de comunicaciones o de telefonía celular, con el propósito de bloquear el servicio para el que está destinado [Fuentes et al. \(2017b\)](#). Este ataque busca desconectar el equipo de la red, que es la fuente que ofrece la información. La mayoría de los ataques intentan irrumpir en el sistema para conseguir el control de una máquina y darse el lujo de aprovechar sus vulnerabilidades. Una gran cantidad de solicitudes al sitio web se realizan desde la misma computadora o dirección IP, consumiendo así los recursos proporcionados por el servicio, hasta que deja de responder y comienza a rechazar las solicitudes, entonces el servicio tendrá un error.

También existen los ataques de denegación de servicio distribuidos, DDoS (Distributed Denial of Service), que se llevan a cabo generando un gran flujo de tráfico desde diferentes puntos de conexión hacia un mismo destino. En este caso, las solicitudes o conexiones se realizan utilizando una gran cantidad de computadoras o direcciones IP. Todas estas solicitudes se realizan de forma simultánea y al mismo servicio comprometido. El ataque DDoS es más difícil de detectar debido a la cantidad de solicitudes que provienen de diferentes direcciones IP y el administrador no puede bloquear la dirección IP que envía la solicitud.

Ataques a las Aplicaciones Web

Las aplicaciones web son herramientas esenciales para el desarrollo de organizaciones a nivel comercial. Al igual que son un pilar fundamental para varios sectores, se han convertido en el objetivo número uno para la explotación de amenazas. La revista Application Vulnerability elaboró un reporte en el cual se afirmaba que los ataques a las aplicaciones web pueden llegar a ser una

de las amenazas más críticas para una empresa, ya que podría tener diferentes debilidades. Por otra parte, existen diferentes tipos de ataques que pueden representar amenazas dependiendo en la manera en cómo actúa la herramienta maliciosa y el riesgo que corre una aplicación ante un ataque. Es decir, en el supuesto caso de que el servidor haya sufrido un ataque de seguridad la aplicación no funcionará correctamente.

Los principales ataques que pueden afectar a los servidores web son la inyección SQL, Cross-Site Request, ataque de envenenamiento de cookies, robo de cookies, ataques de Phishing, navegación forzada, división de respuesta HTTP. Este tipo de ataques también pueden ser explotados si existen archivos utilizados por la aplicación sin privilegios previamente configurados de una manera adecuada, comprometiendo la confidencialidad de los recursos.

Ataques de Escaneo de Puertos

El ataque de escaneo de puertos o Port Scan es un proceso mediante el cual, se analizan automáticamente los puertos de una máquina conectada a la red con la finalidad de verificar cuáles están abiertos, cerrados o si cuenta con algún protocolo de seguridad. Al escanear puertos, además de los mismos, se puede obtener información de aquellos puertos lógicos que están protegidos con cortafuegos, el tipo de sistema operativo que tiene instalado el computador o servidor y cuáles son las direcciones IP vecinas a la máquina escaneada. [Algaolahi et al. \(2021\)](#).

El propósito habitual de un ataque de escaneo de puertos es mapear el sistema operativo del equipo o dispositivo, así como las aplicaciones y/o servicios que se están ejecutando para comprender cómo está protegido y qué vulnerabilidades pueden estar expuestas para ser explotadas. El escáner de red escanea toda su infraestructura de red para obtener y registrar las métricas de disponibilidad, rendimiento y utilización de sus recursos de red. Realiza barridos de ping y escaneos de SNMP para identificar hosts y servicios activos que se ejecutan en su red. Entre algunas de las herramientas más utilizadas se pueden señalar: Nmap, Netcat, Port Authority, Advanced Port Scanner, Network Scanner by MiTeC y NetScanTools. [Fuertes et al. \(2017a\)](#)

Tipos de ciber atacantes

Los ciber atacantes o delincuentes informáticos evolucionan día a día. Con nuevas tecnologías acosan a los usuarios y empresas. Su accionar, muchas ve-

ces genera pérdidas representativas de información personal como también de dinero a base de sabotaje por su divulgación. Detrás de estos ciberataques se encuentran delincuentes informáticos, hackers y organizaciones criminales. Cuando un hacker ingresa a una red o sistema informático, se denomina hackeo de seguridad. El término correcto para este tipo de hackeo ilegal es crackeo. Ahora será mejor lograr comprender lo que es un cracker, que sucede cuando alguien realiza un ataque de seguridad. Los crackers usan tecnología para acceder a una computadora, programa o cuenta. Los métodos de crackeo a menudo no son sofisticados como las técnicas habituales de hackeo.

Para prevenir un ataque se debe estar preparado con una instalación de software de forma legal para asegurarse ante virus, para eso también debe haber una instalación de antivirus con el sistema adecuadamente definido, una de las recomendaciones básicas es la forma correcta del uso de contraseñas, las cuales deben de ser largas, complejas, se incluyen letras y números. Sin embargo, es fundamental encriptar la información importante para mantenerla segura y confidencial. Así como la seguridad informática avanza, también los ataques lo hacen de manera constante y grave, logrando perjudicar a usuarios o empresas. Lo importante es evitar, estar prevenidos y saber cuándo se está sufriendo de un ataque, para esto es fundamental conocer las formas correctas de seguridad, dado que sea el caso contrario se corre un alto grado de padecer y tener consecuencia de estos tipos de inconvenientes. La Tabla II.4 lista los principales ciber delincuentes que se encuentran en el ciberespacio.

Tabla II.4: Tipos de ciber atacantes.

ATACANTE	DESCRIPCIÓN
Cracker	Personas que rompen o vulneran algún sistema de seguridad de forma ilícita.
Hacker	Su fin es detectar defectos de seguridad para acceder o irrumpir ilegalmente en los equipos y sistemas informáticos.
Sniffer	Captura y analiza los paquetes que se envían y reciben con fines maliciosos.
Phisher	Persona que engaña para obtener contraseñas, números de tarjeta de crédito, etc.
Phreaker	Pirata telefónico, utiliza el teléfono para cometer delitos informáticos
Hactivists	Abuso de la web para promover causas sociales o fines políticos.

Crackers

Se conoce como cracker al delincuente cibernético dedicado a romper o vulnerar la seguridad de la información de algún dispositivo o sistema informático en funcionamiento. Su meta es delinquir, robar datos, suplantar identidad, acosar, modificar, alterar, e incluso utilizar software privativo o comercial gratis, sin derecho. Un cracker se caracteriza porque cuenta con amplios conocimientos de ciberseguridad, dominan bien el ámbito en el que se mueven, están motivados por fines lucrativos, en señal de protesta, desafío o incluso para realizar espionaje industrial. Algunos crackers se dedican a alterar el contenido de determinado software, otros en en alterar páginas webs o sistemas informatizados, algunos prefieren la ruptura de la criptografía, sistemas de protección y licencias de los diferentes softwares. Unos pocos rastrean llamadas telefónicas o realizan llamadas sin gasto alguno [Kizza \(2020\)](#).

Hackers

Según el diccionario de la Real Academia de la Lengua Española (RAE), un hacker es una persona con grandes habilidades y conocimientos en el manejo de computadoras que investiga un sistema informático para detectar fallos de seguridad y desarrollar técnicas de mejora. Un hacker además es el encargado de programar artefactos de software con el objetivo que impedir el acceso a un sistema privado por personas no autorizadas. Un hacker no siempre tiene fines ilícitos detrás de su exploración. Sin embargo, existen, hackers que utilizan sus conocimientos de forma maliciosa [Kizza \(2020\)](#). Para realizar piratería ética o ilícita, los hacker normalmente utilizan diversas herramientas de software disponibles en el Internet tales como Acunetix, Invicti, Intruder, Nmap, Wireshark, Ettercap, Maltego, de cientos de posibilidades. Véase la efigie de un hacker en la Figura [II.4](#).

Hacktivistas

Los hacktivistas son ciber delincuentes que se fusionan para realizar ciberataques en favor de determinadas causas políticas o ideológicas. Suelen enfocarse en industrias enteras o interrumpir las actividades de las organizaciones públicas. En ocasiones suelen atacar a instituciones previamente definidas que no coinciden con su doctrina, puntos de vista o prácticas políticas [Kizza \(2020\)](#).

Figura II.4: Efigie de un hacker



Phreakers

Es un término que proviene de la combinación de las palabras en inglés phone (teléfono) y freak (loco). Son ciber delincuentes que se especializan en la manipulación fraudulenta del sistema telefónico para realizar llamadas telefónicas gratuitas. El phreaking originalmente se refería a aplicar la ingeniería inversa de los tonos específicos utilizados por las compañías telefónicas para enrutar llamadas. Al emular esos tonos, los phreaks podrían hacer llamadas gratis a larga distancia en todo el mundo [Kizza \(2020\)](#).

Amenaza interna (insider Threat)

Es la probabilidad de ocurrencia de un ataque interno que se origina dentro de la organización y que puede involucrar a un empleado, socio comercial, o interesado (stakeholder), vigente o cesante, que tiene acceso a la información o a las cuentas privilegiadas de una compañía. Esto es peligroso pues comúnmente, las medidas de seguridad tradicionales se enfocan en las amenazas externas y no siempre son capaces de identificar una amenaza interna generada en el interior. Las amenazas internas incluyen: (i) Insider malicioso, que están familiarizados con las políticas y los procedimientos de seguridad de una organización, así como con sus vulnerabilidades, quien intencionalmente abusa de credenciales legítimas para robar información por motivos financieros o personales. (ii) Insider distraído, que sin conocer, expone el equipo, dispositivo o sistema a amenazas externas a causa de omisión o error. (iii) Insider impostor externo, que técnicamente es un extraño externo a la compañía que se hace pa-

sar por empleado o socio y que ha logrado obtener privilegios de acceso a una red interna o privada.

Crimen organizado cibernético

Son grupos de ciber delincuentes instaurados que aprovechan las oportunidades que le brindan las TICs junto con el ciberespacio para cometer delitos cibernéticos. Estos grupos explotan la ingenuidad y avaricia de los usuarios a través de servicios en línea. Así por ejemplo, una red de apuestas por Internet, estafas piramidales, extorsión mediante ataques de ransomware, tráfico de drogas contratando a piratas informáticos.

Lecciones aprendidas. En este capítulo se expuso que existe una correlación entre tipos de ciber ataques, ciber delincuentes y delitos cibernéticos. A mayor proliferación de ciber delincuentes, mayor número de ciber ataques y ciber delitos. Los ciber delitos son actos ilegales caracterizados por el uso indebido de las TICs por parte de los ciber delincuentes. En el Ecuador los delitos informáticos están tipificados por el COIP que establece penas y sanciones a aquellos que la incumplan. Para denuncias, además fue creada la Unidad Nacional Especializada en Investigación del Ciberdelito de la Fiscalía General de la Nación. Así mismo desde el 2019 existe la Unidad Nacional de Ciberdelitos, de la Policía Nacional del Ecuador. Existen una variedad de tipos de ataques cibernéticos, así como una diversidad de tipos de ciber delincuentes, los cuales fueron caracterizados en el desarrollo de este capítulo.

Sitios de Interés

1. **OSI**, Oficina de Seguridad del Internauta. Virus: ¿Cómo prevenirlos y evitarlos?. URL: <https://guiasbib.upo.es/ciberseguridad/virus>
2. **OSI**, Oficina de Seguridad del Internauta. Kit de concienciación en ciberseguridad. URL: https://guiasbib.upo.es/ciberseguridad/consejos_ciberseguridad
3. **ITU**, Índice Global de la Cibseguridad. URL: https://www.itu.int/dms_pub/itu-d/opb/str/D-STR-GCI.01-2021-PDF-S.pdf



Ciber Acoso

Introducción

El confinamiento de las personas y el uso masivo de Internet a través de la práctica obligatoria de tele-trabajo, tele-educación y tele-medicina, generados como consecuencia de la pandemia provocada por el COVID-19 en nuestra sociedad ha incrementado el Ciberacoso o acoso cibernético (Cyberbullying). De acuerdo con Englander et al. (2017) el Ciberacoso es un acto agresivo e intencional llevado a cabo por un individuo o grupo, a través del uso de computadoras, teléfonos celulares u otros dispositivos electrónicos de contacto repetidamente y a lo largo del tiempo contra una víctima provocando daños psicológicos, estrés, infelicidad, depresión e incluso el suicidio.

En forma general se define el acoso cibernético como el acoso que ocurre a través de medios electrónicos o digitales en contra de víctimas de edades similares o no. Para que exista el acoso debe existir el victimario o perpetrador, el medio mediante el cual se realiza el acoso, y la víctima Bauman (2015). La Figura III.1 ilustra una víctima del acoso cibernético con insultos, burlas e intimidaciones comunes por parte del o los perpetradores.

Figura III.1: El acoso cibernético.



En este capítulo se aborda el tema del Ciberacoso como un ciberdelito que afecta a niños y adolescentes. Aunque existan diversos tipos de acosos ciberné-

ticos, aquí se analizarán el cyberbullying, el cyber-grooming, el cyber-sexting, el cyber-stalking. Para llevarlo a cabo, se examina los tipos de Ciberacoso existentes caso por caso, e incluye sus fundamentos, los métodos y técnicas utilizadas, algunas estadísticas, frecuentes señales y medidas de prevención o formas de afrontarlos.

¡Bienvenidos!

Acoso cibernético, ciber acoso o Cyberbullying

Definición

En la actualidad existen varias formas de violencia mediante el uso del Internet, dirigido a cientos de internautas sin distinguir su edad, sexo, raza, religión o condición social. Desde el 2007 se viene utilizando el término Cyberbullying como una forma de acoso psicológico que se ejerce a través de los dispositivos electrónicos o digitales. El Cyberbullying es la práctica de hacer enojar a los usuarios de manera deliberada, inteligente y secreta a través del Internet, al hacer comentarios groseros, difamatorios, calumniadores dirigidos a una víctima seleccionada.

El acoso cibernético puede ocurrir a través de una llamada telefónica, mensaje de texto, mensaje de WhatsApp, correo electrónico, imagen, video, mensaje instantáneo, sitio web o sala de chat. Por tanto, los usuarios que usan Gmail, Twitter, Facebook, Whatsapp, etc., son los más vulnerables (ver Figura III.2).

El cyberbullying es diferente al acoso tradicional debido a que las víctimas no saben quién es el acosador o por qué son atacados. Puede hacerse viral, pues una gran cantidad de personas pueden enterarse muy rápidamente. Se puede hacer remotamente y de manera impersonal. El ataque no se realiza de manera física, no tiene objetivos de naturaleza sexual y normalmente se realiza entre personas de la misma edad. A continuación se analizan las principales características.

Características

El Cyberbullying aprovecha el ciberespacio, que es el ecosistema ideal debido a que está en constante funcionamiento las 24 horas de los 365 días del año. Los usuarios necesitan estar conectados con un alcance global. En el Internet ya no existe ni espacio ni tiempo, de modo que el perjuicio para la víctima acosada puede ser incalculable.

Figura III.2: El acoso cibernético o cyberbullying.



El Cyberbullying se perpetra en el ciberespacio, pues facilita que los victimarios oculten su nombre, su fotografía o su identidad, condición denominada anonimato. Este mecanismo intenta conseguir que el victimario no deje huellas o evidencias de tal forma que no sean descubiertos. El usuario anónimo agrava el problema para las víctimas, pues ellas desconocen quién es el causante del daño generado.

Los acosadores cibernéticos que descubren el perfil de un usuario común en el Internet, pueden acosar a los padres, maestros, compañeros de clase o del trabajo de la víctima. Cuando el Cyberbullying se hace viral, es decir se propaga, se convierte en problema peligroso para la víctima.

Los acosadores cibernéticos engañan a la víctima, y luego amenazan en publicar o publican su información personal privada en línea. Así mismo, incitan a otros a acosar a la víctima también. Luego animan al grupo de compañeros para que también se burlen, se alejen, o lo excluyan.

Los acosadores cibernéticos amenazan con revelar información confiden-

cial del internauta, con contenido vergonzoso, que perjudicaría su imagen. No se detendrá para destruir su reputación o que le despidan de tu trabajo.

Los acosadores cibernéticos se ocultan detrás de los monitores de sus dispositivos electrónicos para atormentar a sus víctimas; esto hace que sea difícil rastrear al perpetrador. La Figura III.3 es una infografía del la forma de actuación de los acosadores cibernéticos. Una leve descripción se presenta a continuación.

Figura III.3: Formas de acoso cibernético (cyberbullying).



Tipos de ciber acosadores

El Ciberbullying se caracteriza porque el victimario tiene la intención de hacer daño a la víctima, se produce en más de una ocasión y se identifica además porque existe una desigualdad de poder que beneficia al ciber atacante. De acuerdo con www.stopcyberbullying.org referenciado [Gao et al. \(2020\)](#), generalmente existen algunos tipos de personas que acosan cibernéticamente:

- Codiciosos de poder.- Son aquellos que buscan la atención de sus compañeros, quieren mantener el control intimidando a la víctima, esperan una reacción, y controla con el miedo.
- Vengador.- victimario que fue acosado cibernéticamente en el pasado, el cual busca vengarse de los acosadores, puede ser menos popular, pero generalmente tiene habilidades informáticas superiores a la medianía de compañeros.
- Trastornos de personalidad.- victimarios que actúan con el fin de generar entretenimiento o para aliviar el aburrimiento. Tiene como objetivo aumentar su propia popularidad menospreciando a los demás. Suelen hacerlo apoyados por un grupo, es intimidador dentro y fuera de línea.
- Justiciero.- Busca justicia en nombre de aquellos que han sido intimidados; tiene como objetivo proteger a los amigos; No se visualiza como un ciber acosador.
- Atracador.- Aquel victimario que le gusta irrumpir en las cuentas de las redes sociales de alguien, utilizando un perfil inexistente. A menudo, el acosador intenta someter al usuario o arruinar su reputación publicando comentarios inadecuados, humillantes o provocativos.
- Inconsciente.- Utiliza Internet sin cuidado, sin considerar el impacto potencial en los demás. No lastima intencionalmente a otros, puede que no se dé cuenta de que es acoso cibernético.

Cybergrooming

Es un tipo de acoso sexual cibernético mediante el cual los victimarios seleccionan a una víctima con engaños y se ganan la confianza hasta capitalizar el contacto sexual [Mladenović et al. \(2021\)](#). La Figura [III.4](#) muestra las fases de un ataque de cybergrooming o acoso sexual cibernético.

Figura III.4: Pasos en un ataque de ciber-grooming.



El cyber-grooming inicia cuando un adulto se hace amigo de un niño, adolescente o joven en línea y crea una conexión emocional con eventuales intenciones de abuso sexual, explotación sexual o tráfico. Puede ser alguien a quien nunca hayan conocido, inclusive algún amigo o familiar. Los ciber atacantes fingen que tienen la misma edad que la víctima. En este caso, el victimario puede ser un pedófilo o pederasta, que es una persona con trastorno psiquiátrico que tiene excitación, fantasías sexuales o placer sexual con niños, adolescentes o jóvenes.

Tal como se ilustra en la La Figura **III.4** a menudo la manipulación comienza con la amistad. El pederasta buscará formas de ganarse la confianza de su víctima con regalos o promesas, jugando el mismo papel con conversaciones de chat en el Internet inocentes en principio y depredadoras al finalizar. Eventualmente, comenzarán a pedir algo a cambio, intentado desorientar en sus aspectos morales (desensibilización). Posteriormente, lo seducen y lo asilan hasta capitalizar o no el contacto sexual. Los pederastas continúan con el post abuso e intentan mantener el control de la víctima por tiempos prolongados.

Cyberstalking

El cyber Stalking es una práctica delictiva que implica el uso repetido de Internet, teléfono celular y/o cualquier otro dispositivo electrónico en forma

sistemática para hostigar a alguien e invadir su privacidad [Wilson et al. \(2021\)](#). Algunos métodos incluyen el envío de correos electrónicos denigrantes, solicitudes y mensajes de amistad no deseados, hurto, spam, mensajes de texto en redes sociales, foros web, o cualquier de herramienta en línea. Los actos también pueden ser más graves, como enviar correos electrónicos abusivos, amenazantes u obscenos a la víctima o su familia, de manera que genera aprensión y/o miedo.

La principal intención del acosador es acechar a una persona, hombre o mujer, aunque el foco del acoso puede ser una ex esposa, ex amante o un ex jefe. Las mujeres son hostigadas sexualmente por el acosador porque tiene una fotografía de la víctima y la amenaza exigiéndole tener sexo con él, de lo contrario subirá la foto o el video a las redes sociales. En casos extremos, el cyber Stalking puede conducir al acoso físico o violencia sexual, dado que el victimario puede usar la información que ha recopilado sobre la víctima para rastrear su paradero y acecharla en persona.

Las características principales del cyber Stalking se pueden resumir en las siguientes: El acosador invade la privacidad de una persona, monitorea el comportamiento de la víctima, la amenaza o hace insinuaciones no deseadas. El hostigador amenaza en publicar información privada en línea, pues puede secuestrar su cámara web, roba su identidad para enviar mensajes no deseados o llamar para calumniarlo. Además, monitorea el paradero de sus víctimas usando registros de redes sociales y etiquetas de ubicación. El hostigador hace que sus víctimas se sientan avergonzadas, acosadas, amenazadas o asustadas.

El ciber Stalking se asemeja al Ciberbullying (de hecho, se considera una extensión) debido a que utilizan las mismas técnicas de anonimato. Las redes sociales, blogs, sitios para compartir fotos y muchas otras actividades de uso común en línea brindan a los hostigadores cibernéticos una gran cantidad de información que los ayuda a planificar su acoso. Sin embargo, existen algunas diferencias como las siguientes. El Ciberbullying normalmente ocurre entre adolescentes o menores de edad, mientras que el cyber Stalking se concibe entre adultos. El cyber Stalking puede ser más complicado, y pueden existir mayores impactos o consecuencias con las víctimas que el Ciberbullying, aunque esto no siempre es una norma. La Figura [III.5](#) muestra algunos elementos.

Figura III.5: Elementos del cyber-stalking



Cybersexting

El ciber-sexting es la práctica que implica la recepción o transmisión de imágenes o videos íntimos con contenido sexual, ya sea con consentimiento o no, a través de las redes sociales utilizando dispositivos electrónicos [Trub et al. \(2022\)](#). La difusión de tales videos o imágenes es instantánea, con consecuencias nefastas para las personas involucradas.

El cyber sexting puede resultar después de haber ocurrido un encuentro sexual, en el cual alguien tomó fotos o grabó un video con o sin conocimiento de la víctima, para luego distribuirlo. Así mismo, puede ocurrir que las imágenes fueron extraídas de un dispositivo extraviado o robado por terceros. El problema es cuando se difunden estas imágenes o videos sin consentimiento de manera pública para perjudicar o avergonzar a alguien.

Los mensajes, imágenes y videos íntimos son elaborados conscientemente por los ciber delincuentes y enviados a sus víctimas para crear un chantaje, de manera tal que la víctima entregue dinero ante la amenaza de que comparta dicha información que podría afectar su reputación. En la mayoría de estos casos el victimario o acosador puede utilizar este compendio para extorsionar a la víctima, una práctica también conocida como sextorsión.

El cyber sexting en la práctica puede involucrar o no a menores de edad, preadolescentes y adolescentes, especialmente niñas para que realicen actos sexuales. Esta práctica es prohibida por las leyes del mundo. Los victimarios suelen ser ex parejas o aspirantes a parejas que intentan acosar, avergonzar y

controlar a las víctimas. Los ciber delincuentes amenazan con difundir en línea fotografías de ellos desnudos o información sexual, o compartirlas con amigos, familiares o compañeros de trabajo si la víctima no suministra más material, coopera en actos sexuales, o entrega dinero. La Figura III.6 muestra algunos de los elementos del cybersexting y sus interrelaciones.

Figura III.6: Elementos del cyber-sexting



Lecciones aprendidas. En este capítulo se definió el acoso cibernético como la persecución, amenaza, insultos, burlas e intimidaciones que ocurren a través de medios electrónicos o digitales en contra de víctimas de diversas edades. Se señaló que existían algunas formas de violencia mediante el uso del Internet. El acoso cibernético tiene sus variedades que difieren del acoso tradicional debido a que las víctimas no saben quién es el acosador o por qué son atacados, puede hacerse viral, remotamente y de manera impersonal. Los ciber atacantes aprovechan el ciberespacio, que funciona las 24 horas de los 365 días del año. Por mencionar dos ejemplos, el cyber grooming es un tipo de acoso sexual cibernético mediante el cual los victimarios seleccionan a una víctima con engaños y se ganan la confianza hasta capitalizarlo. El Cyber stalking es una práctica delictiva que implica el uso repetido de Internet, teléfono celular y/o cualquier otro dispositivo electrónico en forma sistemática para hostigar a alguien e invadir su privacidad.

Sitios de Interés

1. **UNESCO**, ¿Qué hace la UNESCO sobre acoso y violencia escolar? URL: <https://es.unesco.org/themes/acoso-violencia-escolar/accion>
2. **KASPERSKY**, ¿Qué es el cibercrimen? ¿Cómo protegerse del cibercrimen?. URL: <https://latam.kaspersky.com/resource-center/threats/what-is-cybercrime>
3. **INTERPOL**, Ciberdelincuencia – El Próximo Puede Ser Usted. URL: https://www.itu.int/dms_pub/itu-d/opb/str/D-STR-GCI.01-2021-PDF-S.pdf



CAPÍTULO IV

Ciberguerra

Introducción

Con el paso del tiempo, la humanidad ha librado la guerra, intentado impulsar y promover las agendas nacionales en un juego de poder internacional en constante cambio. Desde las batallas con espadas del pasado hasta los ataques con drones no tripulados de la actualidad, este juego de poder se ve constantemente impulsado a cambiar y evolucionar gracias a la tecnología. En el siglo XXI el dominio del ciberespacio es tan decisivo y sorprendente como lo fue el dominio del mar en el siglo XIX y el dominio del aire en el siglo XX [Firdous \(2020\)](#). Actualmente, el ciberespacio es considerado como el campo de batalla en el que se libra la guerra del futuro. Es el escenario de la nueva “Guerra Fría”. Un escenario en el que todas las naciones del planeta tierra, todas las empresas criminales y, en efecto, casi todos los humanos del planeta tienen intereses y residen. A lo largo de la historia del hombre nunca antes ha habido un lugar en el que un conflicto global se esté librando activamente en el mismo espacio que todas las empresas y organizaciones del planeta.

Con solo aproximadamente 50 años de historia a sus espaldas, Internet y la conectividad global se están expandiendo a una velocidad extraordinaria. A medida que aumenta la cantidad de sistemas conectados a Internet, los ataques cibernéticos también aumentan en tamaño, sofisticación y costo. Por ejemplo, el hackeo de Yahoo, el incidente más grande de su tipo, afectó a alrededor de 3 mil millones de cuentas de usuario en 2014 [Journal \(2017\)](#), mientras que la brecha de Equifax afectó a 145,5 millones de clientes [Ng \(2018\)](#) y junto con WannaCry Los ciberataques [Team \(2017\)](#) y NotPetya [Greenberg \(2018\)](#) fueron los de mayor escala y más complejos que tuvieron lugar en 2017. Durante los años 2019 y 2020, la superficie de ataque se expandió debido a la digitalización acelerada y la creciente dependencia en la infraestructura digital (por ejemplo, servicios basados en la nube, y trabajo remoto) [Symantec \(2020\)](#). A principios de 2021 ocurrió uno de los ciberataques más extraños y aterradores. Un ciberdelincuente obtuvo acceso ilegal al sistema de tratamiento de agua de la ciudad de Oldsmar en Florida e intentó hacer que el agua no fuera segura para el consumo cambiando los niveles químicos específicos [Magazine \(2021\)](#). Finalmente, en el último informe del panorama de amenazas compilado por la Agencia de la Unión Europea para la Seguridad de las Redes y la Información (ENISA) [for Cybersecurity. \(2020\)](#), se predice que un ciberespacio seguro y confiable será aún más importante en el nuevo entorno social y económico. norma establecida tras la pandemia del COVID-19 y la consiguiente transformación

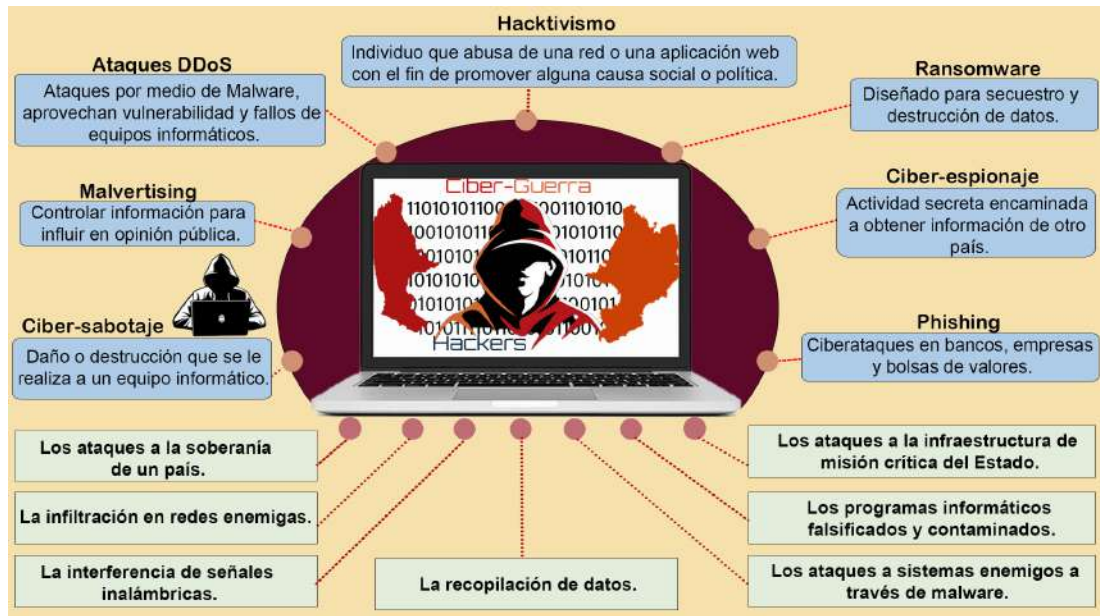
del entorno digital.

Los ataques cibernéticos son ahora el crimen de más rápido crecimiento a escala global [Huber \(2019\)](#). El ciberdelito indujo pérdidas financieras que superaron las pérdidas agregadas del comercio mundial de todas las drogas ilegales [Huber \(2019\)](#); [Symantec \(2020\)](#). Las estimaciones muestran que el delito cibernético le costará al mundo más de 10,5 billones de dólares estadounidenses al año para 2025, un crecimiento significativo de los 3 billones de dólares estadounidenses registrados en 2015 [Ventures \(2020\)](#). Este espectacular aumento pone de manifiesto el fuerte aumento del número de organizaciones (tanto públicas como privadas) que no están preparadas para hacer frente a los ciberataques. Además, los ataques se vuelven más mutables y alcanzan sus objetivos más rápido que nunca. Para dar un ejemplo, un estudio de Cybersecurity Ventures informó que las empresas fueron víctimas de un ataque de ransomware cada 11 segundos en 2021, frente a los 40 segundos en 2016 [Ventures \(2020\)](#). Las organizaciones enfrentan una necesidad urgente de aumentar y mejorar su ciberseguridad debido al crecimiento continuo de la cantidad de dispositivos, redes e interfaces de usuario para usuarios finales, combinado con las crecientes cantidades de datos que se transmiten a través de Internet debido a los avances en la nube. y fog/edge computing, Internet de las cosas (IoT), Industria 4.0/5.0 y 5G/6G [Gumusbas et al. \(2020\)](#); [Institute \(2019\)](#).

Sobre la base de estos antecedentes, se puede definir que la ciberguerra es una guerra tecnológica que se puede generar por diferencias políticas, doctrinas o conflictos que se pueden materializar al interconectar usuarios, aplicaciones y servicios en el ciberespacio. La ciberguerra se produce mediante una variedad de ataques digitales (hacktivismo, malvertising, ransomware, etc) por parte de un sector, país o región para dejar sin funcionamiento los sistemas informáticos de las infraestructuras de misión esenciales de otro. La Figura [IV.1](#) muestra algunos aspectos relacionados con la ciberguerra tales como los ataques a la soberanía de un país, la infiltración en redes de cómputo enemigas, la interferencia de señales inalámbricas o de redes celulares, los programas informáticos falsificados y contaminados, la difusión de información secreta o confidencial de un político, ministerio o país, entre otros. A continuación se analizarán aspectos y casos relaciondos con la ciberinteligencia, ciberespionaje, ciberterrorismo y el cibersabotaje.

¡Bienvenidos!

Figura IV.1: Resumen de ciberguerra.



Ciberinteligencia

El nivel estratégico de planificación y control se centra en establecer la misión y la dirección de una organización, establecer objetivos y concebir planes sobre cómo se lograrán esos objetivos [Macas et al. \(2022\)](#). En términos generales, la estrategia no es realmente un plan, sino la lógica que impulsa un plan que promueve el avance hacia una determinada meta. Para cada empresa, la estrategia evoluciona y su implementación cambia.

Como proceso, la inteligencia consiste en un ciclo mediante el cual se adquiere información, se convierte en su producto terminado y se pone a disposición de los responsables políticos. En cada etapa de este ciclo de inteligencia, el ciberespacio ha cobrado mayor importancia, desde su uso como un medio para recopilar información mediante el seguimiento de los hábitos en línea, hasta el análisis de grandes conjuntos de datos, la creación de modelos predictivos de comportamiento, así como el uso del ciberespacio para lanzar ataques contra otros sistemas informáticos, como fue el caso de Stuxnet. Como tal, la ciberinteligencia es un término general que cubre una variedad de prácticas diferentes utilizadas por los actores de inteligencia a través del ciberespacio. En la practica, la inteligencia cibernética ayuda a comprender a los atacantes, sus motivos, sus acciones y capacidades, y cómo funcionan. Es más que solo extracción de datos: requiere la capacidad de analizar lo que sucede en tiempo

real para reducir el impacto de los ataques a las empresas brindando asesoramiento proactivo sobre cómo protegerse contra las amenazas.

Ciberinteligencia: Recopilación y Análisis

La comunidad de inteligencia (p. ej., agencias y organismos gubernamentales) utiliza el ciberespacio para recopilar contenido de comunicación mediante el acceso a correos electrónicos o llamadas de voz, así como el avance hacia la recopilación y el análisis de metadatos a través de la extracción de datos y vigilancia de datos. Esta antigua táctica de ciberinteligencia de extracción de datos implica recopilar la información personal de un individuo de varias fuentes de datos (identidad personal, cuentas financieras, registros médicos, huellas dactilares o perfiles de ADN, por ejemplo) para desarrollar un “expediente digital” personalizado Syed (2020).

En comparación, la “vigilancia de datos” implica monitorear la “huella electrónica” que inevitablemente queda cuando un individuo interactúa con un sistema computarizado Andrejevic and Gates (2014). Los sitios web, por ejemplo, rastrean secretamente la navegación web de un cliente cuando accede, incluidos datos sobre el ISP, el hardware y el software de la computadora, el sitio web desde el que se vinculó y exactamente qué partes del sitio web exploró y durante cuánto tiempo. Estos datos se pueden recopilar de manera similar a los métodos de vigilancia de comunicaciones existentes, registrando a todas las personas que visitan un sitio web en particular, lo que aquí se denomina “registro del servidor” para mayor facilidad, ya que se enfoca en los eventos del lado del sitio web, o una lista detallada de todos los sitios web que visita un individuo, denominados “registros web personales”, ya que examina las actividades realizadas desde la perspectiva del individuo.

Además, muchas acciones del mundo real también crean huellas digitales, registrando el tiempo, el lugar y la acción. El dinero, los viajes, la documentación oficial, las compras y todas las formas de comunicación son solo algunos ejemplos en los que, incluso en el mundo real, es probable que las actividades se registren en algún sistema informático. Esto hace que evitar que nuestras actividades se registren en nuestra vida cotidiana sea cada vez más difícil en las sociedades desarrolladas. Al recopilar este tipo de información de suficientes personas y hacer referencias cruzadas en una base de datos de búsqueda, es posible comprender lo que un individuo está haciendo y tiene la intención de hacer y determinar si se trata de una amenaza Goel (2011).

Ciberdaño

El problema particular que plantea la inteligencia cibernética es que los desarrollos recientes, tanto en la tecnología como en la forma en que las personas usan esa tecnología, significan que no hay una hoja de ruta para la comunidad de inteligencia en cuanto a lo que se espera de ellos. La naturaleza semipública del ciberespacio junto con la dificultad de atribuir procedencia una vez que la información deja al individuo significa que la idea misma de “privacidad” en Internet no está clara [Kim et al. \(2022\)](#). Los cambios en la interacción social en el ciberespacio han resultado en una comprensión cada vez más confusa de los “espacios en línea”. Por ejemplo, las salas de chat, los foros de redes sociales como Facebook y YouTube, e incluso la navegación web distorsionan las distinciones públicas/privadas establecidas al representar esferas privadas y sociales, actuando para mostrar y difundir públicamente información personal para que la vea una audiencia cada vez más amplia y variada. Sin embargo, no está claro hasta qué punto las personas pretenden renunciar a su privacidad o control y permitir el acceso estatal a esta información [Otero \(2022\)](#). Además, la recopilación de metadatos que detallan los hábitos en línea puede revelar información personal sobre el individuo, incluidas las inclinaciones políticas, el estado de salud, la sexualidad, los sentimientos religiosos y una amplia gama de otras características personales, preocupaciones e intereses individuales.

Ciberespionaje

De acuerdo con Felt [Felt et al. \(2011\)](#) la mayoría de los ciberdelincuentes producen y emplean malware para ganar dinero. Una de las características que vienen con esto es que intentarán maximizar la ganancia de un ataque. Por ejemplo, en los ataques de phishing, esto se traduce en tener tantos objetivos como sea posible para maximizar la probabilidad de que alguien sea víctima del fraude. Es probable que el objetivo sea un ataque de espionaje, por ejemplo, los llamados ataques de spear phishing. Los incentivos para los ataques de espionaje también difieren dentro de las categorías de Felt, ya que el monitoreo y la recopilación de información son los principales impulsores. Los atacantes de espionaje tienen como objetivo robar información valiosa para, por ejemplo, futuros ataques, obtener ventajas industriales o ganar ventaja en una negociación futura [Deibert et al. \(2009\)](#). Además, los atacantes en un ataque de espionaje a menudo buscarán información específica y sabrán cómo

obtenerla. Esto nos lleva al papel de la experiencia en el espionaje cibernético, ya que una operación a gran escala exige un conocimiento experto sobre el objetivo. La operación debe incluir más que el conocimiento de las vulnerabilidades del experto en TI para tener éxito. Entre otras cosas, un correo electrónico de phishing dirigido a otro país y cultura requiere un conocimiento experto sobre el idioma y las situaciones políticas para tener éxito. También se requiere experiencia en la industria para extraer y filtrar la información correcta.

Ciberterrorismo

El ciberterrorismo es la convergencia del terrorismo y el ciberespacio [Kenney \(2015\)](#). Por lo general, se entiende que significa ataques ilegales y amenazas de ataques contra computadoras, redes y la información almacenada en ellas cuando se realizan para intimidar o coaccionar a un gobierno o su pueblo en la consecución de objetivos políticos o sociales. Además, para ser considerado como ciberterrorismo, un ciber ataque debe implicar violencia contra las personas o la propiedad, o al menos causar suficiente daño para generar miedo. Los ataques que conducen a la muerte o lesiones corporales, explosiones, accidentes aéreos, contaminación del agua o pérdidas económicas graves serían ejemplos. Los ataques graves contra infraestructuras críticas podrían ser actos de ciberterrorismo, dependiendo de su impacto. Los ataques que interrumpen servicios no esenciales o que son principalmente una molestia costosa no lo harían [Hua and Bapna \(2013\)](#).

Cibersabotaje

Como mencionamos en la sección anterior, el término “ciberterrorismo” se ha utilizado con cierta frecuencia. Sin embargo, es difícil argumentar que ha habido casos, hasta ahora, de terroristas que mataron a personas (o amenazaron con hacerlo) a través de redes informáticas. Los terroristas, los Estados o naciones y los delincuentes pueden intentar interrumpir y destruir las redes informáticas a través del *Cibersabotaje o sabotaje cibernético* [Buchan and Navarrete \(2021\)](#). En consecuencia, se diría que el “sabotaje cibernético” es una forma más efectiva de pensar sobre el tema. Esto no quiere decir que las personas no puedan morir debido al impacto en las redes informáticas. En 2009, debido a un error humano, 75 personas perdieron la vida en la represa Shushenskaya en Siberia [Hamill \(2020\)](#), porque un operador de computadora presionó las teclas

equivocadas y encendió una turbina sin usar, lo que provocó una acumulación de presión que provocó que el piso se derrumbara y se inundara. Si bien este no fue un caso de sabotaje, los esfuerzos conscientes para causar interrupciones en las instalaciones de infraestructura crítica u otros lugares podrían resultar en el tipo de daño que podría amenazar a los trabajadores, sin mencionar causar daños por millones de dólares e interrumpir las operaciones de las plantas de energía, represas, etc.

En el pasado reciente, se han visto ataques de piratas informáticos diseñados para interrumpir sitios web y actividades económicas por parte de grupos o individuos que intentan lograr una agenda política; dichos grupos e individuos se conocen como hacktivistas. El Ejército Electrónico Sirio [Warren and Leitch](#) (2016), pro régimen, ha estado implicado en la desfiguración de sitios web gubernamentales y de prensa, incluido el de la revista Forbes. Además, el colectivo hacktivista conocido como Anonymous ha estado involucrado en ataques en línea contra el gobierno y organizaciones como la Iglesia de la Cien-ciología. La Figura [IV.2](#) muestra un infografía con diferentes formas en las que un hacker podría realizar cibernsabotaje sobre una determinada víctima.

Figura IV.2: Ejemplos de cibernsabotaje.



Lecciones aprendidas. La ciberguerra es una guerra que se lleva a cabo en y desde las computadoras y las redes que las conectan, librada por los Estados o sus representantes contra otros Estados. La guerra cibernética generalmente se libra contra redes gubernamentales y militares para interrumpir, destruir o negar su uso. La ciberguerra no debe confundirse con el uso terrorista del ciberespacio o con el ciberespionaje o el ciberdelito. Aunque se utilizan tácticas similares en los cuatro tipos de actividades, definirlas todas como ciberguerra es una interpretación errónea. Algunos Estados que se han involucrado en la guerra cibernética también pueden haberse involucrado en actividades disruptivas como el espionaje cibernético, pero tales actividades en sí mismas no constituyen una guerra cibernética.

Sitios de Interés

1. **National security US: Sabotage and War in Cyberspace.** Sabotaje y guerra en el ciberespacio. URL: <https://warontherocks.com/2022/07/sabotage-and-war-in-cyberspace/>.
2. **Military News: Cyber Sabotage.** Sabotaje cibernético. URL: <https://www.military.com/defensetech/2008/02/06/cyber-sabotage>.
3. **CSIS: Significant Cyber Incidents.** Incidentes cibernéticos significativos. URL: <https://www.csis.org/programs/strategic-technologies-program/significant-cyber-incidents>.



CAPÍTULO V

Web profunda

Introducción

Muchos pueden considerar Internet y World Wide Web (web) como sinónimos, sin embargo no lo son. Por el contrario, la web es una parte de Internet y un medio a través del cual se puede acceder a la información. Al conceptualizar la web, algunos pueden verla como compuesta únicamente de sitios web accesibles a través de un motor de búsqueda tradicional como Google. Sin embargo, este contenido—la *"Web de superficie (Surface Web)"*—es solo una parte de la web. Más allá del contenido que la *Web de superficie* puede proporcionar, hay otra capa, una capa mucho más grande, de material al que no se accede a través de una búsqueda en línea tradicional.

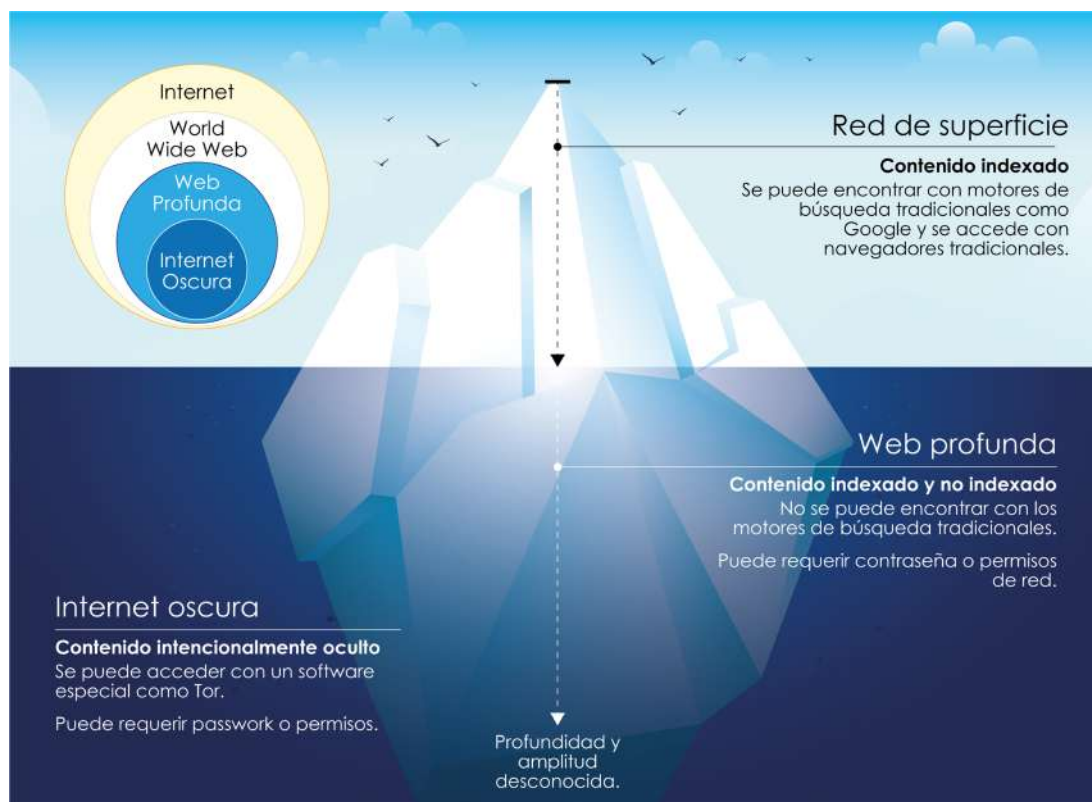
De acuerdo con Chertoff (2017), "buscar en Internet hoy en día se puede comparar con arrastrar una red por la superficie del océano". Si bien una gran cantidad de información puede quedar atrapada en la red, todavía hay una gran cantidad de información que es profunda y, por lo tanto, se pierde. Esta área profunda de Internet, o *Web profunda*, se caracteriza por la amplitud, profundidad, contenido y usuarios desconocidos. En particular, la *Web profunda*, *Deep Web* o *Web invisible* se refiere al contenido oculto detrás de formularios HTML. Para acceder a dicho contenido, un usuario debe realizar un envío de formulario con valores de entrada válidos. Como se mencionó anteriormente, el nombre *Web profunda* surge del hecho de que se pensaba que dicho contenido estaba fuera del alcance de los motores de búsqueda. También se cree que la *Web profunda* es la mayor fuente de datos estructurados en la Web y, por lo tanto, acceder a su contenido ha sido un desafío de larga data en la comunidad de gestión de datos.

Los rincones más alejados de la *Web profunda*, conocida como *Web oscura*, *Dark Web* o *Darknet*, poseen contenido que se ha ocultado intencionalmente. Se puede acceder a la Dark Web con fines legítimos y para ocultar actividades delictivas o maliciosas. La explotación de la Darknet para prácticas ilegales ha despertado el interés de funcionarios y/o legisladores de gobierno. Por ejemplo, Silk Road Hout and Bingham (2013), uno de los sitios más notorios anteriormente en Dark Web. Silk Road era un bazar global en línea de servicios ilícitos y contrabando, principalmente drogas. Los vendedores de estas sustancias ilegales estaban ubicados en más de diez países en todo el mundo, y se proporcionaron bienes y servicios de contrabando a más de 100,000 compradores. Se ha estimado que Silk Road generó alrededor de \$1.2 mil millones en ventas entre enero de 2011 y septiembre de 2013, luego de lo cual los agentes

federales la desmantelaron. La Figura V.1 muestra las capas de Internet. Este capítulo arroja información sobre la Web profunda, con especial atención en los navegadores, recursos y precauciones a tener en cuenta en dicha capa de Internet.

¡Bienvenidos!

Figura V.1: Capas de Internet.



Navegadores

La Web profunda alberga todo tipo de recursos a los que es difícil acceder por medio de los buscadores tradicionales como: Google, Bing, Yahoo, etc, porque las páginas están cifradas y su calidad es varias veces superior a la de la web superficial. Una parte de la Web profunda consiste en redes internas de instituciones científicas y académicas que forman la llamada Web Invisible Académica (WIA). La WIA se refiere a las bases de datos que contienen material académico, avances tecnológicos y publicaciones científicas a los cuales no se pueden acceder fácilmente. Además, se puede encontrar foros privados, carpetas y archivos en Dropbox, drive, entre otros. Los navegadores más co-

munes utilizados en la Web profunda son:

The onion router (Tor)

El navegador Tor [The Tor Project \(2023\)](#) o “La Red Cebolla” es el más popular y utilizado, es un servicio online que mediante un software específico permite conectarse a una red de comunicaciones de baja latencia que brinda anonimato a sus usuarios. Se creó en el año 2003 con el objetivo de proporcionar privacidad y anonimato. Está basado en el proyecto OR del Laboratorio de Investigación Naval de los Estados Unidos, quien lo financió hasta el año 2004 [Dingledine et al. \(2004\)](#). Es de código abierto y en permanente evolución. Se estima que Tor es utilizado diariamente por cientos de miles de usuarios en todo el mundo. El principal objetivo de Tor es evitar las censuras de ciertos proveedores de servicios y de ciertos países. Como cualquier herramienta o tecnología, se puede utilizar para hacer el bien y para hacer el mal. Los ciberdelincuentes han aprovechado las características de anonimato de la red para cometer delitos y por este motivo, se tiende a relacionar las redes Tor con ciberdelincuencia.

Tor es una red completamente gratuita, creada para evadirse de las medidas de control que ejecutan los gobiernos hacia los usuarios. Como se puede ver en la Figura [V.2](#), esta red cuenta con nodos de salida y nodos intermedios, para garantizar el secreto de la información consultada y el anonimato. Sin embargo, no existe el anonimato en Internet de manera perfecta (es decir, al 100 %), siempre se deja algún rastro, incluso dentro de TOR, aunque puede ser extremadamente complicado rastrear la información en este tipo de sistemas.

Figura V.2: Estructura del cifrado de la red TOR.



Proyecto Internet Invisible (I2P)

El Proyecto Internet Invisible o I2P [I2P \(2023\)](#) es una red anónima descentralizada desarrollada en Java. El I2P permite construir, desplegar y mantener

una red para una comunicación segura y anónima, ya que cifra el tráfico de la red creando una capa dentro de UDP y TCP/IP mediante claves privadas y públicas. Fue desarrollado bajo principios similares a los de Tor, pero diseñado desde el principio como una Darknet totalmente autónoma [Ali et al. \(2016\)](#). Una vez conectado por medio de túneles de entrada y salida, se puede navegar por sitios web, utilizar software de foros y blogs, enviar correos electrónicos, participar en chats anónimos en tiempo real, etc. I2P no usa servidores centralizados sino nodos de cifrado que a su vez están cifrados y mandan las comunicaciones de punto a punto.

FreeNet

FreeNet [Inc. \(2023\)](#) es una plataforma peer-to-peer de código abierto y es mucho más antigua que Tor o I2P. Compatible con las tecnologías OpenNet y DarkNet. FreeNet no dispone de un servidor central, por lo que disminuye la probabilidad de ser pirateado. La información almacenada se encripta antes de llegar a los servidores, por lo que no puede ser leída por trackers. Freenet en vez de mandarte a un servidor donde está la información, guarda la información en varios servidores, de manera cifrada y anónima [Clarke et al. \(2002\)](#). De este modo, si uno de los servidores es capturado por un gobierno o lo que sea, esa información seguirá estando disponible en todos los demás. Por supuesto, oculta los datos de quienes han accedido a esa información. Además, Freenet admite que otros usuarios continúen descargando un archivo, incluso después de que el usuario que lo cargó esté desconectado.

Disconnect

Disconnect [Disconnect \(2021\)](#) es una extensión de navegador de código abierto y orientada a la privacidad. Combina los conocimientos técnicos contra el seguimiento y la publicidad maliciosa con capacidades de búsqueda anónima y una red VPN. Dispone de una opción gratuita de protección para un navegador con el bloqueador de seguimiento y la posibilidad de realizar búsquedas de forma privada. El siguiente nivel de protección es de pago y permite bloquear el seguimiento y el malware de todo el dispositivo. En la opción Premium se oculta la dirección IP tras un VPN de la compañía. Está disponible para los navegadores Chrome, Firefox, Safari, Opera y Samsung Browser en Windows, iOS y Android.

Whonix

Whonix [Whonix \(2023\)](#) es un sistema operativo (SO) gratuito centrado en la privacidad, seguridad y el anonimato. Este SO se basa en la red de anonimato Tor, Debian GNU/Linux y seguridad por aislamiento. Todas las comunicaciones son forzadas a través de la red Tor [Ranakoti et al. \(2017\)](#). Además, permite navegar de forma privada ocultando la dirección IP mientras se navega utilizando una red única conocida como Whonix-Workstation que se ejecuta en el sistema privado. Tiene dos interfaces de red virtuales, una se conecta a través de NAT y conecta con la red Tor y otra acoplada con una LAN virtual.

Yandex

Yandex [Yandex \(2022\)](#) es un navegador gratuito bastante popular que ofrece anonimato para navegar por internet. Impide cualquier tipo de seguimiento y dispone de una característica adicional para escanear archivos en busca de malware. Es compatible con Windows, Mac, Linux, Android y iOS. Cuenta con plugin para desactivar flash, ad-blockers y los que protegen de sitios no seguros. También tiene protección contra DNS spoofing que encripta todos los datos y previene ataques de corrupción de cache [Gerb et al. \(2016\)](#).

Recursos

En esta subsección, proporcionamos una descripción general de los recursos que nos proporciona la Web profunda. Los recursos científicos, estadísticos, financieros, de comercio internacional y de legislación están entre los más comunes. Los **recursos científicos** más utilizados son Elseiver ¹, Espacenet ² y Latipat ³. Elseiver es un repositorio se especializa en contenido científico, técnico y médico. Espacenet es un buscador de patentes de los países Europeos. Latipat está bajo la plataforma de espacenet agrega resultados de patentes de países de Latinoamérica, España y Portugal. Mientras que Eurostat es una **fuentes estadística** de todos los países europeos. Bureau Van Dijk ⁴ y Duns & Bradstreet son ⁵ **recursos financieros** que proporcionan información sobre registros mercantiles e son informes financieros, respectivamente. Market access database ⁶

¹<https://www.elsevier.com/>

²<https://lp.espacenet.com/>

³<https://lp.espacenet.com/>

⁴<https://www.bvdinfo.com/en-gb/>

⁵<https://www.dnb.com/>

⁶<https://www.macmap.org/>

y la Organización Mundial del Comercio (OMC)⁷ son **recursos de comercio internacional**. Market access database son datos sobre tarifas arancelarias en los distintos países de destino a las exportaciones. La OMC recoge informaciones legales sobre el comercio internacional. Finalmente, entre los **recursos sobre legislación** más populares están Eurolex⁸ y FDA (Food and Drug Administration)⁹. Eurolex incluye toda la información legal y disposiciones sobre la legislación y tratados europeos. Mientras, que FDA es la agencia de alimentación de EE.UU. aquí puedes encontrar todas las regulaciones acerca de pesticidas, conservantes y aditivos autorizados.

Precauciones

La Web profunda tiene algunas precauciones importantes, por ejemplo:

- **El control del robo de identidad** es fundamental para impedir que la información privada sea utilizada incorrectamente.
- **Adquirir programas de seguridad**, las protecciones antimalware y anti-virus son decisivos para evitar la explotación por parte de actores malintencionados.
- **Aparte tu imagen en línea de la vida real**. Es decir, nombre de usuario, dirección de correo electrónico, “nombre real”, contraseña, e incluso la tarjeta de crédito nunca deben usar en ningún otro lugar de tu vida.
- **Usar una cuenta de usuario local** secundaria que no sea administrador para todas las actividades cotidianas. De manera predeterminada las cuentas nativas en la mayoría de las computadoras tienen privilegios de administrador.
- Muchos servicios de seguridad en línea ahora ofrecen **protección de identidad para su seguridad**, los cuales permiten monitoreo proactivo de robo de identidad y financiero, si se tiene acceso a estas herramientas es recomendable aprovecharlas.
- **Actualizar periódicamente un equipo de cómputo** permitirá corregir las vulnerabilidades del mismo.

⁷<https://www.wto.org/indexsp.htm>

⁸<https://www.eurolex.com/>

⁹<https://www.fda.gov/>

- Siempre **descargar software desde sitios legítimos, es decir, usar solo aplicaciones y páginas de Internet oficiales**, y no desde sitios de terceros donde se puede filtrar alguna aplicación maliciosa con el único objetivo de robar datos.
- **Deshabilitar la ubicación del dispositivo**, se puede encontrar a través de la dirección IP la ubicación, así como a través del propio dispositivo. Descargar e instalar los navegadores de la Web profunda utilizando los sitios web oficiales para evitar productos fraudulentos similares que podrían comprometer tu seguridad digital.
- **Cifrar el tráfico de Internet por medio de una VPN**. Las VPN encriptan el tráfico web y garantiza que las direcciones IP estén ocultas de los piratas informáticos o la vigilancia del gobierno, incluso en el caso de una fuga del navegador. La Tabla V.1 presenta un resumen de los navegadores más comunes utilizados en la Web profunda y recomendaciones al navegar en la misma.

Tabla V.1: Resumen de navegadores y precauciones de la web profunda.

NAVEGADORES	PRECAUCIONES
■ TOR ■ FreeNet ■ I2P ■ Whonix ■ Yandex	■ Control del robo de identidad. ■ Separe su imagen en línea de la vida real. ■ No utilizar siempre el usuario administrador. ■ Utilizar la autenticación de dos factores. ■ Cifrar el tráfico de Internet mediante una VPN ■ Deshabilitar la ubicación de dispositivos ■ Descargar software desde sitios legítimos

Lecciones aprendidas. Gran parte de la cobertura y la publicidad de la red profunda y la web oscura se centra en las actividades ilícitas que tienen lugar en los mercados y foros clandestinos. Estos incluyen el desarrollo, distribución y/o venta de drogas, armas, servicios de sicarios, pornografía, moneda falsificada, datos personales y financieros, y malware y exploits. Esto es cierto; sin embargo, no toda la actividad de la web profunda o la web oscura es ilícita, ni toda la actividad ilícita es relevante para la mayoría de los clientes de los proveedores de seguridad cibernética y antivirus. La web profunda y oscura, a pesar de la connotación negativa, debe interpretarse de manera más amplia como espacios donde los usuarios pueden ejercer su derecho a la privacidad y la protección de datos, sin excepción de los riesgos o abusos inherentes a cualquier tecnología o servicio.

Sitios de Interés

1. **Avast, Dark Web Links: The Best Onion and Tor Sites in 2023.** Dark Web. URL: <https://www.avast.com/c-dark-web-websites>.
2. **Norton, How to safely access the deep and dark webs .** Deep web & dark web. URL: <https://nr.tn/3M53iQK>.



CAPÍTULO VI

Ataques de Ingeniería Social

Introducción

La ingeniería social es uno de los ataques más populares, peligrosos y amenazantes dentro del entorno digital. Se ha vuelto cada vez más frecuente debido a la vulnerabilidad de los usuarios, especialmente por su ingenuidad y desconocimiento. Estos ciber ataques pueden causar graves daños a sus víctimas, ya sea social, en su reputación o en aspectos económicos [Fuertes et al. \(2021\)](#). La complejidad de los ciber ataques, explotando el componente humano, es alta, y frecuentemente posibilita estos ciberataques.

Entre los ataques de ingeniería social más comunes se encuentran el fraude, la intrusión, la extorsión, el espionaje y la suplantación de identidad, a las que hay que enfrentarlas y estar alerta. El ataque más empleado en el mundo es el phishing y algunas de sus derivaciones como el Pharming. Sin embargo, existen otros ciber ataques que son muy delicados como el Ransomware, Smishing, Vishing, Baiting, Scareware, entre otros.

Según la compañía internacional de seguridad informática Kaspersky [Ding et al. \(2022\)](#), la ingeniería social se define como un conjunto de técnicas de manipulación emocional y engaño, que usan los cibercriminales para engañar a los usuarios incautos para que les envíen datos confidenciales, infecten sus computadoras con malware o abran enlaces a sitios infectados. Los hackers se aprovechan frecuentemente del poco conocimiento que tienen las personas sobre la tecnología, ya que esta avanza con gran velocidad [Fuertes et al. \(2021\)](#). Estos ataques se pueden realizar a través de correos electrónicos, ventanas emergentes, estafas en línea, sitios web falsos entre lo más importantes. La Figura [VI.1](#) muestra algunos tipos de ataques más agresivos de ingeniería social, mismos que se describe brevemente a continuación.

¡Bienvenidos!

Ataques de Phishing

Definición

En el Informe de tendencias de la actividad de Phishing del tercer trimestre de 2022 del Anti-Phishing Working Group (APWG) [\(APWG\)](#), se define al Phishing como un ciberdelito que emplea tanto la ingeniería social como el subterfugio técnico para robar los datos de identidad personal y las credenciales de las cuentas financieras de los usuarios. Las técnicas de ingeniería social se aprovechan de las víctimas vulnerables engañándolas, haciéndoles

creer que están tratando con una parte legítima y confiable. Los esquemas de subterfugios técnicos por su parte instalan código malicioso en los equipos y dispositivos para robar las credenciales directamente.

Figura VI.1: Tipos de ataques de Ingeniería Social.



Phishing es tipo de ciberataque en el que los ciber atacantes envían mensajes haciéndose pasar por una persona o entidad legítima. Los mensajes de phishing manipulan psicológicamente a los usuarios, lo que hace que instalen archivo con código malicioso, iniciar sesión en enlaces falsos o divulgar información confidencial. Están diseñados para engañar a las personas para que caigan en una estafa especialmente de transacciones monetarias. La intención es lograr que los usuarios revelen información financiera, credenciales del sistema u otros datos confidenciales [Cazares et al. \(2022\)](#).

El phishing es uno de los ciber ataques más comunes y graves en Internet que ocurren en las últimas dos décadas. Esta práctica se realiza mediante el uso de servicios de mensajería instantánea o correo electrónico al aprovechar las vulnerabilidades de empresas y usuarios en el ciberespacio. En tales ataques cibernéticos, los phishers intentan robar información confidencial del usuario haciéndose pasar por una entidad confiable y cometiendo fraude, generalmente con fines económicos. El proceso para ejecutar un ataque de Phishing se puede visualizar en la Figura [VI.2](#).

Los ataques de phishing no son recientes, sin embargo, la frecuencia y complejidad han aumentado drásticamente especialmente como consecuencia de la pandemia global de CoVID-19. El principal medio utilizado fue los correos electrónicos infectados con phishing. Esto demuestra cómo los ciber atacantes

Figura VI.2: ¿Cómo se ejecuta un ataque Phishing?



capitalizan el miedo, la confusión y el desconcierto.

Según el referido informe de tendencias de actividad de phishing de APWG (APWG), en resumen en el 2022, se observaron 1.270.883 ataques de phishing en total, lo cual significaba un nuevo récord. Por otro lado, el número de ataques contra el sector financiero representó el 23,2 % de todos los ataques de phishing. Así mismo, los ataques por correo electrónico comercial siguieron siendo los de mayor frecuencia, y el número de ataques mediante transferencias bancarias en el tercer trimestre aumentó en un 59 %. Estafas de fraude de tarifas anticipadas lanzadas a través del correo electrónico aumentó en un 1000 % en el tercer trimestre de 2022.

Tipos of Phishing

1. Spear Phishing.- Es un tipo de ataque de phishing que se dirige a un objetivo específico, sean personas u organizaciones definidas, generalmente a través de correos electrónicos maliciosos. El objetivo del Spear phishing es robar información confidencial como credenciales de inicio de sesión, o infectar el dispositivo de la víctima con código malicioso. Este ciber ataque sirve para robar información sensible y empieza

por identificar a los trabajadores para entender su comportamiento. Luego, el ciber atacante utiliza esa información para el envío de correos o mensajes de parte de supuestos compañeros, para acceder a páginas web maliciosas y robar datos confidenciales. Los administradores de TI y los encargados de recursos humanos son objetivos habituales debido al nivel de acceso que pueden tener dentro de la organización en general.

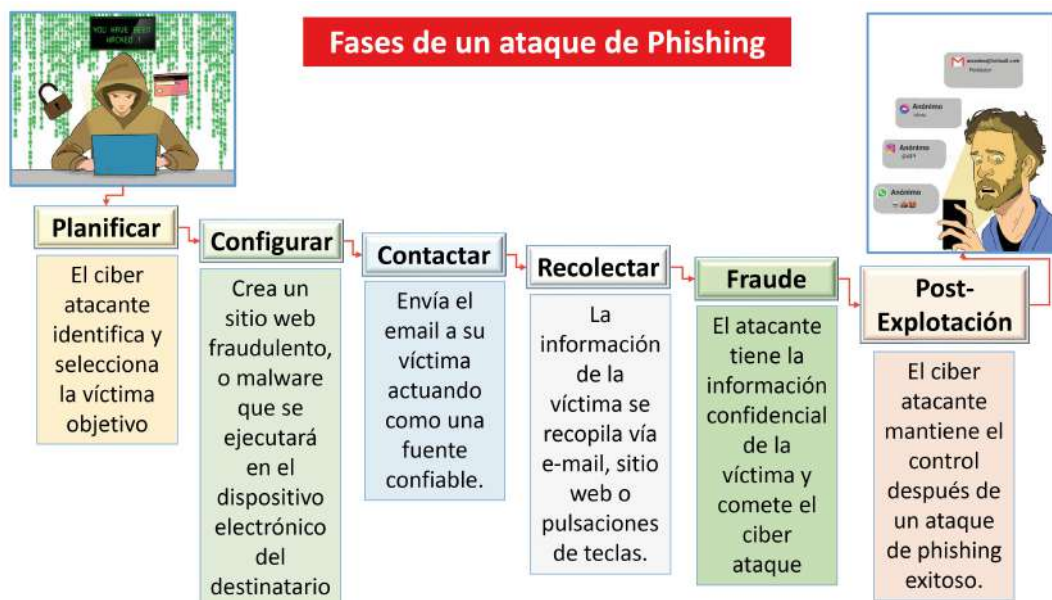
2. **Pharming.** – Es otro tipo de ataque de ingeniería social que se desarrolló a partir del Phishing. El ciber atacante (**pharmer**) que implementa esta técnica, intenta redirigir el tráfico a un sitio web fraudulento y todas las credenciales son accedidas por el atacante a través del sitio falso. Esto se logra al explotar las vulnerabilidades en los nombres de dominio o en los equipos o dispositivos de los propios usuarios, que permiten a los ciber atacantes redirigir un nombre de dominio a otro equipo servidor distinto. El atacante tiende a dirigir todo el tráfico que llega a un sitio web específico al sitio web falso recién creado al piratear el nombre de dominio sistema. Se cambian las direcciones IP de la máquina y el servidor, y todos los clics en el sitio web original se redirigen al sitio fraudulento afectado por malware. Estos sitios falsos pueden recopilar información confidencial de la víctima, o bien pueden instalar código malicioso en el dispositivo electrónico. Los pharmers suelen enfocarse en sitios web del sector financiero como la banca, plataformas de pago en línea u otros puntos de venta o de comercio electrónico, a menudo mediante la suplantación de identidad como objetivo [Siranjeevi et al. \(2020\)](#).
3. **Vishing.** – El vishing, es otra forma común de phishing que utiliza una llamada telefónica empujando la suplantación o robo de identidad de otra persona. El modus operandi del ciber atacante es suplantar la identidad de una persona de confianza a través de una llamada de teléfono con el objetivo de obtener información confidencial y datos sensibles de su víctima. El vishing, se aprovecha de las líneas de teléfono convencional, tecnología de voz IP y algunos servicios básicos digitales. El ciber atacante que llama intentará que la víctima revele información personal, como su número de la seguridad social, su número de tarjeta de crédito, sus claves de cuentas bancarias u otra información sensible [Dominguez and García \(2021\)](#).
4. **Smishing.** – Es un ciber ataque que se lleva a cabo a través de mensa-

jes de texto o aplicaciones de mensajería como Whatsapp, en lugar de correo electrónico. En este ataque, los ciber delincuentes buscan robar datos personales, que luego pueden usar para cometer fraude u otros delitos cibernéticos. Los mensajes contienen enlaces a sitios web fraudulentos que contendrá un enlace que lleva a las víctimas a un formulario que se utiliza para robar su información o instalar malware en el teléfono celular o solicitar datos personales. El enlace también puede descargar malware como virus, ransomware, spyware o adware en el dispositivo de la víctima. Estos mensajes de texto pueden parecer solicitudes urgentes enviadas desde un banco o un servicio de entrega de paquetes, para establecer el número de teléfono y la dirección de correo electrónico de una víctima, la cual será atacada mediante un mensaje de texto.

Fases de un ataque de Phishing

De acuerdo con la propuesta de Natasha M. Wojcicki [Wojcicki \(2019\)](#) en combinación con la iniciativa de Michael A. Ivanov y otros [Ivanov et al. \(2021\)](#) a continuación en la Figura VI.3 se ilustran las etapas de un ataque de phishing, con una leve descripción posterior.

Figura VI.3: Fases de un ataque de Phishing.



1. Etapa 1- Planificación: El ciber atacante identifica y selecciona la víctima objetivo, sea un individuo u organización y empieza a recopilar información relevante de los sitios web, realizando llamadas telefónicas,

visitando las instalaciones o monitoreando el tráfico de la red. Los objetivos pueden ser tan definidos como un solo individuo, o tan amplios como todos los usuarios de una empresa.

2. Etapa 2- Configuración: El ciber atacante crea un sitio web fraudulento que sea idéntico al sitio web real de las víctimas, o a su vez, crea un código malicioso que se ejecutará en el dispositivo electrónico del destinatario. Por ejemplo, para capturar pulsaciones de teclas o bloquear el acceso a los archivos de la computadora de la víctima y pedir un rescate. Los ataques de phishing, además, hacen uso de nombres de dominio que son visualmente similares a un dominio conocido real. Así mismo, para infectar directamente una máquina de destino, un atacante puede incluir un archivo adjunto en el correo electrónico. Los documentos de Office y los archivos PDF son un objetivo frecuente, ya que los usuarios están condicionados a recibirlos a diario y no siempre se percatan de que pueden contener código malicioso.
3. Etapa 3: Contacto: El ciber atacante enviará el correo electrónico a su víctima objetivo actuando como una fuente confiable o reconocida, como un banco, proveedor de servicios, amigo, colega, entre otros. El correo electrónico se referirá a un problema que requiere una acción urgente, lo que motiva a la víctima para actualizar información, hacer clic en un enlace, restablecer una contraseña o proporcionar otra información confidencial sin cuestionamiento. La mayoría de las veces, le pide a la víctima que siga un enlace falso de un tercero, para una inspección de seguridad o una simple actualización de funciones.
4. Etapa 4- Recopilación: la información compartida por la víctima se recopila preferentemente vía correo electrónico, sitio web o pulsaciones de teclas. En el sitio web falso, se le pide al usuario que envíe cierta información privada, como las credenciales de la cuenta para un sitio web específico. Una vez que se reúne los detalles, toda la información se envía al ciber atacante que diseñó el sitio web y el correo electrónico malicioso.
5. Etapa 5- Fraude: Ahora que el atacante tiene la información personal o confidencial de la víctima objetivo como número de tarjeta de crédito, credenciales del sitio web, detalles de la cuenta bancaria, puede cometer transacciones ilegales, robo de identidad y otras formas diversas de

fraude o delitos informáticos.

6. Etapa 6- Post-explotación: Existe la probabilidad de que el atacante mantenga el control después de un ataque de phishing exitoso. La post explotación consiste en que algunos atacantes pueden vender credenciales robadas en foros de hackers. Otros pueden controlar las computadoras infectadas para crear grandes botnets con el fin de enviar spam o lanzar ataques de denegación de servicio.

Cómo detectar y protegerse de un ataque de phishing

Los ciber atacantes usan correos electrónicos o mensajes de texto para intentar robar contraseñas, números de cuenta bancaria u otra información confidencial. Si obtienen esa información, podrían obtener acceso a correos electrónicos, bancos u otras cuentas. Los phishers lanzan miles de ataques de phishing diariamente, con relativo éxito.

Los correos electrónicos o mensajes de texto infectados de phishing cuentan una historia para engañar a la víctima para que haga clic en un enlace o abra un archivo adjunto. El mensaje crea un sentido de urgencia. Es posible que reciba un correo electrónico o mensaje de texto inesperado que parece ser de una empresa que conoce o en la que confía, como un banco, una financiera, una empresa de servicios públicos o un sitio web o aplicación de pago en línea. Si bien las empresas reales pueden comunicarse con usted por correo electrónico, las empresas legítimas no enviarán correos electrónicos ni mensajes de texto con un enlace para actualizar su información de pago. La banca por ejemplo jamás solicita el envío de credenciales vía email.

Algunas técnicas comunes que se usan en los correos electrónicos o mensajes de texto de phishing pueden estar escritos en diferentes sentidos:

- Le convence que su cuenta está suspendida debido a un problema de facturación.
- Lo invita a hacer clic en un enlace para actualizar sus detalles de pago.
- Le persuade de alguna actividad sospechosa o intentos de inicio de sesión en su cuenta.
- Le exhorta a que revise un problema con su cuenta o su información de pago.
- Le exige a confirmar cierta información personal o financiera.

- Le confirma que es elegible para registrarse para un reembolso del gobierno o de una empresa
- Le ofrece un cupón para cosas gratis.

La forma más obvia de detectar un correo electrónico falso es si el remitente envía el mensaje desde un dominio de correo electrónico público, como "@gmail.com". Así por ejemplo: "paypalsupport@gmail.com".

Una forma de detectar un ataque de phishing es cuando los ciber atacantes han registrado el dominio muy similar a uno real. Por ejemplo 'microsfrtftonline.com'. Para un lector incidental parecería leer las palabras 'Microsoft Online', que podría considerarse como una dirección legítima, sin embargo es una mala imitación, o por ende un sitio web falso.

Otra táctica para detectar si un correo electrónico está infectado con phishing, si contiene errores ortográficos y/o gramaticales. Al redactar los mensajes de phishing, los estafadores usan un corrector ortográfico o un software de traducción como el traductor de Google, proporcionando todas las palabras correctas, aunque no necesariamente en el contexto adecuado.

Por otro lado, un email infectado con phishing podría incluir archivos adjuntos o enlaces sospechosos. Un archivo adjunto infectado es un documento aparentemente benigno que contiene malware. Al abrir el archivo se libera malware en la computadora de la víctima, que podría realizar cualquier cantidad de actividades nefastas.

Otra técnica bastante utilizada se vincula con las noticias relacionadas a la farándula o cultura popular, ya que son aspectos de distracción, entretenimiento de gran atracción a los usuarios de redes sociales. De hecho, estas divulgaciones abusan de las fotografías y los medios digitales. Estas noticias se convierten en un vector para ejecutar enlaces y programas maliciosos. Entre algunos ejemplos se pueden señalar las noticias de videos e imágenes relacionadas a figuras importantes de la farándula o cultura popular.

Ransomware

Es un malware perteneciente a los ataques de Ingeniería Social, mediante el cual se secuestran los datos de un usuario encriptándolos y exigiendo un rescate económico a cambio de recuperarlos. El ransomware bloquea los datos o el dispositivo informático de una víctima y amenaza con mantenerlo bloqueado mientras la víctima no pague el uso de la clave para descifrar o des

encriptar los datos. El **WannaCry**, fue uno de los ataques de ransomware más devastadores lanzados en 2017 que infectó en menos de 24 horas a 230.000 computadores provocando pérdidas económicas sobre los 4.000 millones de dólares [Marion and Twede \(2020\)](#).

De acuerdo con **WliveSecurity by eset**, en octubre de 2021, el mayor banco privado de Ecuador, el Banco Pichincha, presumiblemente sufrió un ataque de ransomware, que paralizó temporalmente parte de sus operaciones, y dejó fuera de servicio algunos cajeros automáticos ^[1]. Fuentes del portal **Bleeping-Computer** ^[2] indicaron que se trató de un ataque de extorsión de ransomware a través de la herramienta de pentesting Cobal Strike, la cual suele ser manipulada por los delincuentes cibernéticos.

El ransomware se transmite regularmente a través de correos electrónicos infectados con phishing, sea mediante anuncios con vínculos corrompidos (malvertising) o páginas web falsas con código malicioso embebido para engañar al usuario para que abra dicho enlace o descargue un archivo adjunto. Luego, este ataque emplea la encriptación asimétrica para bloquear el acceso a los archivos infectados, lo que impide que las víctimas los puedan utilizar. El malware del ransomware codifica los ficheros o estructuras de archivos para que sean inutilizables e inaccesibles. Luego, el ciber atacante presenta una nota de rescate en el monitor del usuario en la que se exige criptomonedas a cambio de la clave de descifrado, hasta que la víctima pague por dicha clave. La Figura [VI.4](#) ilustra las características de un ataque de ransomware, así como su típico mensaje de extorsión.

Las instituciones más afectadas de los ataques de ransomware en la última década han sido gobierno, ministerios y las instituciones educativas. Sin embargo, como consecuencia provocada el COVID-19, además han sido afectados los centros de salud y los empresarios que trabajan de manera remota. Además, en el último año, se han acrecentado reportes de ransomware transmitido a través del tráfico encriptado, para camuflar sus enlaces y archivos adjuntos maliciosos.

Entre algunas medidas de prevención para evitar los ataques de ransomware se incluyen: (1) Copias de seguridad de la información (backups); (2) parches actualizados en aplicaciones y sistema operativos; (3) capacitación y concienciación en aspectos prácticos de ciberseguridad; (4) implantación de

¹<https://www.wlivesecurity.com/la-es/2021/10/14/banco-pichincha-sufrio-ataque-informatico/>

²<https://www.ciberseguridadlatam.com/2021/10/13/el-mayor-banco-de-ecuador-fue-victima-de-un-ciberataque/>

Figura VI.4: Caracterización y funcionamiento de un ataque de Ransomware.



planes de continuidad o recuperación de desastre; (5) uso de bloqueadores de anuncios para defenderse de los enlaces de publicidad infectada; (6) uso de antivirus que incluya una suscripción de actualización.

Baiting

Es una técnica de ataque de ingeniería social que consiste en aprovecharse de la curiosidad o avaricia de la víctima a través de un cebo. Este ataque se perpetúa de dos maneras: (i) mediante enlaces a páginas webs falsas, con ofertas, premios o descuentos exclusivos; ii) en dejar dispositivos de almacenamiento extraíble como CD, DVD, memorias USB con algún software infectado en algún lugar público a la vista, en espera de que alguien los recoja y conecte a su dispositivo para que se ejecute el malware. Según el estudio realizado por [Bekkers et al. \(2015\)](#), los ataques baiting o cebo se pueden encontrar en varios sitios Web y la mayoría son infectados a través de clientes de correo electrónico.

Scareware

El scareware es una técnica de ingeniería social que usufructúa el miedo de un usuario para que instale un software antivirus falso o malware. Las motivaciones de este tipo de ciber ataque pueden variar desde la comercialización de software falso hasta la instalación de código malicioso que puede exponer

información confidencial. La intención del scareware es asustar al usuario para que pague por un software falso o para infectar aún más un sistema informático. Para asustar a los usuarios, el scareware le presenta una variedad de alertas de seguridad mediante ventanas emergentes que aparecen como advertencias de compañías antivirus reales, que con frecuencia afirman que los archivos del usuario han sido infectados. Si la táctica funciona, la víctima descarga software falso o código malicioso que pone los datos personales del usuario en riesgo, lo que podría generar otros problemas, como el robo de identidad, víctima de espías, robo de información personal, datos de tarjetas de crédito o cuentas bancarias; bloqueo de su computadora y la exigencia de un rescate.

¿Cómo protegerse de un ataque de ingeniería social?

Para protegerse de un ataque de ingeniería social se le recomienda lo siguiente:

- Capacitar y concienciar en ciberseguridad para que los empleados y las personas vulnerables puedan detectar los signos de un correo electrónico o un mensaje de texto infectado.
- Desarrollar una cultura de ciberseguridad y tener entrenamiento para detectar mensajes maliciosos.
- Proteger los equipos computacionales y los dispositivos electrónicos usando software antivirus, anti-malware, anti spam, y/o de control parental.
- Configurar el software para que se actualice automáticamente, de modo que se ocupe de cualquier nueva amenaza de seguridad. Se sugiere contratar la suscripción de actualización automática.
- Proteger los dispositivos electrónicos móviles configurando el software para que se actualice automáticamente, con encriptación de mensajes extremo a extremo.
- Proteger las cuentas bancarias mediante la autenticación multi-factor. Algunas cuentas ofrecen seguridad adicional al requerir dos o más credenciales para iniciar sesión, un código de acceso, un PIN, la respuesta a una pregunta de seguridad, o una clave de seguridad

- Proteger la información mediante copias de seguridad en discos duros externo o en la nube.
- Invertir en tecnología de avanzada en el ámbito de la ciberseguridad para disponer de seguridad perimetral, seguridad profunda, a las aplicaciones, etc.

Lecciones aprendidas. Los ataques de Ingeniería Social se han vuelto cada vez más frecuentes debido a la vulnerabilidad de los usuarios dada su ingenuidad y desconocimiento. Pueden causar graves daños a sus víctimas, ya sea social, en su reputación o en aspectos económicos. La complejidad de los ciber ataques al explotar la percepción humana, es alta, y facilita estos ciberataques. Entre los ataques más comunes se encuentran el fraude financiero, la intrusión, la extorsión, el espionaje y la suplantación de identidad. El phishing es el más utilizado, aunque el más delicado es el Ransomware. Existen diferentes fases para la diversidad de los ataques de Ingeniería social, sin embargo, en la mayoría, el ciber atacante identifica y selecciona la víctima objetivo, sea un individuo u organización y comienza a recopilar información relevante de los sitios web, realizando llamadas telefónicas, visitando las instalaciones o monitoreando el tráfico de la red. Los objetivos pueden ser tan definidos como un solo individuo, o tan amplios como todos los usuarios de una empresa.

Sitios de Interés

1. **COMPUTING**, Los 10 ciberataques más grandes de la década. URL: <https://bit.ly/42Dsbsc>
2. **MUYCOMPUTER**, Los 10 peores incidentes de ciberseguridad en 2020. URL: <https://bit.ly/3pgps9P>
3. **KASPERSKY**, Ingeniería social: definición. URL: https://www.itu.int/dms_pub/itu-d/opb/str/D-STR-GCI.01-2021-PDF-S.pdf



or
tring< String
tring< IFormatPro
tring< String*, IFormat
tring< String* when run
following output with various co
sr is formatted with various co
FormatProvider.
sr is not used; the default cultu
tring: 11876.54
tring: 11.87654000
tring: 1.187654E+004
tring: 1.18765E+004
object for [en-MX] is used for
tring: 11876.54
tring: 11.87654000
tring: 1.187654E+004
state, object with digits group
to used for the [en-MX]
tring: 11.87654000
tring: 1.187654E+004

CAPÍTULO VII

Ataques a las aplicaciones Web

Introducción

Inicialmente, el objetivo de muchos ataques de aplicaciones web era obtener el control de un servidor de destino, que generalmente era un sistema estático en el espacio IP público que ofrecía una variedad de servicios orientados a Internet. Los ataques exitosos a menudo requerían un reconocimiento inicial y una huella de los servicios disponibles, luego un “exploit” (como un desbordamiento de búfer o la inclusión de archivos remotos) que apuntaba a una vulnerabilidad en el servidor web o en una aplicación web alojada que se ejecutaba en el contexto del usuario del servidor web. Por lo general, el objetivo final del atacante era desfigurar el sitio web y cargar contenido sospechoso, u obtener un punto de apoyo para atacar otros servidores dentro de una organización. El robo de datos confidenciales, como credenciales de usuario o información de facturación de tarjetas de crédito, también ocurría con regularidad. A menudo, se descargaban herramientas adicionales desde sitios remotos para ayudar en la escalada de privilegios al nivel de SISTEMA/raíz, limpiando la evidencia del compromiso y para obtener el control total del sistema operativo del servidor subyacente.

A medida que aumentaron las motivaciones financieras y las organizaciones criminales se involucraron más en la intrusión informática, los atacantes cambiaron el enfoque de sus ataques hacia los datos del usuario final. El robo de información personal, como detalles de contacto, registros de tarjetas de crédito y números de seguridad social, puede facilitar el robo de identidad y el fraude, o puede proporcionar un recurso económico para comercializar en el mundo clandestino electrónico. Los atacantes se centraron inicialmente en extraer datos personales almacenados a los que se podía acceder por error a través de aplicaciones web mal diseñadas o mal defendidas. Esto a menudo implicaba ataques contra listas de miembros y bases de datos de comercio electrónico de back-end, como el compromiso de agosto de 2006 del sistema de aprovisionamiento de servicios DSL en línea de AT&T. A medida que han mejorado el desarrollo web seguro y las prácticas de seguridad del lado del servidor, los millones de PC de escritorio a menudo mal administradas y los usuarios finales relativamente crédulos aún ofrecen a los atacantes presas fáciles. Esto convierte a los sistemas de los usuarios finales en algunos de los objetivos más atractivos y de mayor valor, y en los eslabones más débiles de la cadena de seguridad web. También plantea nuevos desafíos para los atacantes.

Las técnicas de contacto tradicionales, como el envío masivo de mensajes

de correo no deseado cargados de virus y los señuelos de phishing, aún pueden generar beneficios, pero los usuarios son cada vez más inteligentes cuando se trata de detectar estafas obvias basadas en correo electrónico. Los archivos adjuntos no solicitados ya no suelen abrirse automáticamente y los sistemas antispam están mejorando lentamente. Los defensores del sistema, como PIRT de CastleCops o Spamhaus, también se han vuelto más receptivos y exitosos en el cierre o bloqueo de estafas de phishing y otros dominios claramente maliciosos. Esto ha reducido significativamente el tiempo de vida activa de muchos sitios web abiertamente maliciosos.

Las mejoras en el sistema operativo y la seguridad de las aplicaciones han seguido reduciendo la amenaza del malware basado en la red que se autopropaga, disminuyendo los privilegios de usuario innecesarios y aumentando las advertencias sobre actividades potencialmente sospechosas. Por lo tanto, los atacantes se han visto obligados a buscar nuevos métodos para explotar estos objetivos de alto valor, y la web omnipresente y en constante evolución continúa brindando una serie de nuevos y atractivos vectores de ataque.

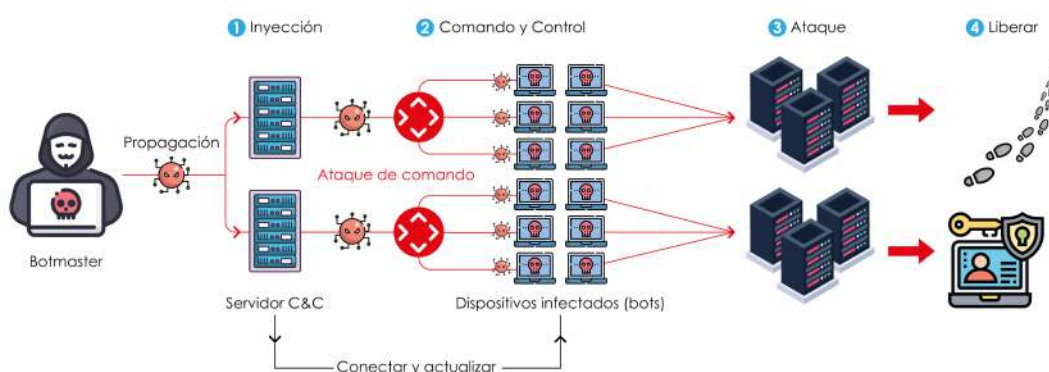
La mayoría de los sistemas cliente ya no están directamente expuestos al tráfico entrante de Internet (en parte como respuesta al escaneo masivo de la red y la propagación de malware de tipo gusano, y en parte por razones arquitectónicas, como la disminución de la tasa de uso del espacio de direcciones IPv4 disponible). Por lo tanto, los usuarios finales deben ser inducidos a interactuar con un sistema externo antes de que se pueda explotar cualquier vulnerabilidad potencial. Esencialmente, el atacante tiene que encontrar una manera de hacer que los usuarios finales desprevenidos lleguen a su sistema malicioso e interactúen con él. Hoy en día, obtener el control completo de un servidor web de destino a menudo ya no es el objetivo final de un atacante de aplicaciones web. En cambio, los servidores web comprometidos se han convertido en peldaños para los ataques contra los objetivos finales: los usuarios finales vulnerables. Este capítulo aborda algoritmos de generación de dominios y detección de botnets, detección de fraude, filtrado de spam, identificación y autenticación del usuario.

¡Bienvenidos!

Algoritmos de generación de dominios y detección de botnets (DGA)

Hoy en día, Internet juega un papel central en nuestras vidas, particularmente en la educación, las comunicaciones, la banca, los servicios gubernamentales y el comercio electrónico. Lamentablemente, el creciente número de aplicaciones empleadas amenazan con comprometer la seguridad y la privacidad del usuario [Kim et al. \(2020\)](#); [Meidan et al. \(2018\)](#); [Vinayakumar et al. \(2020\)](#); [Xu et al. \(2021\)](#). Se espera que el tamaño del mercado global de detección de botnets alcance los USD 965,6 millones para 2027, desde USD 207,4 millones en 2020, a una CAGR de 24,0 % durante el período 2021-2027 [Research \(2022\)](#). Una *botnet* es un programa de software que administra computadoras (o dispositivos), conocidos como bots, con intenciones maliciosas. Los bots son pequeños scripts creados para llevar a cabo determinadas tareas automatizadas [Kim et al. \(2020\)](#), que son operados por uno o un pequeño grupo de atacantes colaboradores conocidos como “botmaster(s)” [Vinayakumar et al. \(2020\)](#). Figura VII.1 muestra el ciclo de vida típico de una botnet.

Figura VII.1: Ciclo de vida típico de un botnet. (1) inyección (es decir, propagar bots mediante inyección), (2) comando y control (es decir, los bots están listos para recibir comandos y lanzar un ataque), (3) ataque (es decir, el botmaster envía el comando para lanzar un ataque), y (4) liberación (es decir, el botmaster elimina su huella o código fuente distribuido).



Las redes de bots dependen de los DGA para conectarse a su servidor de comando y control (C&C o C2). Estos DGA producen periódicamente muchos dominios generados algorítmicamente (AGD), que sirven como puntos de encuentro para la botnet [Curtin et al. \(2019\)](#); [Tran et al. \(2018\)](#); [Woodbridge et al. \(2016\)](#); [Yang et al. \(2020\)](#). Aunque los bots consultan todos los AGDs, solo los registrados por el botmaster de antemano se resuelven en direcciones IP válidas.

das. De esta forma, bloquear los intentos de conexión del bot a su servidor C2 es más complejo que usar direcciones IP fijas o nombres de dominio fijos, y las técnicas convencionales, como la creación de listas negras o el hundimiento, se están volviendo menos eficientes.

Los métodos tradicionales de ML para la detección de DGA basados en cadenas de nombres de dominio se basan en la extracción de características léxicas predefinidas diseñadas por humanos [Lison and Mavroeidis (2017); Spaulding and Mohaisen (2018)]. Cada vez que se utilizan características diseñadas por humanos, existe la oportunidad de que un adversario elabore su DGA con cuidado para evitar la detección. Como consecuencia, el mantenimiento de dichos sistemas de ML requiere bastante mano de obra. Hoy en día, las técnicas de DL para detectar DGA aprenden características automáticamente, por lo que potencialmente eluden el esfuerzo humano de la ingeniería de características.

Para realizar la **detección y la clasificación de familias DGA**, Woodbridge et al. [Woodbridge et al. (2016)] propusieron un enfoque basado en datos utilizando un modelo LSTM entrenado en datos recopilados de la lista blanca de Alexa (1 millón superior)¹ y aproximadamente 750 000 nombres de dominio DGA de la lista negra de Bambenek Consulting², incluidas treinta familias de malware DGA. La red LSTM para la clasificación binaria (DGA o no-DGA) se extendió a una red LSTM con una capa softmax para realizar la clasificación multiclase (qué clase DGA) y se comparó con un bosque aleatorio uno contra todos (OVA-RF) enfoque, incluyendo a Alexa como una familia benigna. Los resultados experimentales mostraron que el enfoque LSTM superó al enfoque OVA-RF para todas las familias; sin embargo, no logró identificar correctamente a algunas de las familias. Los autores afirmaron que las razones detrás de este comportamiento eran que la representación de algunas familias en el conjunto de datos era demasiado pequeña para poder realizar un aprendizaje significativo y que el clasificador confundía fácilmente algunas familias específicas (como Cryptolocker) con otra similar (como ramnit). Como solución potencial, propusieron entrenar un clasificador DGA que asigne nombres de dominio a superfamilias, haciendo que el problema de clasificación de clases múltiples sea más sencillo y resulte en puntajes de precisión predictiva más altos.

El estudio de Tran et al. [Tran et al. (2018)] propuso el uso de un algorit-

¹<https://www.alexacom/topsites>

²<http://osint.bambenekconsulting.com/feeds/>

mo de aprendizaje sensible a los costos para entrenar una red LSTM para la clasificación de familias DGA que tenga en cuenta los desequilibrios de clase. Específicamente, emplearon una arquitectura de clasificador jerárquico: en el primer paso, se entrenó una red LSTM para la clasificación binaria para etiquetar los nombres de dominio como DGA o no DGA, y en el segundo paso, a los dominios que se identificaron como DGA se les asignó un etiqueta de familia por una estructura LSTM entrenada para clasificación multiclase. El documento utilizó los datos recopilados de Alexa (lista blanca) y Bambenek Consulting (lista negra) para experimentos. Los autores afirmaron que su enfoque les permite proporcionar una mejora de al menos un 7 % en términos de recuperación del promedio macro, precisión y puntuación F1 en comparación con CS-NN, CS-SVM, CS-C4.5, Weighted Extreme Learning Machine, HMM, C5.0 DT y el estudio anterior de Woodbridge et al. [Woodbridge et al. (2016)], porque su modelo entrenado es más adecuado para familias con una representación limitada en los datos, caso en el que Woodbridge et al. [Woodbridge et al. (2016)] tuvo problemas. Aún así, el enfoque de Tran et al. no clasifica con precisión algunas familias, como la familia *locky* (malware ransomware), que no se incluyó en los trabajos originales de Woodbridge et al. [Woodbridge et al. (2016)].

Muchas DGA usan listas de palabras en inglés para generar nombres de dominio de aspecto plausiblemente limpio, lo que dificulta la detección automática. Curtin et al. [Curtin et al. (2019)] aplicaron la arquitectura RNN para la detección de dominios DGA utilizando una puntuación smashword como medida del parecido del dominio con las palabras en inglés. El modelo de detección DGA propuesto dividió los datos de entrada en subdominio, dominio y dominio de nivel superior (TLD). El subdominio y el dominio se introdujeron en modelos RNN individuales (con celdas LSTM) para predecir el siguiente carácter en ellos y estas predicciones se combinaron a través de una prueba de razón de verosimilitud generalizada (GLRT). Luego, la salida se combinó con los datos de WHOIS y el TLD codificado one-hot en el modelo de regresión logística final para predecir si el dominio de entrada es malicioso o no. Los datos no DGA se recopilaron de Alexa³ y OpenDNS⁴, mientras que los dominios DGA se recopilaron a partir de nombres de dominio simulados mediante los siguientes algoritmos DGA disponibles públicamente: DGArchive⁵.

³<https://www.alexa.com/topsites>

⁴<https://github.com/opendns/public-domain-listas>

⁵<https://dgarchive.caad.fkie.fraunhofer.de/>

el repositorio DGA de Andrey Abakumov⁶ y las implementaciones de DGA de Johannes Bader⁷. El conjunto de datos final incluyó 41 familias DGA más datos no DGA, con un total de 2,29 millones de nombres de dominio (1,01 millones no eran DGA y 1,28 millones eran DGA), que se utilizaron en varios experimentos. Los resultados experimentales demostraron que el enfoque propuesto proporciona un mejor rendimiento con tasas más bajas de falsos positivos en familias DGA con puntajes altos de *smashword*, como las familias difíciles *matsnu* y *suppobox*.

Con el desarrollo de redes móviles más allá de 5G (B5G), han aumentado los problemas que amenazan la seguridad y la privacidad. Para detectar los nombres de dominio maliciosos, Xu et al. [Xu et al. (2021)] utilizaron un modelo LSTM bidireccional jerárquico (H-BiLSTM), que se entrenó con datos recopilados de Alexa y 360netlab [at 360 (2019)]. Los resultados experimentales mostraron que el modelo propuesto con tres capas en la jerarquía logró un 96,1 % de precisión superando a los algoritmos tradicionales (es decir, SVM, DT, LR y NB), pero cuando aumenta el número de capas, aumenta la complejidad computacional del modelo. también, disminuyendo la tasa de precisión.

Detección de fraude

En los sistemas tecnológicos, las acciones fraudulentas ocurren en varias áreas de la vida diaria, por ejemplo, en redes de telecomunicaciones, banca en línea, comunicaciones móviles y comercio electrónico [Kou et al. (2004)]. Estos fraudes generan pérdidas financieras considerables para las personas, las empresas y el gobierno. Como consecuencia, la detección del fraude se ha convertido en un tema crítico. Según [Intelligence (2021)], se prevé que el mercado mundial de detección y prevención del fraude alcance los 51 300 millones de USD en 2027, frente a los 19 500 millones de USD de 2020, con un crecimiento anual del 14,8 % durante el período 2020-2027.

La detección de fraude se refiere a reconocer rápidamente el fraude tan pronto como sea posible después de que se haya cometido [Ji et al. (2020); Pandit et al. (2021); Xu et al. (2018); Yu et al. (2020)]. Los métodos de detección están en constante desarrollo para enfrentar a los delincuentes adaptándose a sus estrategias, generalmente aprovechando la minería de datos, las estadísticas y el

⁶<https://github.com/andrewaeva/DGA>

⁷<https://johannesbader.ch> y

https://github.com/baderj/domain_generation_algorithms

aprendizaje automático. Los métodos de representación en profundidad propuestos por DL pueden obtener los vectores de representación más profundos incorporando información oculta. En particular, las técnicas de DL permiten la extracción de información compleja de los datos. En comparación con los métodos tradicionales de aprendizaje de representación basados en aprendizaje automático, los métodos de representación profunda son más propicios para explorar patrones de fraude implícito más profundos. Esta sección incluye tres tipos de fraude: fraude de telecomunicaciones, fraude de intrusión informática y fraude de tarjetas de crédito.

En general, las actividades de fraude con tarjetas de crédito pueden ocurrir tanto en línea como fuera de línea. Sin embargo, en el mundo actual, las actividades de transacciones fraudulentas en línea aumentan día a día. El fraude en línea se realiza a través de compras telefónicas, la web o el titular de la tarjeta no está presente. Los delincuentes únicamente requieren los datos de la tarjeta (por ejemplo, DNI, fecha de caducidad, etc.), y no es imprescindible tener la tarjeta en mano o simular la firma del titular. Para detectar los patrones de comportamiento fraudulento más relevantes en un sistema de detección en línea, Cheng et al. [Cheng et al. \(2022\)](#) propusieron una red de gráficos basada en la atención espacial-temporal (STAGN). En primer lugar, un GNN aprendió las características del gráfico de transacción temporal y basado en la ubicación. Luego, los autores emplearon atención espacio-temporal, además de las representaciones de tensor aprendidas, que luego se introdujeron en una red de convolución 3D. Los pesos atencionales se aprendieron de manera conjunta de extremo a extremo con redes de detección y convolución 3D. STAGN se evaluó en un conjunto de datos de transacciones de tarjetas del mundo real de un banco comercial. Aunque se logró un AUC medio de 0,88 a 0,90 en la mayoría de los experimentos realizados, el enfoque propuesto se empleó para alertar a los expertos del dominio sobre posibles fraudes, y los agentes procesaron manualmente las acciones de seguimiento. Por lo tanto, la interacción humana es necesaria y no hay forma de bloquear las transacciones fraudulentas en tiempo real.

Con respecto a la búsqueda de transacciones fraudulentas en línea, Cao et al. [Cao et al. \(2021\)](#) propusieron un modelo de atención de dos niveles para capturar la representación profunda de las características de los comportamientos de las transacciones en línea. Esto se logra mediante la integración de dos incrustaciones de datos en el nivel de muestra de datos y el nivel de característica. El modelo de atención a nivel de muestra es un modelo basado

en árbol y se emite para incrustar la información significativa de la muestra. El modelo de atención a nivel de función se basa en GRU bidireccional y se utilizó para incorporar la información de dependencia entre funciones. Finalmente, se combinaron las incrustaciones aprendidas por los dos mecanismos de atención para el entrenamiento de un modelo de detección de fraude. El modelo propuesto se evaluó en cuatro conjuntos de datos públicos⁸ y un conjunto de datos privados (registros de transacciones de tarjetas) proporcionado por una empresa financiera en China. Los resultados mostraron que el método propuesto logró una exactitud, precisión, recuperación y F1 de más del 85 % en los experimentos realizados, superando las técnicas tradicionales como el aumento de gradiente.

Filtrado de spam

El spam es un problema grave para la mayoría de los usuarios de Internet y el ciberataque más común. Se estima que los correos electrónicos no deseados constituyen la proporción mayoritaria de los correos electrónicos globales, alrededor del 73 % [Sorkin \(2023\)](#). Según [Sorkin \(2023\)](#), el spam cuesta a las empresas 20.500 millones de dólares estadounidenses al año en disminución de la productividad y los gastos técnicos. Por lo tanto, se hace evidente que existe la necesidad de filtros antispam fiables e inteligentes. Los métodos tradicionales de ML a veces se consideran inadecuados para capturar la variabilidad del comportamiento del spam. Recientemente, se adoptó DL en el desarrollo de filtros antispam y se demostró que es eficaz en esta área [Feng et al. \(2018\)](#); [Gao et al. \(2021\)](#); [Guo et al. \(2020\)](#); [Madisetty and Desarkar \(2018\)](#); [Makkar and Kumar \(2020\)](#); [Roy et al. \(2020\)](#); [Seth and Biswas \(2017\)](#); [Wu et al. \(2017\)](#); [Yang et al. \(2013\)](#).

Seth et al. [Seth and Biswas \(2017\)](#) propusieron dos arquitecturas multimodales basadas en CNN para abordar los correos electrónicos no deseados basados en imágenes y contenido no deseado. Estas arquitecturas combinaron clasificadores de texto e imagen para producir una clase de salida (es decir, spam o no spam). La primera arquitectura empleó la fusión de características, mientras que la otra extrajo las reglas entre los dos clasificadores y empleó las probabilidades de clase. Entre los dos enfoques, la segunda arquitectura logró

⁸Los conjuntos de datos públicos se recopilaron de Kaggle y el Repositorio de aprendizaje automático de UCI, que cubren las áreas de detección de fraude con tarjetas de crédito, predicción de pagos predeterminados y predicción de préstamos. Desafortunadamente, no se proporciona información detallada sobre ellos.

la mejor precisión con una tasa del 98,11 %. Sin embargo, el conjunto de datos utilizado es limitado (solo incluye 1500 imágenes), lo que genera un problema de sobreajuste. Por otro lado, para detectar sitios web de spam en entornos de IoT, Makkar [Makkar and Kumar \(2020\)](#) introdujo un modelo basado en LSTM que se entrenó con las funciones de enlace. Este trabajo utilizó el conjunto de datos WEBSHAM-UK2007 [Castillo et al. \(2006\)](#) y logró una precisión del 95,25 % en la detección de hosts de spam. Lamentablemente, la parte de evaluación no proporciona ninguna otra medida, como precisión, recuperación o puntaje F1.

En [Makkar et al. \(2021\)](#), se propuso un esquema basado en DL que proporciona inteligencia perimetral para la filtración de datos web y la detección de spam web. La solución propuesta constaba de tres capas: la capa inferior, la capa intermedia y la capa superior. La capa inferior era responsable de recopilar datos web de varias fuentes y entregar los datos procesados a la siguiente capa. La capa intermedia era responsable de la detección de spam web en el perímetro, donde se utilizaron los modelos LSTM y CNN para construir el detector de spam. Finalmente, la capa superior se encargaba de almacenar eficientemente la información web en el entorno de la nube. Aunque el enfoque propuesto logró una precisión del 98,77 %, se utilizó un conjunto de datos de tamaño pequeño de 300 muestras para entrenamiento y 300 muestras para prueba, lo que podría causar un problema de sobreajuste.

Con el predominio de Internet, las reseñas en línea se han convertido en un valioso recurso de información para las personas. Sin embargo, la autenticidad de las reseñas en línea sigue siendo una preocupación, y las reseñas engañosas se han convertido en uno de los problemas de seguridad a resolver. Los spams de reseñas engañarán a los usuarios para que tomen decisiones subóptimas e infligirán su confianza en las reseñas en línea. El estudio [Gao et al. \(2021\)](#) introdujo un modelo de detección de spam no supervisado basado en DL para revisiones en línea utilizando una versión modificada de GAN condicional para abordar el problema anterior. Su modelo se evaluó en reseñas recopiladas de Douban (una comunidad china en línea donde los usuarios comparten sus reseñas para expresar sus sentimientos sobre las películas). El rendimiento del modelo propuesto presenta una precisión del 87,03 % superada por algunos clasificadores no supervisados tradicionales y profundos populares, como VAE, LOF y OC-SVM.

Teniendo en cuenta que el uso del servicio de mensajes cortos (SMS) [Roy et al. \(2020\)](#) ha aumentado durante la última década, Roy et al. realizó un aná-

lisis comparativo de dos modelos de DL (a saber, LSTM y CNN) y varios sistemas tradicionales para clasificar los mensajes de texto spam y no spam [Roy et al. \(2020\)](#). Los modelos propuestos se basaron únicamente en datos de texto, y para su evaluación se utilizó el conjunto de datos SMS Spam Collection v.1 [Almeida et al. \(2011\)](#). El estudio informa que CNN superó a LSTM y otros modelos tradicionales de ML, logrando una tasa de 98,5 %, 97,6 % y 98,0 % en precisión, recuperación y puntuación F1, respectivamente. Sin embargo, el conjunto de datos utilizado no es lo suficientemente grande, con solo 747 mensajes de spam y 4827 mensajes que no son spam, lo que lleva a un sobreajuste. Además, los mensajes de texto examinados en este estudio están escritos únicamente en inglés.

Para abordar la limitación de la eficiencia computacional de las variantes de RNN como LSTM, los autores [Liu et al. \(2021\)](#) propusieron una versión modificada del modelo Transformer [Vaswani et al. \(2017\)](#), que usa solo un mecanismo de atención de múltiples cabezales en lugar de variantes de RNN como codificadores y decodificadores. En particular, se realizaron dos modificaciones al modelo Transformer de vainilla. En primer lugar, debido a la falta de una secuencia de salida (secuencia de destino) en la tarea de detección de spam de SMS, se utilizó una lista de parámetros entrenables denominada “memoria” como sustituto de la incrustación de la secuencia de salida. En segundo lugar, se aplicó la función sigmoidea como función de activación final para asignar el resultado a un resultado binario (prediciendo si el mensaje es spam o no). En los experimentos, se utilizaron dos conjuntos de datos diferentes: SMS Spam Collection v.1 [Almeida et al. \(2011\)](#) y los conjuntos de datos de UtkMI’s Twitter [kaggle \(2019\)](#). Aunque los resultados revelaron que el modelo propuesto supera los modelos tradicionales y de aprendizaje profundo (p. ej., LR, NB, RF, SVM, LSTM y CNN-LSTM) en los dos conjuntos de datos, existen algunos modelos mejorados basados en el Transformador con funciones más complejas. arquitectura como GPT-3 [Brown et al. \(2020\)](#) y BERT [Devlin et al. \(2018\)](#) que podrían explorarse en el futuro.

Identificación y autenticación del usuario

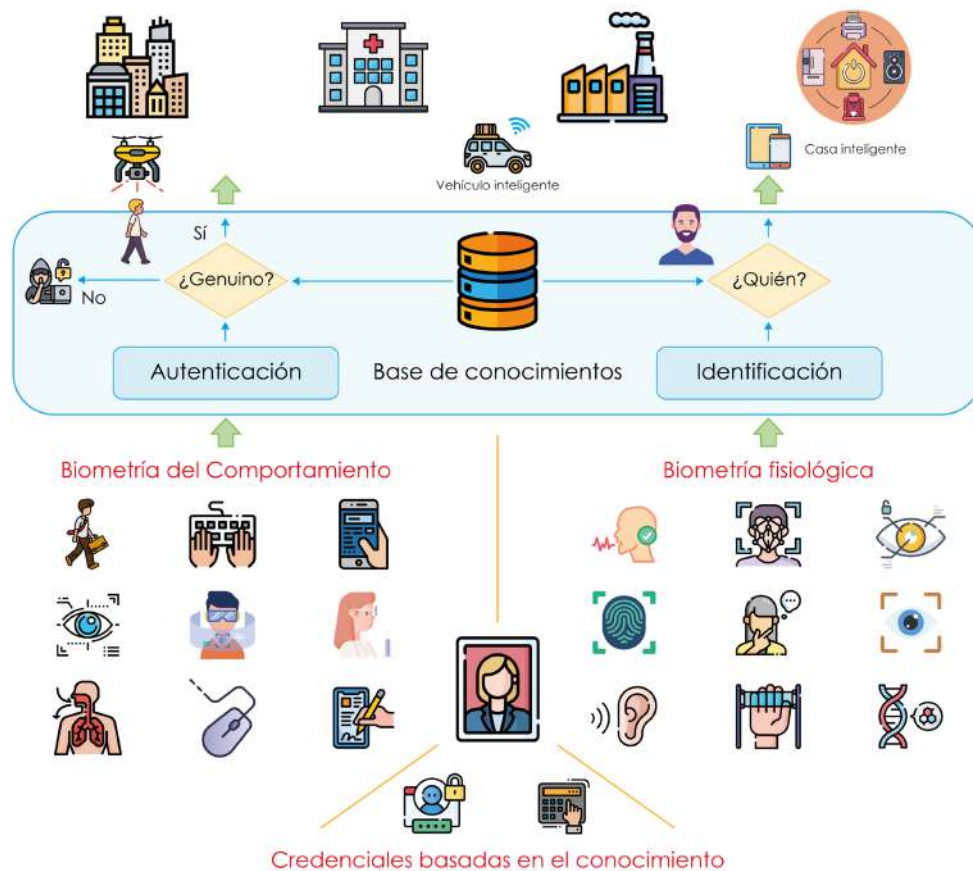
La sociedad hoy en día exhibe una creciente demanda de autenticación automática y segura de personas en una gran cantidad de escenarios. Para hacer frente a esta necesidad, los sistemas de reconocimiento biométrico basados en las características biológicas (p. ej., huella dactilar o iris) o comportamentales

(p. ej., voz o firma) de los individuos se han consolidado como un paradigma fiable en las últimas décadas [George et al. \(2020\)](#); [Menotti et al. \(2015\)](#); [Park et al. \(2019\)](#); [Souza et al. \(2017\)](#).

Otro paradigma de autenticación basado en las características fisiológicas y de comportamiento únicas de los humanos ha surgido como resultado de la amplia proliferación de IoT [Kong et al. \(2019\)](#); [Lin et al. \(2018\)](#), que ha transformado nuestros hogares, oficinas y espacios públicos en espacios inteligentes que integran muchos sensores y actuadores haciéndonos la vida más fácil, sencilla y segura mediante la prestación de diferentes servicios personalizados.

Los beneficios de estos paradigmas de autenticación alternativos sobre los métodos convencionales (por ejemplo, el alivio de la necesidad de memorizar contraseñas y/o transmitir tokens) han permitido su amplio despliegue. La Figura VII.2 muestra las categorías de los sistemas de autenticación.

Figura VII.2: Una descripción general de las credenciales para la autenticación e identificación de usuarios y sus aplicaciones.



Autenticación biométrica

Los sistemas biométricos están expuestos a ataques externos, como ocurre con toda tecnología relacionada con la seguridad. Entre todos los posibles puntos de ataque explicados en [Busch \(2023\)](#); [Ratha et al. \(2001\)](#); [Zwiese et al. \(2000\)](#), el dispositivo de captura biométrica es presumiblemente el más vulnerable: un eventual atacante no necesita saber sobre el funcionamiento interno del sistema para romperlo. En su lugar, se puede presentar el dispositivo de captura con un instrumento de ataque de presentación (PAI), como un dedo pegajoso, una superposición de huellas dactilares o una máscara 3D, para interferir con su comportamiento esperado. El objetivo principal podría ser hacerse pasar por otra persona (es decir, un impostor activo) o evitar ser reconocido (es decir, un encubridor de identidad personal). Estos ataques se conocen en ISO/IEC 30107 [Busch \(2023\)](#) como ataques de presentación (PA), también conocidos como suplantación de identidad. Para abordar los graves problemas de seguridad que plantean los PA, el desarrollo de técnicas automáticas que puedan identificar entre los intentos de acceso realizados con PAI y las presentaciones de buena fe (es decir, en vivo o reales) se ha convertido en una tarea valiosa [Hadid et al. \(2015\)](#); [Marcel et al. \(2014\)](#). Comúnmente llamados métodos de detección de ataques de presentación (PAD) [Menotti et al. \(2015\)](#). Los primeros enfoques de PAD se basaron en las denominadas funciones artesanales, incluido el análisis de movimiento o los descriptores de texturas [Marcel et al. \(2014\)](#); [Raghavendra et al. \(2015\)](#). Sin embargo, DL se ha convertido en un área próspera en los últimos años, y el reconocimiento biométrico en general, y PAD en particular, no son una excepción. DL permite que los sistemas aprendan de la experiencia y capten el mundo en términos de una jerarquía de unidades más simples, de esta manera, permite un progreso significativo en dominios complejos, como el reconocimiento biométrico [George et al. \(2020\)](#); [Menotti et al. \(2015\)](#); [Park et al. \(2019\)](#); [Souza et al. \(2017\)](#).

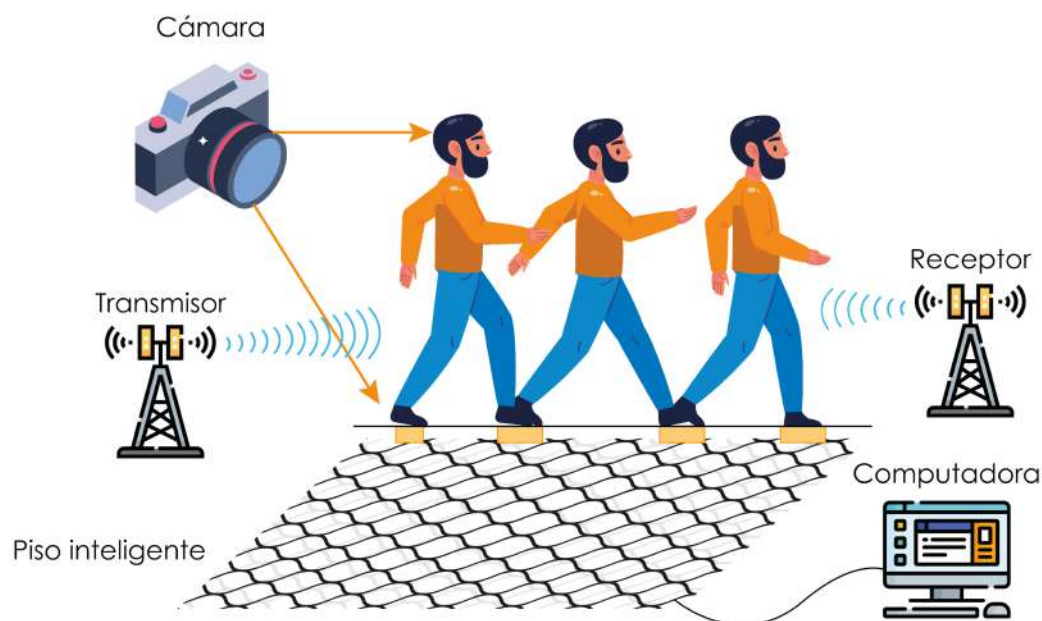
La biometría de los nudillos de los dedos puede proporcionar información invariable y discriminatoria para un reconocimiento confiable [Cheng and Kumar \(2020\)](#). Esto se debe a los patrones inherentes únicos y estables que existen en la superficie exterior de la región del nudillo del dorso del dedo. La adquisición de imágenes de los nudillos de los dedos puede complementar y realizarse simultáneamente con la recuperación de huellas dactilares. Cheng et al. [Cheng and Kumar \(2020\)](#) introdujeron un enfoque basado en DNN para la identificación de nudillos en 3D sin contacto. La imagen de entrada empleada

tenía un tamaño de 48×80 y había un número total de 190 clases. Las configuraciones y bloques de construcción de las capas convolucionales adoptaron una estructura residual como en ResNet. El estudio utilizó la base de datos de imágenes de nudillos de los dedos en 3D de HKPolyU [Cheng and Kumar \(2019\)](#) adquirida de 228 sujetos diferentes. Aunque el modelo propuesto demostró un alto potencial para discriminar individuos con alta precisión, adolece de diferentes limitaciones como una alta complejidad computacional y la falta de una gran cantidad de datos de entrenamiento.

Los PAI para atacar los sistemas de reconocimiento facial se están volviendo cada vez más triviales, debido a la disponibilidad común de docenas de muestras biométricas en las redes sociales y al desarrollo de tecnologías de fabricación, como las impresoras 3D. Un ataque sofisticado podría incluir la fabricación de máscaras 3D personalizadas que se asemejan a la identidad de un objetivo para la suplantación de identidad o eludir la identificación. Para ofrecer un uso más seguro de la tecnología de reconocimiento facial, George et al. [George et al. \(2020\)](#) introdujeron un marco PAD para detectar una diversidad de ataques 2D y 3D basados en Multi-Channel CNN (MC-CNN). MC-CNN usó una subred de reconocimiento facial, a saber, LightCNN, lo que hace que el marco sea reutilizable tanto para PAD como para reconocimiento facial. También introdujeron un conjunto de datos Wide MultiChannel Presentation Attack (WMCA), que contiene PA 2D y 3D. Utilizaba múltiples canales/dispositivos de captura, como profundidad, color, térmica e infrarroja. Con respecto a los ataques faciales en 3D, adoptó una máscara rígida, una cabeza falsa, máscaras de silicona flexibles y máscaras de papel. Su modelo logró una tasa de error de clasificación del 0,3 % sobre el conjunto de datos introducido, superando las líneas de base basadas en características. El conjunto de datos está disponible públicamente. Sin embargo, sigue siendo un conjunto de datos de tamaño pequeño (menos de 75 sujetos), lo que sin duda limita el desarrollo de métodos PAD de máscara 2D/3D útiles y prácticos.

Todos los enfoques anteriores revisados en esta sección demuestran que las técnicas basadas en DL pueden proporcionar una ayuda significativa en la detección de ataques de presentación. Sin embargo, no está claro que su capacidad de detección de ataques desconocidos. Las muestras de entrenamiento limitadas y la generalización de los métodos en los experimentos de bases de datos cruzadas aún deben explorarse y mejorarse.

Figura VII.3: Ejemplo autenticación conductual.



Autenticación conductual

Con el avance de las ciudades inteligentes, los entornos domésticos y los edificios de oficinas, el concepto de autenticación de usuario está evolucionando desde la mera restricción del acceso a la información confidencial por parte de usuarios no autorizados, para ofrecer también oportunidades de servicios personalizados adaptados a cada usuario específico. En la práctica, se considera más adecuado un sistema que permita una identificación automática del usuario discreta. En la Figura VII.3 se muestra un ejemplo sencillo. Con este fin, Lin et al. [Lin et al. \(2018\)](#) aprovecharon la información del estado del canal (CSI) de las señales WiFi para capturar patrones de marcha únicos para la identificación del usuario mediante una red profunda. En particular, al extraer las medidas de CSI integradas en las señales WiFi, una red profunda podría identificar a cada usuario y designar una "huella digital" que encapsularía su comportamiento. La red se diseñó con 1 capa de CNN y 15 capas de ResNet para extraer las características de alto nivel de los datos de CSI, seguida de una capa de agrupación promedio global utilizada para reducir la dimensión y, finalmente, una capa de softmax para el cálculo de la puntuación de probabilidad para cada entrada. Consiguieron una precisión de autenticación del 98 % con un número reducido de sujetos. Aunque este estudio demuestra una alta precisión, los sujetos de prueba tenían que caminar a través de un camino

designado en una dirección de marcha estrictamente predefinida. En general, la tasa de precisión decreta significativamente con el aumento del número de participantes.

Además, Kong et al. [Kong et al. (2019)] utilizaron el CSI de las señales Wi-Fi para autenticar a los usuarios durante las interacciones entre humanos y computadoras basadas en LSTM. Primero, el CSI de las señales WiFi causadas por los gestos de los dedos se preprocesaron y segmentaron a través de un diferencial de amplitud. El CSI fragmentado de las señales WiFi sirvió como entrada para entrenar el LSTM de tres capas. En la primera capa, se extrajeron las características a nivel de gestos. Luego, la salida de la primera capa se alimentó a la segunda capa, que extrajo las características del nivel de movimiento (por ejemplo, velocidad, ángulo y tiempo). Finalmente, la última capa tomó la salida de la segunda capa como entrada y extrajo las características a nivel de usuario, que representaban las características únicas del usuario y se usaban para la identificación del usuario y la detección de falsificadores. Además, el estudio proporcionó un mecanismo de *autenticación continua* basado en la descripción del dominio del vector de soporte, que intentaba autenticar al usuario periódicamente después del inicio de sesión para proteger de manera más eficiente los datos privados del usuario. Su modelo logró una precisión de autenticación del 91,4 % con siete sujetos. El número limitado de participantes y escenarios en los experimentos son inconvenientes en este estudio. En general, los métodos de [Kong et al. (2019)] y [Lin et al. (2018)] tienen una limitación, es decir, funcionan en un entorno controlado donde solo la persona que realiza la autenticación está presente en las proximidades del transmisor y receptor WiFi. Además, es necesario ampliar estos trabajos para que puedan identificar a una persona en presencia de otras personas y actividades en entornos inteligentes.

La autenticación de usuarios móviles mediante funciones y uso conductual se puede implementar aprovechando los sensores integrados. En particular, mediante el uso de datos sensoriales, un proceso en segundo plano captura de forma continua e implícita el comportamiento del usuario para realizar una autenticación activa y transparente (por ejemplo, mediante un patrón de movimiento [Abuhamad et al. (2020)]). En [Abuhamad et al. (2020)] se presentó un enfoque que aprovecha los sensores en los teléfonos inteligentes de consumo para autenticar a un usuario mediante la aplicación de técnicas de DL. Los autores utilizaron LSTM para procesar y modelar el comportamiento del usuario en tiempo real y con alta frecuencia. Se realizaron varios experimentos utilizan-

do un conjunto de datos del mundo real que incluye datos de 84 participantes. Los resultados mostraron que el modelo propuesto operaba con precisión, empleando solo tres sensores: acelerómetro, giroscopio y magnetómetro con una alta frecuencia de autenticación. En particular, el modelo alcanzó su mejor rendimiento utilizando datos sensoriales recopilados cada segundo, logrando una puntuación F1 de autenticación de aproximadamente 98 %, FAR de 0.95 % y FRR de 6.67 %. Sin embargo, no hay detalles suficientes sobre el conjunto de datos (p. ej., el número total de muestras recolectadas); por lo tanto, es imposible concluir si esta aplicación podría escalar de manera eficiente en un entorno real.

La realidad virtual (VR) está ganando popularidad tanto en el entretenimiento virtual como en los dominios profesionales. En general, los sistemas de realidad virtual se caracterizan por un alto grado de inmersión [Liebers et al. \(2021\)](#). Por lo tanto, para mantener esta inmersión, los esquemas de autenticación implícita que no interrumpen la interacción del usuario y se llevan a cabo a través de acciones que realiza el usuario parecen encajar perfectamente [Jakobsson et al. \(2009\)](#). La biometría basada en tareas se basa en los datos obtenidos por el desempeño manual de tareas de un usuario, lo que constituye una subcategoría de biometría conductual. Liebers et al. [Liebers et al. \(2021\)](#) desarrollaron un sistema basado en DL para la identificación implícita de usuarios en realidad virtual a través de biometría conductual basada en tareas en dos escenarios y evaluaron su desempeño en un estudio de usuarios (N = 16). Los escenarios imitaban los juegos comunes de realidad virtual, como los bolos y el tiro con arco, donde los usuarios interactúan naturalmente con el juego. El LSTM y MLP se utilizaron para construir el clasificador para predecir la identidad del usuario. Los resultados mostraron que el sistema propuesto logró una precisión de identificación de hasta el 90 % en diferentes experimentos. Además, se investigó el papel de la fisiología de los usuarios en la biometría del comportamiento al alterar y normalizar virtualmente sus proporciones corporales. Los autores encontraron que la normalización corporal generalmente mejora la tasa de identificación, en algunos casos hasta en un 38 %. En consecuencia, se puede utilizar para aumentar el rendimiento de los sistemas de identificación.

Lecciones aprendidas. Las aplicaciones web plantean una serie de problemas de seguridad derivados de una codificación incorrecta. Las debilidades o vulnerabilidades graves permiten a los delincuentes obtener acceso directo y público a las bases de datos para recopilar datos confidenciales; esto se conoce como ataque de aplicación web. Muchas de estas bases de datos contienen información valiosa (por ejemplo, datos personales y detalles financieros), lo que las convierte en un blanco frecuente de ataques. Aunque tales actos de vandalismo (a menudo realizados por los llamados script kiddies) como desfigurar sitios web corporativos siguen siendo comunes, hoy en día los atacantes prefieren obtener acceso a los datos confidenciales que residen en el servidor de la base de datos debido a los inmensos beneficios de vender los resultados de violaciones de datos.

Sitios de Interés

1. **ION, Nautilus: An Embedded Navigation Authentication Testbed.** Banco de pruebas de autenticación de navegación integrado. URL: <https://www.ion.org/publications/abstract.cfm?articleID=17976>.
2. **IEEE, iBoT: IoT Botnet Testbed.** URL: <https://doi.org/10.1109/tnse.2022.3163201>
3. **Telesign: Verify API simplifies authentication at scale,** APIs para autenticación de usuario a escala. URL: https://www.telesign.com/products/verification?utm_medium=paid_search&utm_source=google&utm_campaign=digital%20identity%20-%20americas



CAPÍTULO VIII

Ataques de Denegación de Servicio

Introducción

Un ataque de Denegación de Servicios (DoS) o (Distribuido, DDoS), es un delito malintencionado que tiene como objetivo hacer que un sitio web, servicio en línea, aplicación móvil, o servidor de red que dependa de la disponibilidad de Internet, queden inaccesibles para los usuarios legítimos. Este tipo de ataque se puede lograr a cabo de varias formas, tales como el envío de grandes volúmenes de tráfico a una página web para sobrecargarla, la inundación mediante el envío de paquetes maliciosos o infectados a través de la red para interrumpir su funcionamiento, o el consumo excesivo de recursos de CPU y memoria para limitar la capacidad de respuesta del sistema, lo que impide que los usuarios legítimos puedan acceder a los servicios.

Para entender la magnitud de los ataques de DoS, en abril de 2007, **Estonia**, un Estado soberano de la Unión Europea, sufrió un ataque DDoS a gran escala contra sus infraestructuras de misión crítica, tales como sus servicios gubernamentales, instituciones financieras y medios de comunicación como lo señala Cloudflare ^[1]. Este ataque tuvo un efecto devastador que duró algunos días, debido a que el Gobierno de Estonia había implementado servicios públicos en línea y gestionaba todo de forma digital. Este ataque fue considerado por muchos como el primer acto de guerra cibernética, que respondía presumiblemente a un conflicto político con Rusia.

Otro ataque de DoS, según la Superintendencia de Bancos del Ecuador ^[2], se registró en contra del **Banco Central** en mayo de 2019, el cual sufrió un ataque DoS que causó la interrupción de varios servicios en línea, incluyendo el colapso de su página web y del sistema de pagos electrónicos. Aunque el ataque no causó daños económicos significativos, el banco informó a sus clientes sobre la probabilidad de intentos de fraude como resultado del ataque perpetuado.

Este capítulo tiene como objetivo poner en consideración del lector las características, elementos que intervienen en un ataque de DoS y sus diferencias con un ataque de Denegación de Servicio Distribuido (DDoS). Además se muestran algunos ataques perpetuados en los últimos años y las herramientas principales utilizadas por los ciber delincuentes para cometer estos delitos. Finalmente, se otorgan soluciones de cómo prevenirlos y mitigarlos.

¡Bienvenidos!

¹<https://www.cloudflare.com/es-es/learning/ddos/famous-ddos-attacks/>

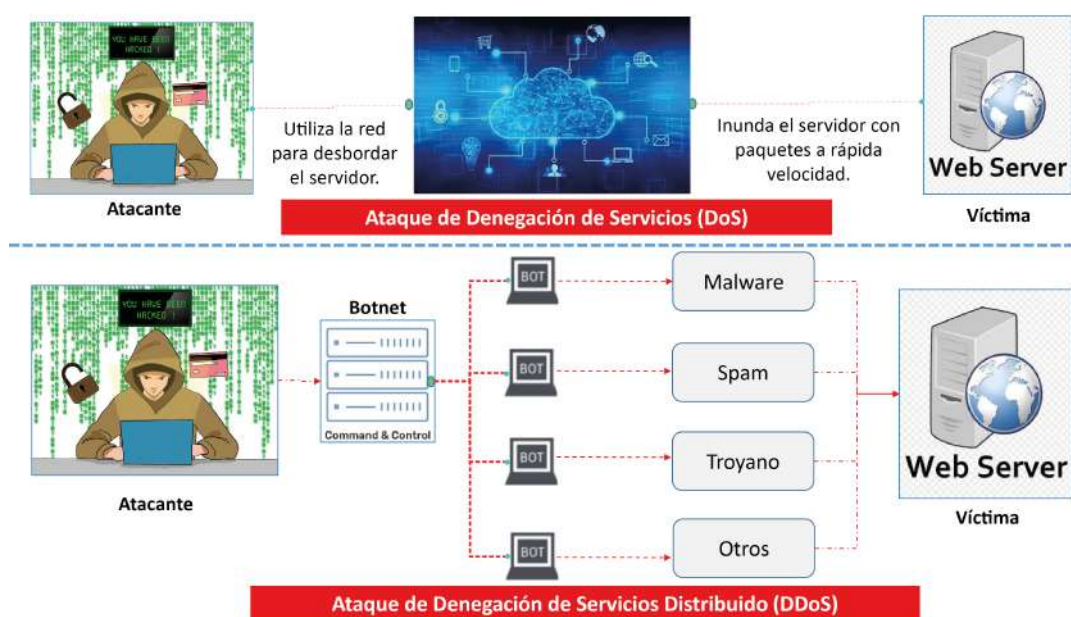
²<https://bit.ly/3NQuBPZ>

Caracterización

Un ataque de denegación de servicio (DoS) es una ofensiva cibernética diseñada para colapsar el funcionamiento de un servicio en línea para usuarios legítimos que funciona de la siguiente manera: El ciber ataque inicia con el establecimiento de la IP del servidor objetivo. Luego utiliza herramientas de software para análisis de vulnerabilidades, como las de escaneo de puertos para detectar posibles vulnerabilidades. Una vez detectadas, el ciber-atacante genera el ataque DoS en contra del objetivo, utilizando técnicas de desbordamiento del bufer de la memoria o la inundación con paquetes ICMP infectados al servidor.

Por lo general, los delincuentes cibernéticos usan una sola computadora para inundar un objetivo con tráfico. Cuando el ataque utiliza una red de computadoras infectadas para enviar tráfico a un objetivo establecido se conocen como un ataque de denegación de servicio distribuido (DDoS). En un DDoS, los dispositivos utilizados son a menudo parte de una botnet, que es una red de dispositivos infectados controlados por un ciber-atacante. La Figura VIII.1 muestra visualmente las diferencias entre un DoS y un DDoS, así como su funcionamiento. La Tabla VIII.1 caracteriza a ambos ataques y muestra sus principales diferencias:

Figura VIII.1: Ataques de DoS y DDoS.



Cómo se ilustra en la Figura VIII.1, el atacante cibernético utiliza una botnet. Una botnet o también denominada red zombi, es un conjunto de equipos

Tabla VIII.1: Matriz de Comparación entre DoS y DDoS.

Argumento	DoS	DDoS
Potencia	El tráfico enviado al objetivo está limitado por la potencia de la computadora del atacante o del rendimiento de la red	El volumen de tráfico es mayor porque se logra mediante el uso de varias computadoras para reenviar el tráfico
Detección	Fácil de rastrear y detener a los ciber-atacantes porque solo usan una computadora.	Difícil rastrear y detener a los ciber-atacantes porque utilizan una red de computadoras infectadas repartidas por todo el mundo
Coordinación	No requiere de coordinación, pues implica el uso de una sola fuente o un solo dispositivo electrónico	Implica el uso y coordinación de múltiples dispositivos para atacar el mismo objetivo simultáneamente.
Escala	Se lo realiza a menor escala puesto que si se lo ejecuta a una mayor escala pierde efectividad.	Es más efectivo debido a su mayor escala y distribución
Intensidad	Intensidad relativamente baja	Es un ciberataque muy severo.
Velocidad	Es un ataque lento	Es más rápido
Conexión en red	Usa una única conexión	Utiliza muchas fuentes de ataque de tráfico, con frecuencia en forma de una botnet

o dispositivos que están bajo el control de un atacante cibernético y que se utilizan para incurrir en actividades maliciosas en contra uno o más servidores víctima. En un ataque de DDoS, el atacante envía un gran volumen de tráfico falso desde cada dispositivo zombi o bot para sobrecargar rápidamente el servidor víctima. A medida que el servidor procura atender el flujo de solicitudes, los ciclos de su procesador, interfaces de red y memoria interna utilizada para su procesamiento se consumen, lo que hace que las conexiones del tráfico normal se ralenticen hasta el punto de colapsar el servicio.

Una variante de los ataques DDoS consiste en sobrecargar una red de computadoras con enormes cantidades de tráfico para saturar la capacidad de transmisión del recurso objetivo, esto es conocido como ataque DDoS volumétrico. En un ataque DDoS volumétrico, la botnet utiliza técnicas de ataque de fuerza bruta para inundar el servidor víctima con paquetes infectados para consumir ancho de banda y recursos. El atacante envía múltiples solicitudes a estos servicios falsificando la dirección IP de la víctima, engañando a los ser-

vidores para que respondan con grandes respuestas. Microsoft, por ejemplo, en noviembre de 2021 sufrió un DDoS que alcanzó un rendimiento de 3,47 terabits por segundo [Najar and Naik \(2022\)](#). Los ataques DDoS volumétricos son capaces de desactivar la infraestructura de seguridad de la información de la víctima para dificultar o imposibilitar el tiempo objetivo de recuperación.

Otra variante conocida como ataque DDoS de protocolo, el cual se basa en las vulnerabilidades y la complejidad de los protocolos de comunicaciones de Internet, para comprometer la red de destino. Los proveedores de servicio de Internet, por ejemplo, utilizan el Protocolo de puerta de enlace fronteriza (BGP) para notificar a otras redes cómo está configurado su espacio de direcciones. Al enviar una actualización de BGP fraudulenta, un atacante cibernético puede redirigir el tráfico de la red para agotar los recursos de memoria interna en enrutadores y firewalls. En 2018, los ciber atacantes utilizaron el secuestro de BGP junto con una botnet DDoS para redirigir el tráfico destinado a MyEther-Wallet, un servicio que administraba cuentas de criptomonedas Ethereum, a servidores presumiblemente rusos para facilitar el robo de billeteras de criptomonedas [Pillai et al. \(2019\)](#).

Fases, tipología y herramientas para ejecutar ataques de DoS y DDoS

Con el firme propósito de que el lector conozca las herramientas disponibles en la Web que utilizan los ciber delincuentes para perpetuar ataques DoS y DDoS, especialmente las técnicas de inundación de la red a través de diferentes tipos de paquetes TCP, UDP, ICMP, etc., en este apartado se presentan algunas de ellas. La Figura [VIII.2](#) es una ilustración que muestra las fases de un ataque de DoS/DDoS, así como sus tipos y destinos principales (targets).

1. **Bomba de bifurcación**, también llamada bomba fork() o bomba lógica, es un ataque de DoS en el que un proceso se replica continuamente de manera recursiva con el fin de agotar los recursos computacionales disponibles del sistema, ralentizando o colapsando el equipo debido a la insuficiencia de recursos.
2. **Desbordamiento de búfer**, que se desencadena cuando un programa de software no controla debidamente la cantidad de datos que se copian sobre un área de memoria reservada para tal efecto. En otras palabras, el desbordamiento se da cuando la cantidad de datos escritos en el buffer

Figura VIII.2: Fases de un ataque de DoS/DDoS, tipos y objetivos.



excede el espacio de almacenamiento temporal, y por lo tanto, el sistema computacional se colapsa.

3. **Ping de la muerte**, en el cual el delincuente cibernético intenta desestabilizar un servidor víctima al enviar paquetes del Protocolo de mensajes de control de Internet (ICMP) con el máximo tamaño permitido, lo que provoca que el equipo se colapse y deje de funcionar. Cabe señalar que este ataque se perpetuaba hace carios años. Sin embargo, en la actualidad, todos los sistemas operativos ya incluyen parches localizados que lo previenen.
4. **SYN Flooding**, también conocido como inundación TCP SYN, es un tipo de ataque DoS o DDoS que envía cantidades masivas de solicitudes SYN a un servidor para colapsarlo con conexiones abiertas.
5. **Teardrop**, que se produce cuando el ciber atacante inunda la red o el servidor con solicitudes y datos mediante paquetes fragmentados al servidor víctima en donde existe una vulnerabilidad de TCP/IP. En este caso, el servidor no puede volver a ensamblar el paquete, lo que provoca el colapso del equipo.
6. **Smurf**, que logra explotar las vulnerabilidades de los protocolo IP e ICMP. Primero, el malware crea un paquete de red adjunto a una dirección IP falsa, una técnica conocida como spoofing. Dentro del paquete

hay un mensaje de ping ICMP, que solicita a los nodos de la red que reciben el paquete que envíen una respuesta que se envían nuevamente a las direcciones IP de la red, configurando un bucle infinito. Cuando se combina con la transmisión de IP, que envía el paquete malicioso a cada dirección IP de una red, el ataque Smurf puede provocar rápidamente una denegación total del servicio.

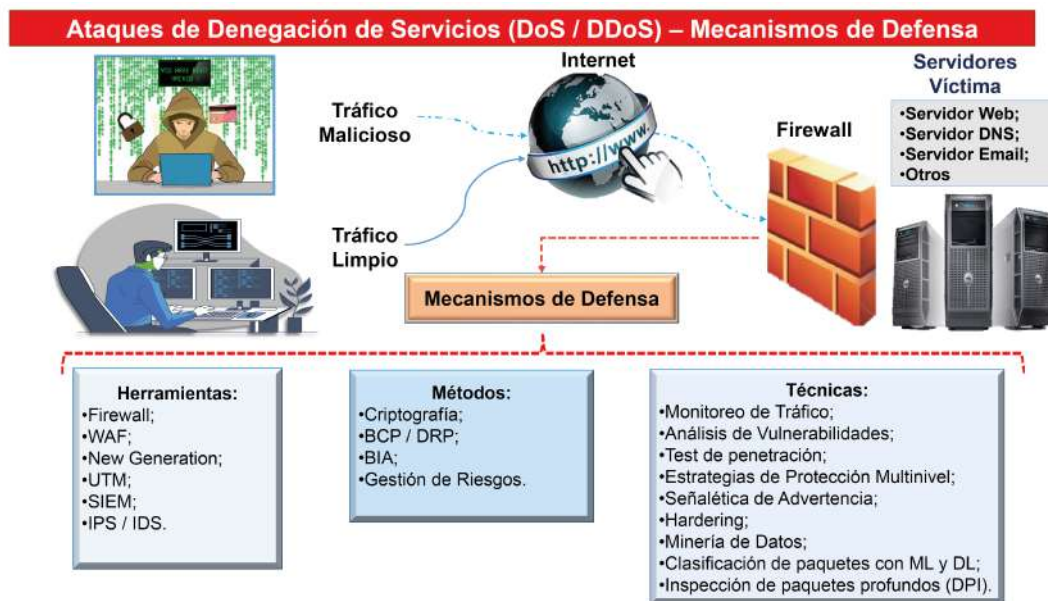
7. **Hping3**: Este ataque consiste en sobrecargar el objetivo con paquetes sobredimensionados o en gran cantidad. Si bien este ataque es muy fácil de ejecutar, no compromete la información ni la privacidad del servidor víctima. No es un ataque de penetración y solo tiene como objetivo evitar el acceso al servidor víctima. El Hping3 puede funcionar además como un ataque de **fuentes aleatorias**, en el cual, un ciber atacante puede enviar múltiples paquetes aleatorios con diferentes direcciones de origen al servidor víctima, lo que lo convierte en un ataque DDoS.

Mecanismos de detección y mitigación de ataques DoS y DDoS.

Los ataques DoS y DDoS son problemas críticos en la seguridad de la red, que representan un peligro para la accesibilidad de los servicios o aplicaciones para sus usuarios legítimos al inundar el ancho de banda o colapsar los recursos computacionales del servidor [Cheema et al. \(2022\)](#). A continuación se presentan algunas recomendaciones para prevenir y protegerse de estos ataques. La Figura [VIII.3](#) presenta una abstracción del funcionamiento de un DDoS/DoS junto con las herramientas, métodos y técnicas utilizadas como mecanismos utilizados por la industria en este tipo de ataques.

- **Análisis de vulnerabilidades**, que haga una revisión completa de todos los dispositivos en la red que permita registrar la información del sistema y delinear las vulnerabilidades existentes. Este nivel de visibilidad permitirá comprender los puntos débiles de la red, fallas, brechas de seguridad, puertos de acceso inseguros y los errores de configuración del sistema, para priorizarlas en función de su criticidad y establecer los mecanismos para mitigarlos.
- **Estrategias de protección multinivel**, que utilicen Sistemas de Prevención de Intrusiones (Intrusion Prevention System, IPS) y gestión de amenazas unificadas (Unified Threat Management, UTM). Un IPS monitorea

Figura VIII.3: Mecanismos de detección y mitigación de un ataque DDoS/DoS.



continuamente una red en busca de actividad maliciosa y toma medidas para evitarla. Un UTM en cambio, es una única solución de seguridad y, por lo general, un único dispositivo de seguridad, que proporciona varias funciones de seguridad en un único punto de la red. Estos sistemas pueden ser combinados con software anti-spam, filtrado de contenido, VPN, firewalls, equilibrio de carga y capas de seguridad para detectar y bloquear ataques antes de inunden la red ³.

- **La micro segmentación perimetral**, que permite reducir la superficie del ataque dividiendo una red en zonas granulares y protege cada zona por separado. El efecto es un perfil de seguridad general más alto, lo que maximiza las capacidades defensivas de la red en su conjunto.
- **Monitoreo de tráfico**, que es el método de estudiar el tráfico entrante y saliente en una red a través de un software especializado que detecta, registra y/o redirige los flujos de tráfico anormales típicamente asociados con un ataque DoS/DDoS, mientras permite que el tráfico normal continúe en la red ⁴.
- **Señales de advertencia**, tales como baja conectividad, aumento repentino de tráfico, ralentización de la red, interrupciones repetidas del servicio, múltiples solicitudes de la misma dirección IP en un corto período de

³<https://www.byos.io/blog/denial-of-service-attack-prevention>

⁴<https://bit.ly/3B3YJzU>

tiempo o cualquier interrupción sostenida del rendimiento. Cabe señalar que los ataques de bajo volumen son más difíciles de detectar debido a su similitud con incidentes de seguridad menos graves.

- **Plan de Recuperación de Desastres**, que cubra la comunicación, la mitigación y la recuperación.
- **Instale software de prevención y mitigación**, eficaz para detener los ataques de DoS y DDoS.
- **Plan de entrenamiento y concienciación en Ciberseguridad**, que incremente los niveles de Ciberseguridad de las personas en su trabajo y en su vida personal.

Lecciones aprendidas. Los ataques de Denegación de servicio (DoS) y Distribuido (DDoS) tienen como objetivo colapsar un sitio web, servicio en línea, aplicación móvil, o servidor de red que dependan de la disponibilidad de Internet, y por tanto queden inaccesibles para los usuarios legítimos. El ciber atacante utiliza una botnet que es un puesto de control de mando para incurrir en actividades maliciosas en contra uno o más servidores víctima. En un ataque de DDoS, el atacante envía un gran volumen de tráfico falso desde cada dispositivo zombi o bot para sobrecargar rápidamente el servidor víctima. A medida que el servidor procura atender el flujo de solicitudes, los ciclos de su procesador, interfaces de red y memoria interna utilizada para su procesamiento se consumen, lo que hace que las conexiones del tráfico normal se ralenticen hasta el punto de colapsar el servicio. Este capítulo también explica las fases, objetivos, herramientas, mecanismos y técnicas disponibles para perpetuar, detectar y mitigar estos tipos de ataque.

Sitios de Interés

1. **OSI** Oficina de Seguridad del Internauta. ¿Qué son los ataques DoS y DDoS?. URL: <https://www.osi.es/es/actualidad/blog/2018/08/21/que-son-los-ataques-dos-y-ddos>
2. **ENISA**, Distributed Denial of Service, ENISA Threat Landscape. April, 2020. URL: <https://bit.ly/42tBWcI>

3. **COMPUTERHOY**, Los siete mayores ataques DDoS de la historia de Internet. URL: <https://computerhoy.com/listas/tecnologia/mayores-ataques-ddos-historia-internet-555187>



CAPÍTULO IX

Análisis de tráfico encriptado

Introducción

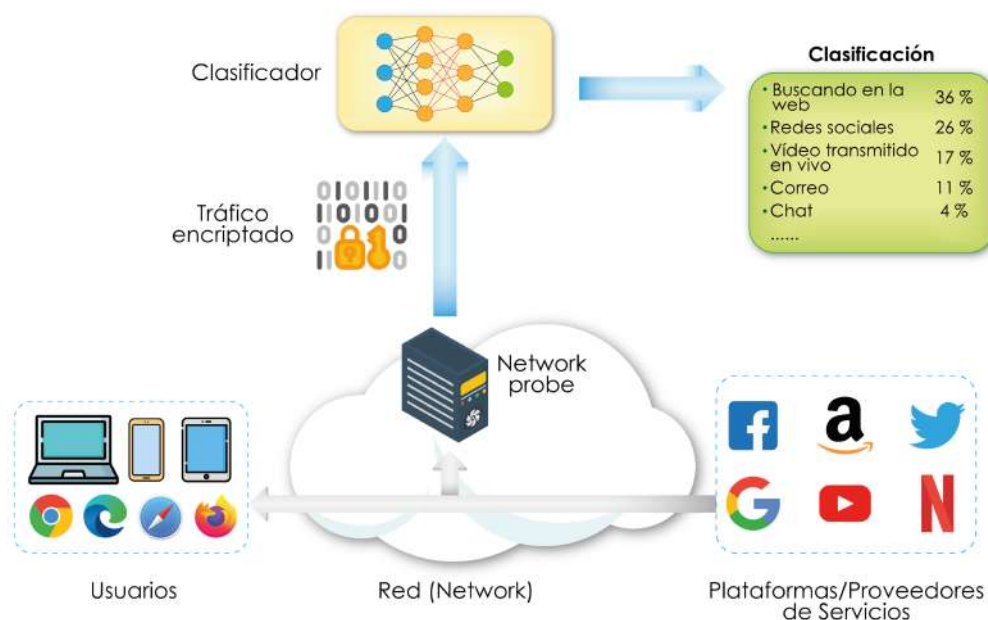
Los protocolos de cifrado, como Transport Layer Security (TLS) [Dierks and Rescorla \(2008\)](#) brindan garantías de seguridad para la confidencialidad e integridad de los datos, lo que reduce como efecto secundario la capacidad de los administradores de red para monitorear su infraestructura en busca de tráfico malicioso y exfiltración de datos confidenciales. Los atacantes han pasado al uso de cifrado y métodos criptográficos en sus ataques, desde ransomware hasta HTTPS para proteger las comunicaciones con dispositivos infectados y evitar la detección. Otros desafíos para los usuarios legítimos incluyen errores de implementación o errores de configuración al implementar protocolos de tráfico cifrado, el costo de rendimiento del cifrado de tráfico y el impacto que tendrán las nuevas tecnologías en el tráfico cifrado. Además, estos desafíos aumentan debido al reciente lanzamiento del estándar TLS 1.3 en 2018 que cifra la mayor parte de la información disponible en los protocolos TLS más antiguos [Rescorla \(2018\)](#). En consecuencia, el principal objetivo de los profesionales de la seguridad es encontrar un equilibrio entre la seguridad de extremo a extremo, proteger la privacidad de los usuarios finales y, al mismo tiempo, recopilar información valiosa del tráfico para detectar posibles amenazas y asignar y proteger mejor los recursos.

La clasificación del tráfico se refiere a clasificar el tráfico de la red en clases adecuadas, lo cual es esencial para varias aplicaciones, como la detección de intrusos/malware, el control de la calidad del servicio (QoS), la fijación de precios y la planificación del uso de recursos. Con el tiempo, las técnicas de clasificación del tráfico han evolucionado. El primer y más sencillo enfoque emplea números de puerto. Sin embargo, su precisión se ha deteriorado porque las nuevas aplicaciones utilizan números de puerto conocidos para disfrazar su tráfico o evadir los números de puerto de registro estándar [Rezaei and Liu \(2019\)](#). A pesar de su inexactitud, el número de puerto todavía se emplea ampliamente en la práctica, solo o junto con otras funciones. La inspección profunda de paquetes (DPI) es la próxima generación de clasificación de tráfico, que depende de la carga útil y se enfoca en descubrir patrones o palabras clave en los paquetes de datos. Sin embargo, esta técnica solo se puede aplicar al tráfico no cifrado y tiene un alto costo operativo computacional. Como consecuencia, surgieron nuevos métodos que se basan en estadísticas de flujo. Estos métodos dependen de características estadísticas o de series de tiempo que les permiten manejar tráfico tanto encriptado como no encriptado. Suelen utilizar

técnicas tradicionales de ML como RF y K-NN. Debido a este hecho, su rendimiento depende principalmente de características diseñadas por humanos, lo que limita su generalización. En consecuencia, el uso de métodos de clasificación de tráfico que emplean técnicas de DL puede eliminar las desventajas de la construcción manual de características, logrando un alto rendimiento en la clasificación de tráfico dinámica y desafiante. La Figura IX.1 muestra un modelo de clasificación de tráfico encriptado basado en DL. Este capítulo incluye fundamentos sobre website fingerprinting e identificación de protocolos y/o aplicación en el tráfico de red.

¡Bienvenidos!

Figura IX.1: Ejemplo de un modelo de clasificación de tráfico encriptado basado en DL.

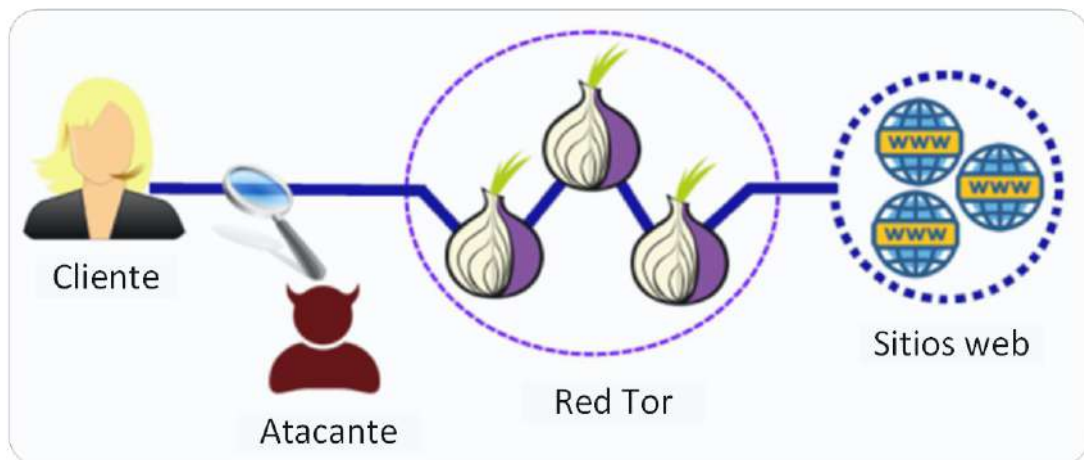


Website fingerprinting

La identificación del tráfico de red de los sitios web visitados a través de tecnologías de mejora de la privacidad como Tor también se conoce como **Website Fingerprinting (WF)**. La Figura IX.2 muestra un escenario de ataque, donde el cliente navega por la Web a través del sistema de anonimato Tor y el atacante intercepta el tráfico entre el cliente y la red Tor. Suponemos que el adversario conoce la identidad del cliente y solo tiene como objetivo identificar el sitio

web. Tenga en cuenta que el adversario puede obtener trivialmente la dirección IP del cliente si tiene acceso a la conexión TLS entre el usuario y el nodo de entrada. Más allá del nodo de entrada, Tor eliminó una capa de cifrado y la IP del cliente ya no está presente en los encabezados de los paquetes de red. En Abe and Goto (2016), los autores estudiaron la eficiencia de los clasificadores basados en DL en WF por primera vez. En su experimento, se supervisó el tráfico de red de 100 sitios web que pasaban por Tor y se extrajo la característica estadística de cada flujo. Demostraron que SDAE es útil para detectar sitios web utilizando solo la dirección de los paquetes Tor (entrantes o salientes) y los tiempos entre llegadas con una tasa de éxito del 86 %. Rimmer et al. (2017) demostraron que DL es una herramienta útil para automatizar el proceso de ingeniería de características, y su modelo SDAE logró una tasa de éxito del 95,3 % solo usando la dirección de los paquetes Tor. En Sirinam et al. (2018), se construyó un clasificador de CNN más profundo para superar los estudios anteriores, mejorando la tasa de éxito al 98 %.

Figura IX.2: Modelo de amenazas de WF.



Identificación de Protocolo/Aplicación

La **clasificación del protocolo de aplicación** está estrechamente relacionada con la **clasificación del tipo de aplicación**. El primero identifica protocolos como HTTP o SSH, mientras que el segundo reconoce aplicaciones individuales (como Skype y Google Talk). Se introdujo un clasificador de tráfico móvil basado en DL en Aceto et al. (2018), lo que demuestra que los NN profundos pueden manejar el tráfico cifrado y representar sus patrones complejos. Los

autores compararon varios métodos de DL como MLP, CNN y LSTM con bosques aleatorios (RF) para resaltar la brecha de rendimiento. Los resultados experimentales muestran que las soluciones basadas en DL logran una precisión superior a la de RF en la clasificación del tráfico de IOS, Android y Facebook. Sin embargo, la configuración del experimento no es completamente justa e igual debido a que las características de entrada utilizadas para los métodos RF y DL son diferentes. Por lo tanto, los resultados no deben considerarse como una comparación exhaustiva de los métodos de ML.

Se propone un modelo de red neuronal convolucional (CNN) en [Shapira and Shavitt \(2019\)](#), cuya entrada consiste en cada flujo de Internet representado como una imagen. Los autores aplicaron una arquitectura de estilo LeNet-5 que consta de siete capas (2 convolucionales, 2 de agrupación, 1 plana, 1 totalmente conectada y 1 softmax) para clasificar el tráfico de Internet en cinco categorías (VoIP, video, transferencia de archivos, chat y browsing). Para cada flujo, construyeron una imagen a partir de los tamaños de los paquetes y los tiempos de llegada de los paquetes. Los conjuntos de datos ISCX VPN-nonVPN [Draper-Gil et al. \(2016\)](#) e ISCX Tor-nonTor [Lashkari et al. \(2017\)](#) se utilizaron para evaluar el modelo. Los autores demostraron que su modelo puede clasificar el tráfico en una categoría con una precisión superior al 96 %, excepto la navegación. Además, el método propuesto es capaz de clasificar el tráfico que pasa a través de VPN con una precisión superior al 99,2 % y también obtiene buenos resultados para el tráfico que atraviesa Tor (más del 89 % excepto la transferencia de archivos). Sin embargo, requiere el registro del tamaño y la marca de tiempo de los paquetes de cada flujo, lo que provoca un procesamiento y una sobrecarga adicional al tiempo de clasificación. Por lo tanto, una dirección de investigación interesante sería buscar métodos similares que produzcan una clasificación más rápida.

Para reducir la cantidad de parámetros y acortar el tiempo de ejecución de una arquitectura DL para realizar la clasificación del tráfico en tiempo real, Cheng et al. [Cheng et al. \(2020\)](#) desarrollaron un modelo DL basado en la atención de múltiples cabezas (que es el cerebro de the Transformer) [Song et al. \(2019\)](#); [Vaswani et al. \(2017\)](#) y 1D-CNN. El modelo extrae automáticamente características de nivel de flujo y de paquete de alto orden. Las interacciones de alto orden a nivel global se exploraron apilando los bloques de atención de múltiples cabezas, mientras que 1D-CNN se aplicó a las extracciones de características para un solo paquete. Los autores entrenan su modelo en dos conjuntos de datos públicos llamados ISCX VPN-nonVPN [Draper-Gil et al. \(2016\)](#)

y HTTPS dataset [Wazen et al. \(2016\)](#). Los resultados experimentales demostraron que los parámetros del modelo propuesto se reducen al 1,8 % y 2,7 % del número utilizado para 1D-CNN y CNN con LSTM, respectivamente. Asimismo, el tiempo de entrenamiento del modelo es el 49,7 % y el 6,8 % del tiempo que necesita 1D-CNN y CNN con LSTM. Aunque el modelo propuesto alcanzó una precisión y recuperación de alrededor del 100 % en ambos conjuntos de datos, superando a 1D-CNN y CNN con LSTM, el conjunto de datos empleado solo incluye tráfico HTTPS y VPN, sin involucrar a otros protocolos. Por lo tanto, se deben considerar más protocolos encriptados, como QUIC, para crear un modelo que pueda funcionar de manera eficiente en un entorno del mundo real.

En [Sun et al. \(2020\)](#), se propuso un método de clasificación de tráfico de cifrado basado en Graph Convolutional Network (GCN) y AE. Los autores utilizaron una arquitectura GCN de dos capas para la extracción de características de flujo y la clasificación del tráfico encriptado. Además, se empleó un codificador automático para aprender la representación de los propios datos de flujo e integrarlos en la representación aprendida por GCN para formar una representación completa de características. Los resultados experimentales demostraron que su método logró una precisión del 85,82 % y del 94,33 % en conjuntos de datos ISCX VPNnonVPN [Draper-Gil et al. \(2016\)](#) y USTC-TFC2016 [Wang et al. \(2017\)](#) respectivamente, superando a los métodos tradicionales como RF. Sin embargo, debe analizarse el problema de la clasificación del tráfico cifrado con tráfico de tipos de aplicaciones desconocidos.

Para evitar la necesidad de un extenso conjunto de datos etiquetados, Rezaei et al. [Rezaei and Liu \(2020\)](#) introdujeron una arquitectura de modelo de aprendizaje multitarea, que utilizaba una 1D-CNN. Emplearon un gran conjunto de datos sin etiquetar y un pequeño conjunto de datos etiquetados para entrenar un modelo que predice tres tareas: aplicación, ancho de banda y duración de los flujos. En particular, los experimentos se realizaron en dos conjuntos de datos públicos: QUIC [Rezaei and Liu \(2018\)](#) e ISCX VPN-nonVPN [Draper-Gil et al. \(2016\)](#). Los resultados revelaron que el modelo propuesto supera significativamente los enfoques de aprendizaje de transferencia y de tarea única. Sin embargo, este estudio solo consideró unas pocas clases y no se muestra que sea escalable para una gran cantidad de clases. Para abordar este problema, Wang et al. [Wang et al. \(2021\)](#) propusieron un método de clasificación de tráfico cifrado de aprendizaje semisupervisado basado en GAN llamado ByteSGAN, que se incorporó en un SDN Edge Gateway para mejorar

aún más la utilización de los recursos de la red. En los experimentos se utilizó el conjunto de datos de tráfico ISCX VPN-nonVPN [Draper-Gil et al. (2016)]. Los autores afirman que cuando el número de muestras etiquetadas es 1000, la precisión de clasificación de ByteSGAN es del 99,18 %, superando a la CNN que logró una precisión del 88,25 %. Sin embargo, este rendimiento se logró utilizando solo un subconjunto del conjunto de datos mencionado anteriormente (es decir, 7 del total de 15 clases/aplicaciones) y empeora cuando se emplean más clases (cae al 92,15 % con 15 clases), lo que pone en duda la generalización del método propuesto en escenarios del mundo real. En la Tabla IX.1 se pueden visualizar las ventajas y desventajas de los estudios seleccionados en esta sección.

Tabla IX.1: Ventajas y limitaciones de los estudios seleccionados centrados en métodos de seguridad basados en DL para análisis de tráfico cifrado.

ESTUDIO	VENTAJAS Y LIMITACIONES
1. Abe and Goto (2016)	Estudio pionero en usar DL & WF.
2. Rimmer et al. (2017)	Experimentos basados en conjuntos de datos grandes.
3. Sirinam et al. (2018)	Tasa de precisión del 98 %
4. Aceto et al. (2018)	Las características utilizadas para los métodos RF y DL son diferentes.
5. Shapira and Shavitt (2019)	Procesamiento y gastos generales adicionales al tiempo de clasificación.
6. Cheng et al. (2020)	El conjunto de datos solo incluye tráfico HTTPS y VPN.
7. Sun et al. (2020)	Incluir tipos de aplicaciones desconocidos en la fase experimental.
8. Rezaei and Liu (2020)	Número limitado de clases en los experimentos.
9. Wang et al. (2021)	Con 15 clases, la precisión decrece.

Lecciones aprendidas. La introducción del cifrado del tráfico de red ha mejorado significativamente la seguridad de las comunicaciones y la privacidad del usuario. Al utilizar tecnologías, como Transport Layer Security (TLS), la mayoría de los usuarios de Internet asumen que terceros no pueden acceder a sus comunicaciones y las empresas pueden estar seguras de que sus transacciones están a salvo de interferencias y escuchas. Sin embargo, el cifrado generalizado del tráfico de red ha reducido la capacidad de los administradores de red para monitorear sus infraestructuras. Paralizando su éxito en el manejo del tráfico malicioso y la exfiltración de datos confidenciales, obligándolos a recurrir al descifrado del tráfico a través de proxies. La investigación en ML e IA nos ha proporcionado herramientas útiles para combatir los ciberataques. Al mismo tiempo, estas nuevas capacidades se pueden utilizar de forma indebida para reducir la privacidad del usuario, a veces incluso con el cifrado empleado.

Sitios de Interés

1. **Cisco, Threats in encrypted traffic.** Amenazas en el tráfico encriptado.
URL: <https://bit.ly/42JvJtq>.
2. **GitHub, Encrypted-traffic-analysis.** Amenazas en el tráfico cifrado.
URL: <https://github.com/topics/encrypted-traffic-analysis>.



CAPÍTULO X

Ataques Ciber-Físicos

Introducción

Los sistemas ciber-físicos o CPS (siglas del inglés cyber-physical system) comprenden una nueva generación de sistemas complejos cuyo funcionamiento normal depende principalmente de las comunicaciones robustas entre sus componentes cibernéticos y físicos. Se espera que el mercado de CPS crezca un 9,7 % anual, alcanzando los USD 9.563 millones en 2025 [Research \(2020\)](#). Estos sistemas han demostrado ser fundamentales para varios sectores y se han implementado ampliamente en varios entornos industriales, como redes eléctricas, refinerías de petróleo, plantas de tratamiento y distribución de agua y sistemas de transporte público, por nombrar algunos. Dado que el despliegue de las comunicaciones móviles Internet de las cosas (IoT) y 5G/6G experimenta un aumento exponencial, el aumento en el uso de CPS para una amplia variedad de tareas no sorprende, lo que da como resultado que muchos sistemas y dispositivos se comuniquen y funcionen de forma autónoma a través de redes. Simultáneamente, los CPS, IoT y 5G/6G también aumentan la probabilidad de incidentes y vulnerabilidades de ciberseguridad [Stellios et al. \(2018\)](#). Desde la perspectiva de los ciberdelincuentes, atacar a los CPS es una oportunidad única para provocar el máximo daño con el mínimo esfuerzo [Anton et al. \(2017\)](#). Como resultado, se han aplicado muchas técnicas elaboradas para explotar sigilosamente los CPS de sectores esenciales, incluidas las ciudades inteligentes [Khatoun and Zeadally \(2017\)](#), las redes de energía [Case \(2016\)](#) y un número creciente de ataques a la gestión de la cadena de suministro.

Dado que los servicios proporcionados por tales sistemas son esenciales para el bienestar de la comunidad, los CPS pueden clasificarse como Infraestructuras Críticas [Stellios et al. \(2018\)](#). Por tanto, deben ser robustos y flexibles frente a los ciberataques. Cualquier ataque que pudiera comprometer o interrumpir los servicios prestados tendría graves consecuencias para la seguridad y el orden público, la economía y el medio ambiente. De ahí que la capacidad de detectar ciberataques sofisticados sobre la naturaleza cada vez más heterogénea de los CPS, amplificada por la llegada de IoT y 5G/6G, se haya convertido en una tarea crítica. Lamentablemente, desarrollar un modelo de seguridad bien definido del complejo proceso físico no es una tarea trivial [Macas and Wu \(2019\)](#). Exige un conocimiento profundo del sistema y su implementación, lo que lleva mucho tiempo y no puede escalar adecuadamente a sistemas complejos y de gran escala. Una estrategia alternativa que recientemente ha sido el foco de atención utiliza técnicas de aprendizaje profundo para construir mé-

todos más inteligentes y poderosos que aprovechan los grandes datos para identificar intrusiones y anomalías. Este capítulo contiene conceptos sobre sistemas ciber-físicos (CPS), modelos y aspectos de los CPS y seguridad en los CPS.

¡Bienvenidos!

Sistemas Ciber-Físicos o CPS

En palabras simples, los CPS son sistemas utilizados para monitorear y controlar el mundo físico [Macas and Chunming \(2019\)](#); [Stellios et al. \(2018\)](#). Se perciben como la nueva generación de sistemas de control integrados, de modo que los CPS son sistemas integrados en red. Además, los sistemas en los que se integran redes de sensores y actuadores también se consideran CPS. Debido a la dependencia de los sistemas de Tecnología de la Información (TI), CPS podría definirse como sistemas de TI que están integrados en la aplicación del mundo físico [Anton et al. \(2017\)](#). Esta integración es el resultado de los avances en las tecnologías de la información y la comunicación (TIC) para mejorar las interacciones con los procesos físicos. Estas definiciones destacan la fuerte presencia de las interacciones entre los mundos cibernético y físico [Anton et al. \(2017\)](#).

Los CPS han demostrado ser fundamentales para varios sectores y han sido ampliamente adoptados en muchos entornos industriales, como plantas de tratamiento y distribución de agua, redes eléctricas, sistemas de transporte público, refinerías de petróleo y muchos más [Macas and Wu \(2019\)](#). Los CPS pueden recibir diferentes nombres, según la aplicación que los utilice. Por ejemplo, un CPS muy importante y representativo es el sistema de control de supervisión y adquisición de datos (SCADA), que se utiliza en las infraestructuras críticas (CI), como la red inteligente y los sistemas de control industrial (SCI). Además, una red de pequeños sistemas de control está integrada en los automóviles modernos para mejorar la eficiencia del combustible, la seguridad y la comodidad. Aquí presentamos brevemente tres aplicaciones representativas de CPS que cubriremos a lo largo de este capítulo.

Sistemas de control industrial (SCI)

SCI se refiere a los sistemas de control utilizados para mejorar el control, el monitoreo y la producción en diferentes industrias, como plantas nucleares, sistemas de agua y alcantarillado y sistemas de riego [Goh et al. \(2017b\)](#);

Inoue et al. (2017); Kravchik and Shabtai (2021). A veces, los SCI se denomina SCADA o sistemas de control distribuido. En los SCI, los controladores con diferentes capacidades colaboran para lograr numerosos objetivos esperados. El controlador lógico programable (PLC) es un controlador popular, un microprocesador diseñado para operar continuamente en entornos hostiles Macas and Wu (2019); Xie et al. (2020). Este dispositivo de campo está conectado al mundo físico a través de sensores y actuadores. Por lo general, está equipado con capacidad de comunicación inalámbrica y por cable configurada según los entornos circundantes. También se puede conectar a sistemas de PC en un centro de control que monitorea y controla las operaciones.

Red Inteligente (RI)

La red inteligente se concibe como la próxima generación de la red eléctrica que se ha utilizado durante décadas para la generación, transmisión y distribución de electricidad He et al. (2017); Niu et al. (2019). La red inteligente proporciona varios beneficios y funcionalidades avanzadas. A nivel nacional, proporciona control de emisiones mejorado, equilibrio de carga global, generación inteligente y ahorro de energía. Mientras que a nivel local, permite a los consumidores domésticos un mejor control sobre su uso de energía, lo que sería beneficioso económica y ambientalmente. La red inteligente consta de dos componentes principales: 1) aplicación de energía y 2) infraestructura de apoyo Wang et al. (2019a,b). La aplicación de energía es donde se proporcionan las funciones centrales de la red inteligente, es decir, generación, transmisión y distribución de electricidad. Al mismo tiempo, la infraestructura de soporte es el componente inteligente que se ocupa principalmente de controlar y monitorear las operaciones centrales de la red inteligente utilizando un conjunto de software, hardware y redes de comunicación.

Sistemas de Transporte Inteligentes (STIs)

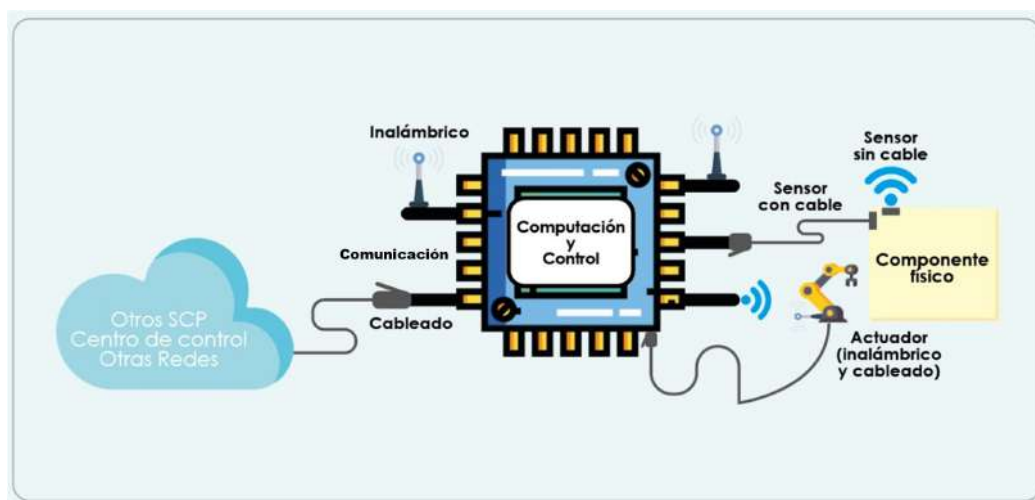
Los STIs están diseñados para mejorar la seguridad y la eficiencia del transporte. Se basan en las TIC para gestionar de manera eficiente los sistemas de transporte y garantizar la seguridad de los pasajeros y los vehículos. Los STI proporcionan servicios tales como gestión de tráfico, seguimiento de transporte y detección de incidentes. Vehicular Ad hoc NETWORK (VANET), la red de drones y la red ferroviaria están dentro del ámbito de STI, en el que los nodos móviles inteligentes, como vehículos y drones, están equipados con tec-

nologías de comunicaciones heterogéneas, incluida el celular (LTE/LTE-A) y WiFi (como 802.11p) para comunicarse con sus nodos e infraestructuras vecinas [Hahn et al. \(2021\)](#); [Hanselmann et al. \(2020\)](#).

Modelos y aspectos de los CPS

Generalmente, un CPS consta principalmente de tres componentes (mire la Figura [X.1](#)): 1) comunicación; 2) cómputo y control; y 3) seguimiento/monitoreo y manipulación. La *comunicación* podría ser inalámbrica o por cable, y podría conectar CPS con sistemas de nivel superior, como centros de control, o con componentes de nivel inferior en el mundo físico. La parte de *cómputo y control* es donde se integra la inteligencia, se envían los comandos de control y se reciben las medidas detectadas. Los componentes de *monitoreo y manipulación* conectan CPS con el mundo físico a través de sensores para monitorear componentes físicos y actuadores para manipularlos.

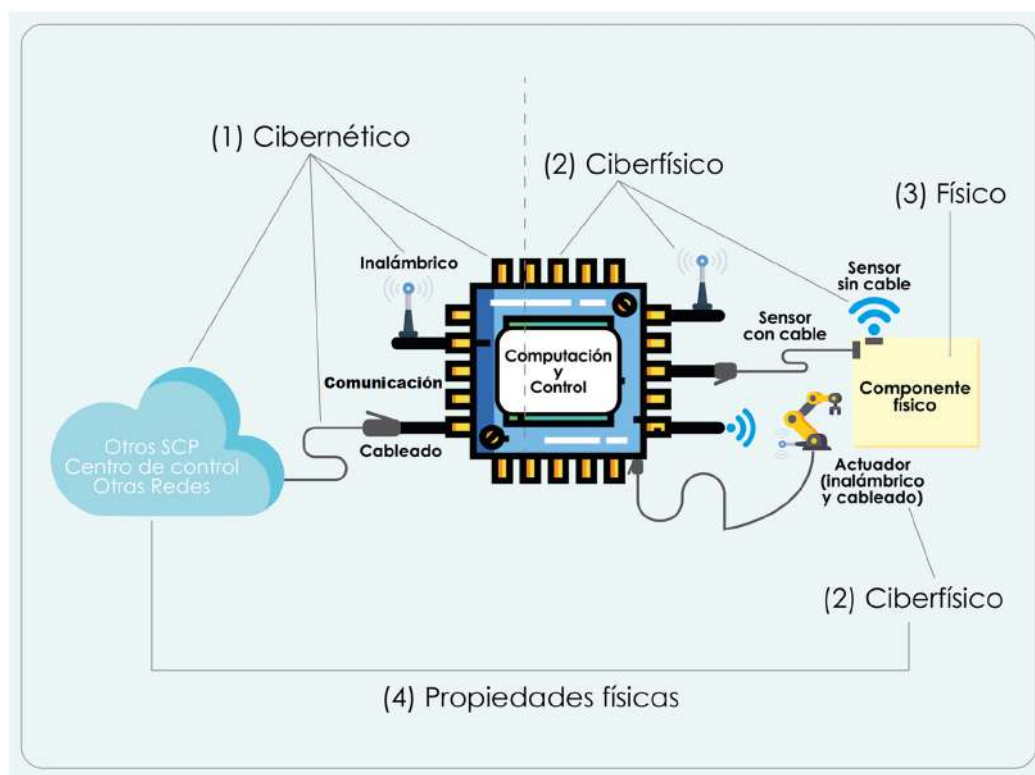
Figura X.1: Abstracción de alto nivel de cualquier CPS.



Un componente de los CPS puede tener la capacidad de comunicarse con los centros de control u otros componentes de los CPS. Este mismo componente también podría contener un sensor, un actuador o ambos para conectarse al mundo físico. Cada una de estas capacidades tiene diferentes implicaciones de seguridad que pueden resultar de las interacciones de las partes del componente y sus capacidades. Por ejemplo, no se espera que las funciones informáticas y de comunicación de un componente de CPS afecten el mundo físico y, sin embargo, podrían explotarse para causar comportamientos inesperados con consecuencias físicas. Del mismo modo, las propiedades físicas de

este componente, además de las propiedades físicas del objeto de interés en el mundo físico que controla y monitorea el CPS, también pueden provocar ataques inesperados que podrían tener consecuencias no físicas, como el envío de información engañosa a la red. Esta heterogeneidad de CPS, entre componentes o dentro de un componente mismo, da como resultado una falta de comprensión de los nuevos tipos de amenazas de seguridad que explotarían dicha heterogeneidad. Surge la necesidad de distinguir claramente entre tales aspectos para el análisis de seguridad. Así, proponemos ver cualquier CPS desde tres aspectos (mire Figura X.2): 1) cibernético; 2) ciberfísico; y 3) físico.

Figura X.2: Aspectos de los CPS.



En particular, (4) el aspecto físico incluye componentes que interactúan directamente con el mundo físico, como sensores y actuadores. Sus propiedades pueden tener problemas relacionados con la seguridad. Los aspectos cibernéticos y ciberfísicos incluyen cualquier cosa que no interactúe directamente con el mundo físico, por ejemplo, cómputos, procesos de comunicación y actividades de monitoreo. Los dos aspectos comparten algunas características, pero la diferencia clave radica en cómo interactúan con los componentes físicos. En nuestro modelo CPS, los componentes cibernéticos no interactúan directamente con los componentes físicos, mientras que los componentes ciberfísicos sí lo hacen. Tal diferencia aparentemente sutil ayuda en el análisis de seguridad de

CPS. En otras palabras, el aspecto cibernético es donde los mundos cibernético y físico pueden conectarse.

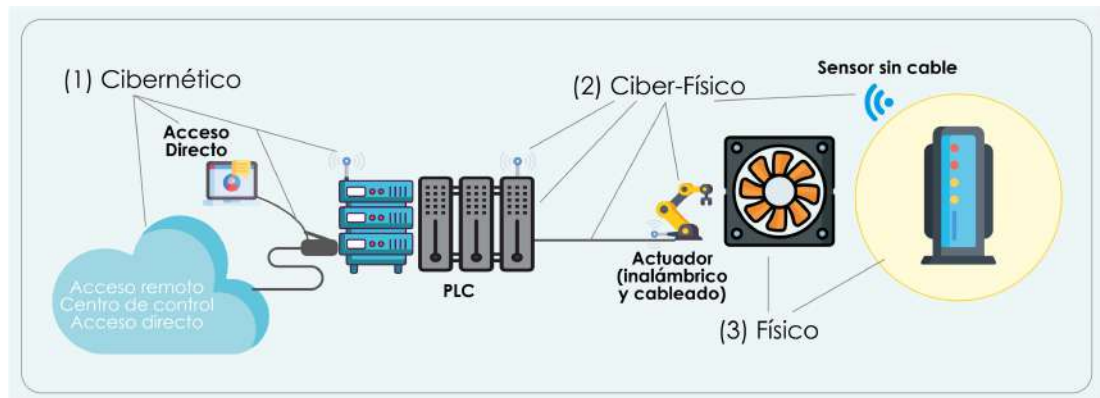
A continuación, presentamos cómo nuestro modelo abstracto puede capturar los aspectos CPS en las aplicaciones representativas.

1. SCI: Basados en los aspectos de un CPS en un escenario de un Controlador Lógico Programable más conocido por sus siglas en inglés PLC (Programmable Logic Controller), donde se utiliza para controlar la temperatura en una planta química. En el escenario antes mencionado, el objetivo es mantener la temperatura dentro de un cierto rango. Si la temperatura excede un umbral específico, se notifica al PLC a través de un sensor inalámbrico conectado al tanque, que a su vez notifica al centro de control del cambio de temperatura no deseado. Alternativamente, en configuraciones de circuito cerrado, el PLC podría encender el sistema de enfriamiento para reducir la temperatura de ese tanque dentro del rango deseado.

Como se puede ver en la Figura [X.3](#), los aspectos cibernéticos (1) son las interacciones cibernéticas con el PLC de modo que no hay interacción directa con los componentes físicos, como los ventiladores de refrigeración o el tanque. Esto involucra computadoras portátiles que pueden conectarse directamente a los PLC, comunicaciones con entornos de nivel superior, como el centro de control y otras entidades remotas, y la interfaz inalámbrica del PLC que podría basarse en frecuencias de largo o corto alcance. Además, los aspectos ciberfísicos (2) son aquellos que conectan los aspectos cibernéticos y físicos. El PLC, el actuador y el sensor son todos aspectos ciberfísicos debido a sus interacciones directas con el mundo físico. Las capacidades inalámbricas del actuador y el sensor también se consideran ciberfísicas. Finalmente, los aspectos físicos (3) son los objetos físicos que necesitan monitoreo y control, es decir, los ventiladores de enfriamiento y la temperatura del tanque.

2. Red Inteligente: Aquí nos basaremos en un escenario típico en las redes inteligentes, donde se adjunta un medidor inteligente a cada casa para proporcionar a las empresas de servicios públicos datos de consumo de electricidad más precisos y a los clientes una forma conveniente de rastrear su información de uso. Un medidor inteligente interactúa con los electrodomésticos de una casa y los sistemas de administración de energía del hogar, por un lado, y con los colectores de datos, por el otro.

Figura X.3: Aspectos de los CPS en los SCI.

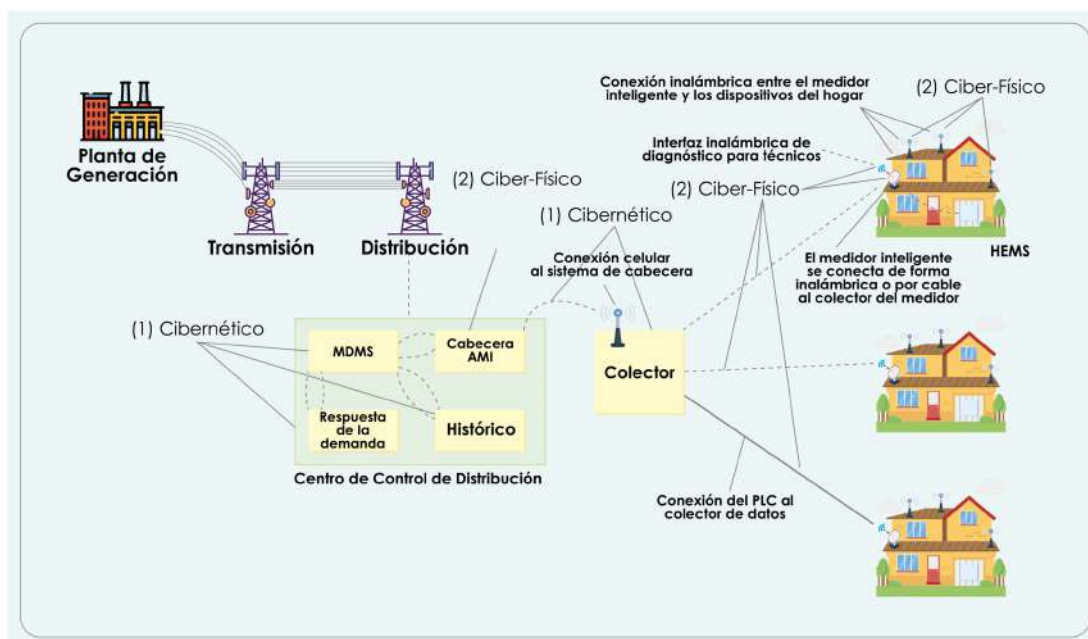


Las comunicaciones inalámbricas son los medios más comunes para comunicarse con los recolectores, aunque también están disponibles las comunicaciones por cable, como las comunicaciones por línea eléctrica. Un medidor está equipado con un puerto de diagnóstico que se basa en una interfaz inalámbrica de corto alcance para facilitar el acceso de lectores de medidores digitales y herramientas de diagnóstico. El medidor inteligente envía las medidas a un colector que agrega todos los datos de los medidores en un vecindario designado. El recolector envía los datos agregados a un centro de control de distribución administrado por la empresa de servicios públicos. En particular, los datos se envían al servidor de cabecera de la Infraestructura de Medición Avanzada o AMI (siglas del inglés advanced metering infrastructure) que almacena los datos de los medidores y los comparte con el sistema de administración de datos de medidores que administra los datos con otros sistemas, como los sistemas de respuesta a la demanda, historiadores y sistemas de facturación. La cabecera puede conectar/desconectar servicios enviando comandos de forma remota a los contadores. Esta característica es un arma de doble filo, ya que es una forma muy eficiente de controlar los servicios, pero podría aprovecharse para lanzar apagones a gran escala mediante el control remoto de una gran cantidad de medidores inteligentes.

La Figura X.4 destaca los aspectos de un CPS en los componentes involucrados que tienen algunas interacciones con los medidores inteligentes. Los aspectos cibernéticos (1) aparecen en el centro de control donde se almacenan, comparten y analizan los datos de los medidores inteligentes y, en base a eso, se pueden tomar algunas decisiones basadas en el aná-

lisis. El centro de control también puede tener un aspecto ciberfísico (2) cuando la cabecera AMI envía comandos de conexión/desconexión a los medidores inteligentes. Además, el aspecto físico cibernético (2) también es evidente en el propio medidor inteligente debido a su capacidad para realizar operaciones cibernéticas, como enviar mediciones a la empresa de servicios públicos, y operaciones físicas, como conectar/desconectar servicios de electricidad. Otros dispositivos de campo en las plantas de generación, automatización de transmisión y distribución tienen una alta presencia del aspecto ciberfísico debido a sus estrechas interacciones con los aspectos físicos de las redes inteligentes. Los electrodomésticos que están conectados con medidores inteligentes se consideran ciberfísicos debido a su interacción directa con los medidores inteligentes. Una empresa de servicios públicos puede usar medidores inteligentes para controlar la cantidad de energía consumida por los electrodomésticos cuando sea necesario, lo cual es una acción ciberfísica (2).

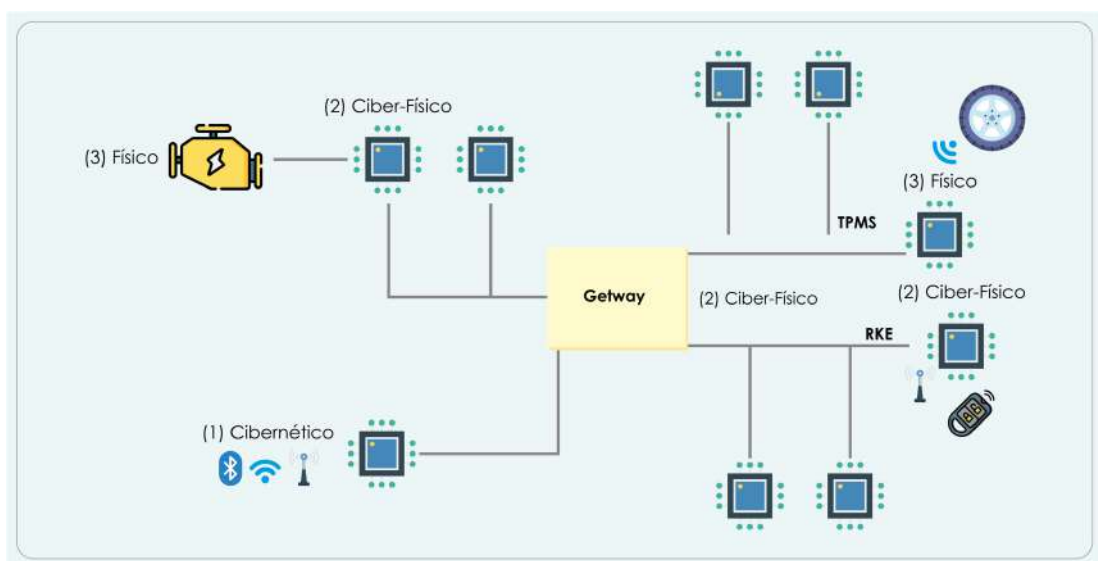
Figura X.4: Aspectos de los CPS en redes inteligentes.



3. Transporte inteligente: Basado en la arquitectura típica de una red en el coche y dependiendo de la naturaleza de las tareas que se esperan de cada unidad de control electrónico o ECU (siglas del inglés Electronic Control Unit), se adjunta una ECU a la subred adecuada. Las ECU de diferentes subredes pueden intercomunicarse a través de puertas de en-

lace. En este libro nos enfocamos principalmente en el bus de la red de área del controlador o CAN (siglas del inglés controller area network) por dos razones: 1) la mayoría de los problemas de seguridad resultan de las redes basadas en CAN y 2) se requiere que se implemente en todos los automóviles en los EE.UU. desde 2008, por lo que es en casi todos los coches que nos rodean. Como se puede ver en la Figura X.5 las ECU que no interactúan con los componentes físicos de los automóviles como cibernéticos (1). Ejemplos de los cuales incluyen la unidad de control telemático o TCU (siglas del inglés Telematics Control Unit) y el reproductor multimedia. La TCU tiene más que una interfaz inalámbrica que permite capacidades avanzadas como actualizaciones remotas de software por parte de los fabricantes de automóviles, emparejamiento de teléfonos, uso de manos libres de teléfonos. Las anotaciones ciberfísicas (2) son para ECU que pueden interactuar legítimamente con componentes físicos y manipularlos, como la asistencia de estacionamiento y los sistemas de entrada remota sin llave o RKE (siglas del inglés Remote Keyless Entry). El RKE, por ejemplo, recibe señales para hacer un impacto físico en el automóvil al bloquear/desbloquear las puertas. Finalmente, los componentes físicos como el motor o los neumáticos son físicos (3).

Figura X.5: Aspectos de los CPS en transporte inteligente.



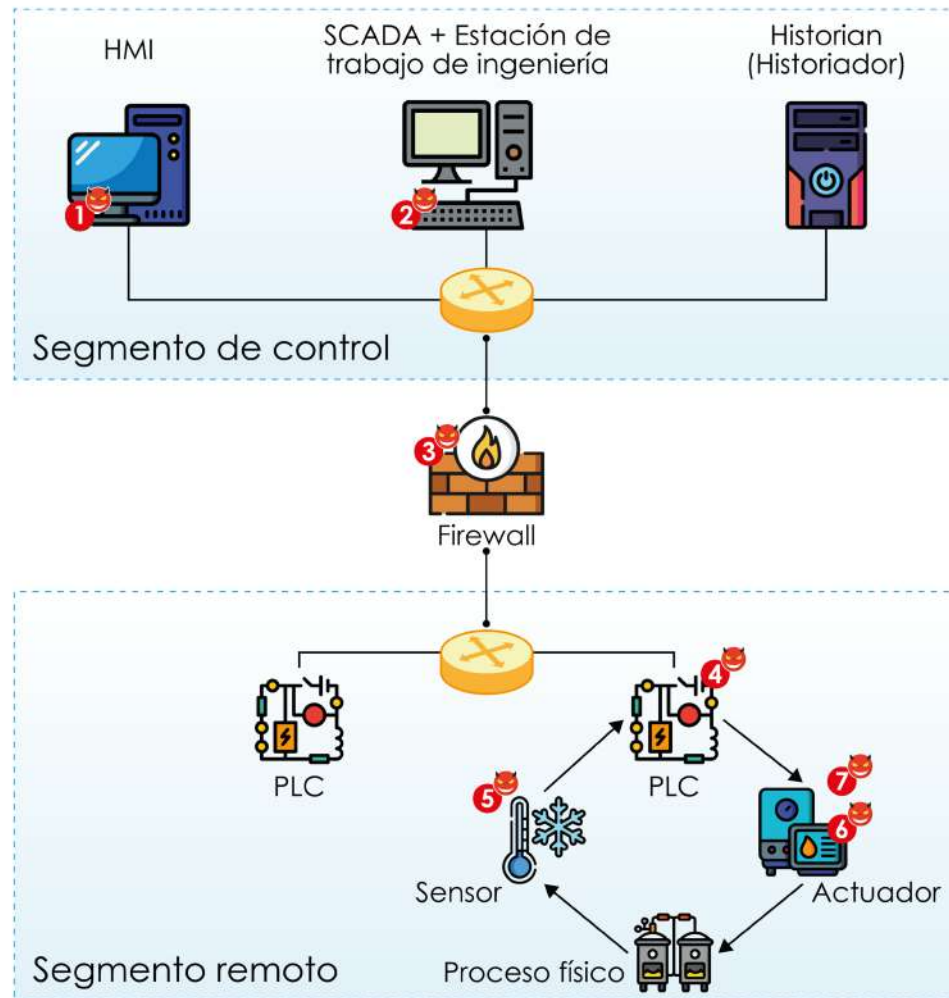
Seguridad en los CPS

Dado que desarrollar un modelo de seguridad bien definido del complejo proceso físico no es una tarea trivial [Kravchik and Shabtai \(2021\)](#). Exige un conocimiento profundo del sistema y su implementación, lo que lleva mucho tiempo y no puede escalar adecuadamente a sistemas complejos y de gran escala. Una estrategia alternativa que ha recibido atención recientemente utiliza técnicas de aprendizaje profundo para crear métodos más inteligentes y potentes que aprovechan los grandes datos para identificar intrusiones y anomalías. En esta sección se resume los trabajos representativos que se centran en los métodos de seguridad basados en el aprendizaje profundo para los CPS.

Sistemas de control industrial (SCI)

Un SCI puede ser atacado utilizando varios vectores de ataque, incluidos el software, el hardware, los protocolos de comunicación, el entorno físico y los elementos humanos. Por ejemplo, un adversario puede atacar: 1) La computadora de interfaz hombre-máquina o HMI (siglas del inglés human machine interface), al explotar vulnerabilidades de software en su sistema operativo y pila de aplicaciones, presenta una vista falsa del proceso y hace que el operador emita comandos erróneos [Kleinmann et al. \(2017\)](#); 2) El SCADA y/o la máquina de estación de trabajo de ingeniería, al explotar las vulnerabilidades del software y obtener el control total del SCI, como sucedió en Ucrania [Nast \(2016\)](#); 3) La red de comunicación en el segmento de control, en el segmento remoto, o entre ellos, mediante la realización de ataques de escucha, repetición o inyección de paquetes falsos; 4) El PLC, al explotar vulnerabilidades de software o confianza entre el PLC y SCADA; esto permitirá al atacante cambiar la lógica del PLC influyendo en el proceso controlado y causar daños, como en el caso de Stuxnet; 5) Los sensores, aprovechando los efectos físicos que interfieren con la medición o reemplazando el sensor por uno malicioso como se muestra en [Ahmed et al. \(2018\)](#), o; 6) Los actuadores, alterando la señal enviada por los actuadores al proceso controlado, como se describe en [Giraldo et al. \(2018\)](#). El ataque también puede combinar una serie de vectores, por ejemplo, emitir comandos maliciosos al actuador y reproducir un estado válido del sistema en el SCADA, como lo hace el malware Stuxnet. La Figura [X.6](#) ilustra las ubicaciones de ataque más comunes.

Figura X.6: Esquema de la arquitectura de un SCI y posibles vectores de ataque.



En los SCI se han propuesto diferentes métodos basados en DL para detectar tanto ataques como fallas [Goh et al. \(2017b\)](#); [Inoue et al. \(2017\)](#); [Kravchik and Shabtai \(2021\)](#); [Macas and Wu \(2019\)](#); [Xie et al. \(2020\)](#). Los tipos de ataque incluyen la inyección de comandos de control falsos, la suplantación de valores de sensores y la alteración de los paquetes de tráfico de comunicación. Goh et al. [Goh et al. \(2017b\)](#) aplicaron LSTM y suma acumulativa (CUSUM) para detectar anomalías en la primera etapa del conjunto de datos SWAT [Goh et al. \(2017a\)](#). Informaron el reconocimiento de nueve de cada diez ataques con cuatro falsos positivos. Desafortunadamente, este estudio no proporcionó un análisis completo/detallado de la estabilidad de los resultados. En [Inoue et al. \(2017\)](#), se realizó un estudio comparativo de dos técnicas de detección de anomalías, a saber, DNN y OC-SVM. El estudio se llevó a cabo en las seis etapas del conjunto de datos SWaT y logró una precisión del 92 % y 98 % para SVM

y DNN, respectivamente. Sin embargo, 23 de los 36 ataques tuvieron un recuerdo de detección de cero para DNN y solo un poco mejor para OC-SVM, lo que llevó a una puntuación F1 baja para ambos modelos. Además, el marco propuesto requiere muchos recursos y es complejo.

Para detectar ataques en cada una de las seis etapas del banco de pruebas SWAT Goh et al. (2017a), Kravchik et al. Kravchik and Shabtai (2018) utilizaron dos modelos de aprendizaje profundo, a saber, 1D-CNN y LSTM. Informaron que el sistema propuesto alcanzó tasas promedio de 96.8 %, 79.1 % y 87.1 % para precisión, recuperación y puntaje F1, respectivamente. Sin embargo, la detección de ataques se realizó por separado en cada etapa. Por lo tanto, no hay forma de aprender las dependencias entre etapas. Al contrario de eso, Macas et al. Macas and Wu (2019) aplicaron un modelo de codificador-descodificador LSTM convolucional basado en la atención (ConvLSTM-ED) en el banco de pruebas SWaT Goh et al. (2017a) en su totalidad (es decir, los seis subsistemas). Por lo tanto, su marco pudo modelar tanto la correlación entre sensores como las dependencias temporales de series temporales multivariadas. Este estudio reporta 96.0 %, 81.5 % y 88.0 % para puntajes de precisión, recuerdo y F1 respectivamente. En Kravchik and Shabtai (2021), los autores aplicaron convolución 1D y codificadores automáticos para detectar anomalías (ataques cibernéticos) utilizando el estado físico del sistema medido por los sensores. Este estudio utiliza tres conjuntos de datos, a saber, SWaT Goh et al. (2017a), BATDAL Aghashahi et al. (2017) y WADI Ahmed et al. (2017). La evaluación experimental del modelo propuesto informó resultados de mayor rendimiento para el conjunto de datos SWaT. En concreto, demostró tasas del 89,0 %, 80,3 % y 84,4 % en precisión, recuperación y puntuación F1. Un inconveniente de esta investigación es que requiere la configuración manual de un umbral para detectar ataques. Xie et al. Xie et al. (2020) propusieron una arquitectura NN híbrida que se basa en CNN y RNN para la detección de anomalías en CPS en el conjunto de datos SWaT Goh et al. (2017a). Aunque el rendimiento de su marco reportó una alta precisión, no consideran que muchas funciones SWaT no tengan la misma distribución en los datos de entrenamiento y prueba Goh et al. (2017a). Características como esta crean una gran cantidad de falsos positivos y, por lo tanto, deben excluirse del modelado.

Para mejorar el rendimiento de DBN mediante la obtención de los parámetros ajustables más apropiados, Lu et al. Lu et al. (2021) propusieron el método de detección de redes de creencias profundas (PEO-DBN) basado en optimización extrema de población (PEO), donde el algoritmo PEO Se empleó Boettcher

and Percus (2000) para determinar los parámetros de la DBN. Además, se mejoró el rendimiento del método único en la detección de ataques cibernéticos mediante la introducción de un esquema de votación mayoritaria para agregar la PEO-DBN propuesta, lo que condujo a la creación de EnPEO-DBN. El estudio utilizó dos conjuntos de datos de red SCADA de un sistema de tubería de gas Morris and Gao (2014) y un sistema de tanque de almacenamiento de agua Morris and Gao (2014) en varios experimentos. Aunque los resultados de la simulación mostraron que PEO-DBN y EnPEO-DBN superan la precisión de otros métodos como SVM y DT, todo el proceso del algoritmo PEO tiene un alto complejidad del tiempo. Los autores sugieren utilizar el modelo asistido por sustitutos para abordar este problema, por ejemplo, la regresión del proceso gaussiano o la optimización bayesiana. Teniendo en cuenta que con la llegada de 5G y el mayor uso de CPS en la industria, la superficie de ataque será más amplia, los autores in Hussain et al. (2021) desarrollaron un marco basado en el modelo ResNet-50 para mitigar dichos ataques. Este trabajo utilizó el conjunto de datos de Telecom Italia Barlacchi et al. (2015) para la experimentación. Aunque el modelo propuesto logró una precisión de detección de ataques superior al 91 %, no se analiza la complejidad del modelo propuesto. Por lo tanto, este modelo no podía escalar bien a un entorno en tiempo real.

Red inteligente

La seguridad de las redes inteligentes puede considerarse como la provisión de seguridad de los canales de comunicación y AMI Rice and AlMajali (2014). Generalmente, hay siete áreas en las redes inteligentes. Estas siete áreas, donde casi todas se comunican entre sí, se muestran en la Figura X.7 Harvey et al. (2014). Cada una de las interfaces de estos siete dominios tiene diferentes requisitos de seguridad en términos de disponibilidad, integridad y confidencialidad de los datos. Además, la privacidad, la calidad del acceso a los datos, la prevención del acceso no autorizado, la garantía de la continuidad del sistema y la calidad del servicio son los requisitos de ciberseguridad de los dominios de redes inteligentes.

En particular, las redes inteligentes aprovechan los CPS para brindar servicios con alta confiabilidad y eficiencia, centrándose en las necesidades del consumidor. Pueden adaptarse a las demandas de energía en tiempo real, lo que permite una mayor funcionalidad Berman et al. (2019). Sin embargo, estas redes dependen de la tecnología de la información, que es vulnerable a los ataques cibernéticos. Uno de esos ataques es la inyección de datos falsos o FDI

Figura X.7: Dominios de redes inteligentes.



(siglas del inglés false data injection). Este ataque sigiloso y difícil de detectar ha atraído muchos esfuerzos de investigación [He et al. (2017); Niu et al. (2019); Wang et al. (2019a,b)]. Generalmente, los ataques FDI inyectan paquetes maliciosos con el objetivo de crear pequeños errores de medición que corrompen el componente de la red inteligente que realiza la estimación del estado. Para superar este problema, He et al. [He et al. (2017)] utilizaron Conditional Deep Belief Network (CDBN) para revelar de manera eficiente las características de comportamiento temporal de alta dimensión de los ataques FDI no observables. Su enfoque se evaluó en el sistema de prueba de potencia de 118 buses IEEE y en el sistema de 300 buses IEEE y pudo lograr una precisión superior al 93 % en varias pruebas. Sin embargo, el número de escenarios experimentales examinados fue bastante limitado.

Según [Niu et al. (2019)], los atacantes podrían inyectar puntos de datos maliciosos multivariados en un período (anomalías contextuales o colectivas). Dado que tales ataques de FDI son más sigilosos, es posible que la inspección

de los datos de medición por sí sola no los detecte. Los autores propusieron un modelo híbrido de detección de anomalías basado en 1D-CNN y RNN que combinaba medidas de sensores y paquetes de red para solucionar este problema. El modelo 1D-CNN extrajo características de los datos de origen, que luego se introdujeron en un RNN con unidades LSTM para predecir el siguiente punto de datos. Los puntos de datos que generaron grandes errores de predicción se clasificaron como anomalías. El framework propuesto fue evaluado en un sistema IEEE de 39 buses, donde alcanzó una precisión superior al 90 %. Al considerar la detección de anomalías como un problema de clasificación binaria, Wang et al. [Wang et al. \(2019b\)](#) aplicaron un modelo RNN a los ataques de FDI. Las simulaciones sobre el sistema de bus IEEE 39 indican que su modelo puede lograr una precisión de detección FDIA aceptable. Sin embargo, el rendimiento de su marco se comparó solo con arquitecturas poco profundas y no se especificó la configuración del modelo RNN.

Dado que la recopilación de datos a gran escala puede ser prohibitivamente costosa y consumir mucho tiempo, Zhang et al. [Zhang et al. \(2021\)](#) propusieron un enfoque de aprendizaje semisupervisado al integrar los AE en un marco GAN para detectar FDIA no observables en los sistemas de distribución. Los AE sirven para la reducción de dimensiones y la extracción de características de conjuntos de datos de medición y el GAN se emplea en la tarea de detección de ataques. Los autores evaluaron el enfoque propuesto en puntos de referencia desequilibrados trifásicos: sistemas de distribución IEEE de 13 y 123 buses [Schneider et al. \(2018\)](#). Los resultados experimentales mostraron que su método tiene una precisión de detección alta y robusta en comparación (alrededor del 97 % de precisión en ambos sistemas) con otras técnicas de aprendizaje semisupervisado. Similar a [Zhang et al. \(2021\)](#), los autores en [Siniosoglou et al. \(2021\)](#) combinaron dos DNN, a saber, AE y GAN, para desarrollar un modelo de detección de anomalías capaz de (I) detección de anomalías y (II) clasificación de ciberataques Modbus/TCP y DNP3. El modelo propuesto fue validado en cuatro entornos de evaluación SG que se originaron en el proyecto SPEAR [Grammatikis et al. \(2020\)](#): (i) laboratorio SG, (ii) central hidroeléctrica, y (iii) central eléctrica. El rendimiento de la detección paralela de anomalías y ciberataques particulares fue del 95 % de precisión con un 3,6 % de FPR. Los métodos de detección de ciberataques o de valores atípicos requieren la recopilación de datos de la misma estructura de topología [Siniosoglou et al. \(2021\)](#). Las medidas y estados correspondientes deben almacenarse de acuerdo a diferentes etiquetas de topología para el análisis de datos posterior cuando

cambia la estructura de la topología. Sin embargo, este efecto no se considera en Siniosoglou et al. (2021); Zhang et al. (2021).

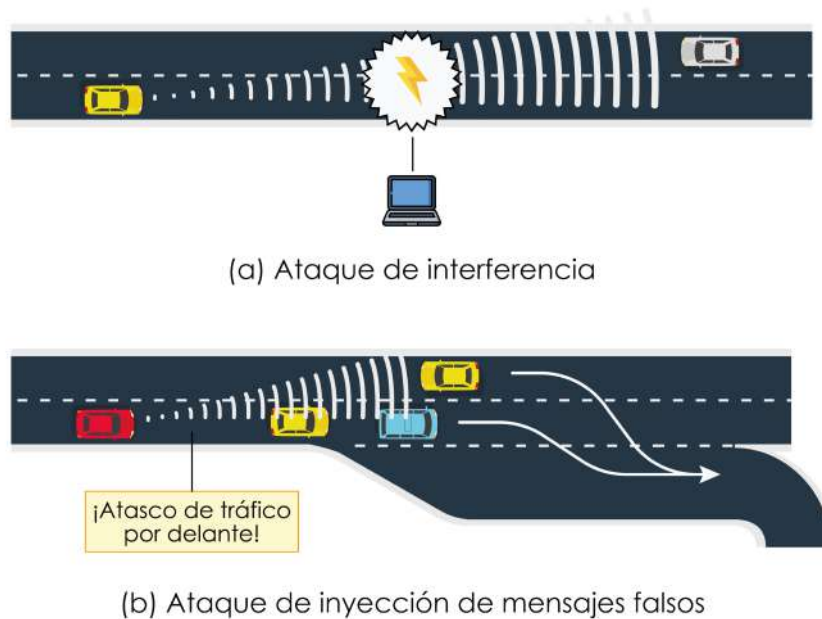
Un ataque de manipulación de datos (PDMA) de una unidad de medición fasorial (PMU) puede cegar a los centros de control de las condiciones operativas en tiempo real de los sistemas de energía. Para detectar este tipo de ataque, Wang et al. (2019a) utilizó un AE profundo. La entrada del AE fue de 108 características extraídas de las mediciones de PMU (p. ej., la magnitud trifásica, los ángulos y los voltajes). Se detectó un ataque, si el error de reconstrucción estaba por encima de un umbral predefinido. El modelo propuesto consiguió un alto rendimiento de detección alcanzando un 94,1 % de exactitud, un 99,6 % de precisión, un 88,6 % de recuperación y un 93,8 % de puntuación F1.

Sistemas de transporte inteligentes

Al permitir el intercambio continuo de información entre los vehículos y la infraestructura vial en tiempo real, se espera que los vehículos conectados y automatizados (CAV) cambien total y drásticamente la industria del transporte (van Wyk et al. (2020)). Aunque es probable que la conectividad y la automatización traigan varios beneficios, pueden dar lugar a nuevos desafíos de seguridad, protección y privacidad. Los CAV dependen en gran medida de las lecturas de sus sensores y de la información recibida de otros vehículos y unidades de carretera para navegar por las carreteras. Por lo tanto, las lecturas anómalas de los sensores causadas por ataques cibernéticos maliciosos o sensores de vehículos defectuosos pueden tener consecuencias disruptivas y provocar accidentes fatales. En este contexto, antes de la implementación masiva de CAV, es fundamental desarrollar estrategias para la detección de anomalías en tiempo real y sin problemas, incluida la identificación de sus fuentes. La Figura X.8 muestra dos ejemplos de diferentes tipos de mala conducta (ataques) en sistemas inteligentes de transporte.

Wyck et al. creó una detección de anomalías para CAV mediante la combinación de filtrado de CNN y Kalman (KF) (van Wyk et al. (2020)). Primero, se empleó un modelo de CNN que constaba de tres capas de CNN y dos capas completamente conectadas para eliminar las lecturas falsas del sensor. Luego, los datos examinados se enviaron a KF para eliminar más anomalías no detectadas por el modelo CNN. El método se validó en un conjunto de datos reales de dos años obtenidos del programa Safety Pilot Model Deployment (SPMD) (Bezzina and Sayer (2014)). El enfoque híbrido general es prometedor,

Figura X.8: Dos ejemplos de diferentes tipos de mala conducta en sistemas inteligentes de transporte.



alcanzando una precisión del 99,7 %, una sensibilidad del 99,2 %, una precisión del 99,8 % y una puntuación F1 del 99,5 %, superando a los dos métodos de referencia (KF independiente y CNN).

La seguridad en el vehículo es particularmente desafiante debido al bus de la red de área del controlador (CAN) que no tiene seguridad incorporada. Con el objetivo de detectar ataques/anomalías en el bus de la red de área del controlador (CAN), que es responsable de la comunicación entre dispositivos (p. ej., bolsas de aire) y unidades de control electrónico (ECU) [Hahn et al. \(2021\)](#); [Hanselmann et al. \(2020\)](#), Hanselmann et al. [Hanselmann et al. \(2020\)](#) introdujo un marco basado en DL llamado CANet entrenado sin supervisión. Diseñaron CANet utilizando LSTM para capturar el comportamiento de la serie temporal del bus CAN, AE para aprender el comportamiento normal y la Unidad lineal exponencial (ELU) [Clevert et al. \(2015\)](#) para mejorar la clasificación de su marco. CANet se probó en datos sintéticos y de trabajo real de alta dimensión y logró una tasa de verdaderos positivos (detección) de alrededor del 99 %.

En la infraestructura de transporte inteligente, las estaciones de carga inteligentes seguras y confiables son de suma importancia. Se han implementado muchas estaciones de carga inteligentes en los últimos años, y la mayoría de ellas están en línea y conectadas, lo que aumenta los riesgos potenciales de amenazas. Li et al. [Li et al. \(2021\)](#) propusieron un método de detección de

anomalías basado en DL para sistemas de suministro de energía en vehículos en los llamados datos reales (es decir, datos recopilados por el instituto del autor). En particular, utilizaron la arquitectura Transformer que considera las correlaciones inherentes del tráfico generado por los ICS. Los resultados mostraron que su modelo logró una tasa de precisión y una puntuación F1 del 99,80 %, superando a otras arquitecturas tradicionales y profundas como DT, RF y CNN. El tren Ethernet Consist Network (ECN) asume la tarea de transmitir instrucciones críticas de control del tren. Para detectar ataques de red contra el tren ECN, Yue et al. [Yue et al. \(2021\)](#) introdujeron un conjunto de IDS basado en CNN y RNN. En particular, utilizaron tres variantes de CNN, a saber, LetNet5, AlexNet y VGGNet, para capturar los patrones espaciales en los datos. Al mismo tiempo, se utilizaron tres variantes de NN recurrentes denominadas vanilla-RNN, LSTM y GRU para capturar los patrones temporales. Treinta y cuatro características de varios contenidos de protocolo se extrajeron de los datos sin procesar producidos mediante el empleo de un banco de pruebas ECN para construir un conjunto de datos específico. Aunque el modelo propuesto alcanzó una tasa de precisión del 98 %, no es posible evaluar si podría funcionar en un entorno real, ya que no se examina su complejidad temporal.

Lecciones aprendidas. Los ataques cibernéticos se dirigen a los sistemas informáticos, acceden a datos confidenciales de una computadora objetivo y luego, por lo general, los inhabilitan o los extraen. Pero cada vez más elementos del mundo físico están conectados a sistemas informáticos a través de Internet. Los ciberataques físicos tienen como objetivo estos elementos, lo que aumenta las infracciones al ordenar que el elemento pirateado realice una acción deliberada, con consecuencias físicas reales. La variedad de aplicaciones es asombrosa. Los atacantes podrían explotar el control de un activo físico y rescatarlo para obtener ganancias financieras. Podrían piratear equipos de construcción inteligentes, retrasando el progreso o dañando la infraestructura existente. Podrían tomar el control de un vehículo autónomo, causando estragos en las calles de la ciudad. Podrían comprometer las máquinas de votación y posiblemente cambiar el resultado de una elección. Con el IoT aumentando el número y el alcance de los dispositivos conectados, un pirata informático que comprometa un dispositivo podría crear errores posteriores en los datos enviados a otro. Los errores compuestos crearían un efecto en cascada, deshabilitando más dispositivos conectados a la red.

Sitios de Interés

1. **iTrust, Bancos de pruebas y plataformas de capacitación de clase mundial.** A One-of-a-Kind Garden of Testbeds. URL: https://itrust.sutd.edu.sg/itrust-labs_overview/.
2. **Nist, Banco de pruebas de sistemas ciberfísicos/Internet de las cosas.** CPS/IoT Testbed. URL: <https://www.nist.gov/programs-projects/cyber-physical-systemsinternet-things-testbed>.

Referencias

- Abe, K. and Goto, S. (2016). Fingerprinting attack on tor anonymity using deep learning. *Proceedings of the Asia-Pacific Advanced Network*, 42:15–20.
- Abuhamad, M., Abuhmed, T., Mohaisen, D., and Nyang, D. (2020). Autosen: Deep-learning-based implicit continuous authentication using smartphone sensors. *IEEE Internet of Things Journal*, 7(6):5008–5020.
- Aceto, G., Ciuonzo, D., Montieri, A., and Pescapé, A. (2018). Mobile encrypted traffic classification using deep learning. In *2018 Network Traffic Measurement and Analysis Conference (TMA)*, pages 1–8. IEEE.
- Aghashahi, M., Sundararajan, R., Pourahmadi, M., and Banks, M. K. (2017). Water distribution systems analysis Symposium–Battle of the attack detection algorithms (BATADAL). In *World Environmental and Water Resources Congress 2017*, pages 101–108. American Society of Civil Engineers.
- Ahmed, C. M., Palleti, V. R., and Mathur, A. P. (2017). Wadi. In *Proceedings of the 3rd International Workshop on Cyber-Physical Systems for Smart Water Networks*, pages 25–28. ACM, ACM.
- Ahmed, C. M., Zhou, J., and Mathur, A. P. (2018). Noise matters: Using sensor and process noise fingerprint to detect stealthy cyber attacks and authenticate sensors in cps. In *Proceedings of the 34th Annual Computer Security Applications Conference, ACSAC '18*, page 566–581, New York, NY, USA. Association for Computing Machinery.
- Algaolahi, A. Q. M., Hasan, A. A., Sallam, A., Sharaf, A. M., Abdu, A. A., and Alqadi, A. A. (2021). Port-scanning attack detection using supervised machine learning classifiers. In *2021 1st International Conference on Emerging Smart Technologies and Applications (eSmarTA)*, pages 1–5. IEEE.
- Ali, A., Khan, M., Saddique, M., Pirzada, U., Zohaib, M., Ahmad, I., and Debnath, N. (2016). Tor vs i2p: A comparative study. In *2016 IEEE International Conference on Industrial Technology (ICIT)*, pages 1748–1751.

- Almeida, T. A., Hidalgo, J. M. G., and Yamakami, A. (2011). Contributions to the study of sms spam filtering: New collection and results. In *Proceedings of the 11th ACM Symposium on Document Engineering, DocEng '11*, page 259–262, New York, NY, USA. Association for Computing Machinery.
- Alsmadi, I. (2023). Cyber operational planning. In *The NICE Cyber Security Framework*, pages 131–178. Springer International Publishing.
- Amaral, A. C. (2014). La amenaza cibernética para la seguridad y defensa de brasil.
- Aminzade, M. (2018). Confidentiality, integrity and availability – finding a balanced IT framework. *Network Security*, 2018(5):9–11.
- Andrade, R. O., Fuertes, W., Cazares, M., Ortiz-Garcés, I., and Navas, G. (2022). An exploratory study of cognitive sciences applied to cybersecurity. *Electronics*, 11(11):1692.
- Andrejevic, M. and Gates, K. (2014). Big data surveillance: Introduction. *Surveillance & Society*, 12(2):185–196.
- Anton, S. D., Fraunholz, D., Lipps, C., Pohl, F., Zimmermann, M., and Schotten, H. D. (2017). Two decades of SCADA exploitation: A brief history. In *2017 IEEE Conference on Application, Information and Network Security (AINS)*, pages 98–104. IEEE, IEEE.
- (APWG), A. P. W. G. (2022). Phishing activity trends report, 3rd quarter, 2022. [Accessed: Nov 4, 2022].
- Asbaş, C. and Tuzlukaya, Ş. (2022). Cyberattack and cyberwarfare strategies for businesses. In *Conflict Management in Digital Business*, pages 303–328. Emerald Publishing Limited.
- at 360, N. S. R. L. (2019). Netlab dga project. url=<https://data.netlab.360.com/>, [Accessed: May 25, 2022].
- Barlacchi, G., Nadai, M. D., Larcher, R., Casella, A., Chitic, C., Torrisi, G., Antonelli, F., Vespignani, A., Pentland, A., and Lepri, B. (2015). A multi-source dataset of urban life in the city of milan and the province of trentino. *Scientific Data*, 2(1).

- Bauman, S. (2015). Types of cyberbullying. <https://doi.org/10.1002/9781119221685.ch4>.
- Beckers, K., Krautsevich, L., and Yautsiukhin, A. (2015). Analysis of social engineering threats with attack graphs. In *Data Privacy Management, Autonomous Spontaneous Security, and Security Assurance*, pages 216–232. Springer International Publishing.
- Berman, D., Buczak, A., Chavis, J., and Corbett, C. (2019). A survey of deep learning methods for cyber security. *Information*, 10(4):122.
- Bezzina, D. and Sayer, J. (2014). Safety pilot model deployment: Test conductor team report. *Report No. DOT HS, 812(171)*:18.
- Boettcher, S. and Percus, A. (2000). Nature's way of optimizing. *Artificial Intelligence*, 119(1-2):275–286.
- Brown, T., Mann, B., Ryder, N., Subbiah, M., Kaplan, J. D., Dhariwal, P., Nee-lakantan, A., Shyam, P., Sastry, G., Askell, A., Agarwal, S., Herbert-Voss, A., Krueger, G., Henighan, T., Child, R., Ramesh, A., Ziegler, D., Wu, J., Winter, C., Hesse, C., Chen, M., Sigler, E., Litwin, M., Gray, S., Chess, B., Clark, J., Berner, C., McCandlish, S., Radford, A., Sutskever, I., and Amodei, D. (2020). Language models are few-shot learners. In Larochelle, H., Ranzato, M., Had-sell, R., Balcan, M., and Lin, H., editors, *Advances in Neural Information Processing Systems*, volume 33, pages 1877–1901. Curran Associates, Inc.
- Buchan, R. and Navarrete, I. (2021). Cyber espionage and international law. In *Research Handbook on International Law and Cyberspace*. Edward Elgar Publishing.
- Busch, C. (2023). Standards for biometric presentation attack detection. In *Handbook of Biometric Anti-Spoofing*, pages 571–583. Springer Nature Singapore.
- Calabrese, J., Esponda, S., Pasini, A., and Pesado, P. (2021). Data evaluation model using GQM approach. In *Communications in Computer and Information Science*, pages 141–154. Springer International Publishing.
- Cao, R., Liu, G., Xie, Y., and Jiang, C. (2021). Two-level attention model of representation learning for fraud detection. *IEEE Transactions on Computational Social Systems*, 8(6):1291–1301.

- Case, D. U. (2016). Analysis of the cyber attack on the Ukrainian power grid. *Electricity Information Sharing and Analysis Center (E-ISAC)*, 388.
- Castillo, C., Donato, D., Becchetti, L., Boldi, P., Leonardi, S., Santini, M., and Vigna, S. (2006). A reference collection for web spam. *ACM SIGIR Forum*, 40(2):11–24.
- Cazares, M. F., Andrade, R., Navas, G., Fuertes, W., and Herrera, J. (2021). Characterizing phishing attacks using natural language processing. In *2021 Fifth World Conference on Smart Trends in Systems Security and Sustainability (WorldS4)*, pages 224–229. IEEE.
- Cazares, M. F., Arévalo, D., Andrade, R. O., Fuertes, W., and Sánchez-Rubio, M. (2022). A training web platform to improve cognitive skills for phishing attacks detection. In *Intelligent Sustainable Systems*, pages 33–42. Springer Nature Singapore.
- Cheema, A., Tariq, M., Hafiz, A., Khan, M. M., Ahmad, F., and Anwar, M. (2022). Prevention techniques against distributed denial of service attacks in heterogeneous networks: A systematic review. *Security and Communication Networks*, 2022:1–15.
- Cheng, D., Wang, X., Zhang, Y., and Zhang, L. (2022). Graph neural network for fraud detection via spatial-temporal attention. *IEEE Transactions on Knowledge and Data Engineering*, 34(8):3800–3813.
- Cheng, J., He, R., Yuepeng, E., Wu, Y., You, J., and Li, T. (2020). Real-time encrypted traffic classification via lightweight neural networks. In *GLOBECOM 2020 - 2020 IEEE Global Communications Conference*, pages 1–6. IEEE.
- Cheng, K. H. and Kumar, A. (2019). Contactless biometric identification using 3d finger knuckle patterns. *IEEE transactions on pattern analysis and machine intelligence*, 42(8):1868–1883.
- Cheng, K. H. M. and Kumar, A. (2020). Contactless biometric identification using 3d finger knuckle patterns. *IEEE Transactions on Pattern Analysis and Machine Intelligence*, 42(8):1868–1883.
- Chertoff, M. (2017). A public policy perspective of the dark web. *Journal of Cyber Policy*, 2(1):26–38.

- Clarke, I., Miller, S., Hong, T., Sandberg, O., and Wiley, B. (2002). Protecting free expression online with freenet. *IEEE Internet Computing*, 6(1):40–49.
- Clevert, D.-A., Unterthiner, T., and Hochreiter, S. (2015). Fast and accurate deep network learning by exponential linear units (elus). <https://arxiv.org/abs/1511.07289>.
- Creado, Y. and Ramteke, V. (2020). Active cyber defence strategies and techniques for banks and financial institutions. *Journal of Financial Crime*, 27(3):771–780.
- Curtin, R. R., Gardner, A. B., Grzonkowski, S., Kleymenov, A., and Mosquera, A. (2019). Detecting DGA domains with recurrent neural networks and side information. In *Proceedings of the 14th International Conference on Availability, Reliability and Security*, page 20. ACM, ACM.
- Davidson, R. (2021). The fight against malware as a service. *Network Security*, 2021(8):7–11.
- Deibert, R. J., Rohozinski, R., Manchanda, A., Villeneuve, N., and Walton, G. (2009). Tracking ghostnet: Investigating a cyber espionage network.
- Devlin, J., Chang, M.-W., Lee, K., and Toutanova, K. (2018). Bert: Pre-training of deep bidirectional transformers for language understanding. <https://arxiv.org/abs/1810.04805>.
- Dierks, T. and Rescorla, E. (2008). The transport layer security (TLS) protocol version 1.2. *RFC*, 5246:1–104.
- Ding, Y., Zhang, X., Li, B., Xing, J., Qiang, Q., Qi, Z., Guo, M., Jia, S., and Wang, H. (2022). Malware classification based on semi-supervised learning. In *Science of Cyber Security*, pages 287–301. Springer International Publishing.
- Dingledine, R., Mathewson, N., and Syverson, P. (2004). Tor: The second-generation onion router. Technical report, Naval Research Lab Washington DC.
- Diogenes, Y. and Ozkaya, E. (2022). *Cybersecurity—Attack and Defense Strategies: Improve your security posture to mitigate risks and prevent attackers from infiltrating your system*. Packt Publishing Ltd.

- Disconnect, I. (2021). Disconnect - internet surveillance puts you at risk. <https://disconnect.me/>. [Accessed: Feb 5, 2023].
- Dominguez, A. H. and García, W. B. (2021). Updated analysis of detection methods for phishing attacks. In *Communications in Computer and Information Science*, pages 56–67. Springer Singapore.
- Donner, M. (2007). Cyberassault on estonia. *IEEE Security & Privacy Magazine*, 5(4):4–4.
- Draper-Gil, G., Lashkari, A. H., Mamun, M. S. I., and Ghorbani, A. A. (2016). Characterization of encrypted and vpn traffic using time-related. In *Proceedings of the 2nd international conference on information systems security and privacy (ICISSP)*, pages 407–414.
- Dubey, R., Gupta, M., Mikalef, P., and Akter, S. (2022). Incorporating blockchain technology in information systems research. *International Journal of Information Management*, page 102573.
- Englander, E., Donnerstein, E., Kowalski, R., Lin, C. A., and Parti, K. (2017). Defining cyberbullying. *Pediatrics*, 140(Supplement_2):S148–S151.
- Felt, A. P., Finifter, M., Chin, E., Hanna, S., and Wagner, D. (2011). A survey of mobile malware in the wild. In *Proceedings of the 1st ACM workshop on Security and privacy in smartphones and mobile devices*, page 3–14. ACM.
- Feng, B., Fu, Q., Dong, M., Guo, D., and Li, Q. (2018). Multistage and elastic spam detection in mobile social networks through deep learning. *IEEE Network*, 32(4):15–21.
- Firdous, M. A. (2020). Cyber warfare and global power politics. *CISS Insight Journal*, 8(1):P71–93.
- for Cybersecurity., E. U. A. (2020). Enisa threat landscape - the year in review. <https://www.enisa.europa.eu/publications/year-in-review>. [Accessed: Jan 5, 2023].
- Fuertes, W., Arévalo, D., Castro, J. D., Ron, M., Estrada, C. A., Andrade, R., Peña, F. F., and Benavides, E. (2021). Impact of social engineering attacks: A literature review. In *Smart Innovation, Systems and Technologies*, pages 25–35. Springer Singapore.

- Fuertes, W., Reyes, F., Valladares, P., Tapia, F., Toulkeridis, T., and Pérez, E. (2017a). An integral model to provide reactive and proactive services in an academic CSIRT based on business intelligence. *Systems*, 5(4):52.
- Fuertes, W., Tunala, A., Moncayo, R., Meneses, F., and Toulkeridis, T. (2017b). Software-based platform for education and training of DDoS attacks using virtual networks. In *2017 International Conference on Software Security and Assurance (ICSSA)*, pages 94–99. IEEE.
- Furnell, S. (2021). The cybersecurity workforce and skills. *Computers & Security*, 100:102080.
- Furnell, S. and Emm, D. (2017). The ABC of ransomware protection. *Computer Fraud & Security*, 2017(10):5–11.
- Gao, M., Filipino, T., Zhao, X., and McJunkin, M. (2020). Adolescent victim experiences of cyberbullying. In *Developing Safer Online Environments for Children*, pages 94–112. IGI Global.
- Gao, Y., Gong, M., Xie, Y., and Qin, A. (2021). An attention-based unsupervised adversarial model for movie review spam detection. *IEEE Trans. Multimedia*, 23:784–796. 10.1109/tmm.2020.2990085.
- George, A., Mostaani, Z., Geissenbuhler, D., Nikisins, O., Anjos, A., and Marcel, S. (2020). Biometric face presentation attack detection with multi-channel convolutional neural network. *IEEE Trans. Inform. Forensic Secur.*, 15:42–55.
- Gerbet, T., Kumar, A., and Lauradoux, C. (2016). A privacy analysis of google and yandex safe browsing. In *2016 46th Annual IEEE/IFIP International Conference on Dependable Systems and Networks (DSN)*, pages 347–358. IEEE.
- Gillard, S. (2020). Defending critical infrastructure: Insights from recommender systems. In *International Series in Operations Research & Management Science*, pages 193–206. Springer International Publishing.
- Giraldo, J., Urbina, D., Cardenas, A., Valente, J., Faisal, M., Ruths, J., Tippenhauer, N. O., Sandberg, H., and Candell, R. (2018). A survey of physics-based attack detection in cyber-physical systems. *ACM Computing Surveys*, 51(4):1–36.

- Goedeker, M. A. (2021). Cyber security. In *Global Business Leadership Development for the Fourth Industrial Revolution*, pages 174–208. IGI Global.
- Goel, S. (2011). Cyberwarfare. *Communications of the ACM*, 54(8):132–140.
- Goethals, P. L. and Hunt, M. E. (2019). A review of scientific research in defensive cyberspace operation tools and technologies. *Journal of Cyber Security Technology*, 3(1):1–46.
- Goh, J., Adepu, S., Junejo, K. N., and Mathur, A. (2017a). A dataset to support research in the design of secure water treatment systems. In *Critical Information Infrastructures Security*, pages 88–99. Springer International Publishing.
- Goh, J., Adepu, S., Tan, M., and Lee, Z. S. (2017b). Anomaly detection in cyber physical systems using recurrent neural networks. In *2017 IEEE 18th International Symposium on High Assurance Systems Engineering (HASE)*, pages 140–145. IEEE, IEEE.
- Grammatikis, P. R., Sarigiannidis, P., Iturbe, E., Rios, E., Sarigiannidis, A., Nikolis, O., Ioannidis, D., Machamint, V., Tzifas, M., Giannakoulis, A., Angelopoulos, M., Papadopoulos, A., and Ramos, F. (2020). Secure and private smart grid: The SPEAR architecture. In *2020 6th IEEE Conference on Network Softwarization (NetSoft)*. IEEE.
- Greenberg, A. (2018). The untold story of NotPetya, the most devastating cyberattack in history. <https://www.wired.com/story/notpetya-cyberattack-ukraine-russia-code-crashed-the-world/>. [Accessed: Jan 5, 2023].
- Gumusbas, D., Yldrm, T., Genovese, A., and Scotti, F. (2020). A comprehensive survey of databases and deep learning methods for cybersecurity and intrusion detection systems. *IEEE Syst. J.*, pages 1–15.
- Guo, Z., Shen, Y., Bashir, A. K., Imran, M., Kumar, N., Zhang, D., and Yu, K. (2020). Robust spammer detection using collaborative neural network in internet of thing applications. *IEEE Internet Things J.*, pages 1–1.
- Hadid, A., Evans, N., Marcel, S., and Fierrez, J. (2015). Biometrics systems under spoofing attack: An evaluation methodology and lessons learned. *IEEE Signal Process. Mag.*, 32(5):20–30.

- Hahn, D., Munir, A., and Behzadan, V. (2021). Security and privacy issues in intelligent transportation systems: Classification and challenges. *IEEE Intelligent Transportation Systems Magazine*, 13(1):181–196.
- Hamill, F. A. (2020). Sayano shushenskaya 2009 accident update.
- Hanselmann, M., Strauss, T., Dormann, K., and Ulmer, H. (2020). CANet: An unsupervised intrusion detection system for high dimensional CAN bus data. *IEEE Access*, 8:58194–58205.
- Harvey, M., Long, D., and Reinhard, K. (2014). Visualizing nistir 7628, guidelines for smart grid cyber security. In *2014 Power and Energy Conference at Illinois (PECI)*, pages 1–8. 10.1109/PECI.2014.6804566.
- He, Y., Mendis, G. J., and Wei, J. (2017). Real-time detection of false data injection attacks in smart grid: A deep learning-based intelligent mechanism. *IEEE Trans. Smart Grid*, 8(5):2505–2516.
- Hout, M. C. V. and Bingham, T. (2013). ‘silk road’, the virtual drug marketplace: A single case study of user experiences. *International Journal of Drug Policy*, 24(5):385–391.
- Hua, J. and Bapna, S. (2013). The economic impact of cyber terrorism. *The Journal of Strategic Information Systems*, 22(2):175–186.
- Huber, E. (2019). *The 2019 Official Annual Cybercrime Report.*, chapter Cybercrime, pages 21–29. Springer Fachmedien Wiesbaden.
- Hussain, B., Du, Q., Sun, B., and Han, Z. (2021). Deep learning-based DDoS-attack detection for cyber-physical system over 5g network. *IEEE Transactions on Industrial Informatics*, 17(2):860–870.
- I2P, I. (2023). I2p - the invisible internet project. <https://geti2p.net/en/>. [Accessed: Feb 5, 2023].
- Inc., T. F. P. (2023). Freenet. <https://freenetproject.org/>. [Accessed: Feb 5, 2023].
- Inoue, J., Yamagata, Y., Chen, Y., Poskitt, C. M., and Sun, J. (2017). Anomaly detection for a water treatment system using unsupervised machine learning. In *2017 IEEE International Conference on Data Mining Workshops (ICDMW)*, pages 1058–1065. IEEE, IEEE.

- Institute, C. R. (2019). Reinventing cybersecurity with artificial intelligence. <https://www.capgemini.com/research/reinventing-cybersecurity-with-artificial-intelligence/>. [Accessed: Jan 5, 2023].
- Intelligence, M. (2021). Fraud detection and prevention market - growth, trends, covid-19 impact, and forecasts (2021 - 2026). <https://www.mordorintelligence.com/industry-reports/global-fraud-detection-and-prevention-fdp-market-industry>. [Accessed: Jun 20, 2021].
- Ivanov, M. A., Kliuchnikova, B. V., Chugunkov, I. V., and Plaksina, A. M. (2021). Phishing attacks and protection against them. In *2021 IEEE Conference of Russian Young Researchers in Electrical and Electronic Engineering (ElConRus)*, pages 425–428.
- Jakobsson, M., Shi, E., Golle, P., Chow, R., et al. (2009). Implicit authentication for mobile devices. In *Proceedings of the 4th USENIX conference on Hot topics in security*, volume 1, pages 25–27. USENIX Association.
- Ji, S., Li, J., Yuan, Q., and Lu, J. (2020). Multi-range gated graph neural network for telecommunication fraud detection. In *2020 International Joint Conference on Neural Networks (IJCNN)*, pages 1–6. IEEE.
- Journal, T. W. S. (2017). Yahoo triples estimate of breached accounts to 3 billion. <https://www.wsj.com/articles/yahoo-triples-estimate-of-breached-accounts-to-3-billion-1507062804>. [Accessed: Jan 5, 2023].
- kaggle (2019). Utkml’s twitter spam detection competition. <https://www.kaggle.com/c/utkml-twitter-spam/data>. [Accessed: May 25, 2021].
- Kenney, M. (2015). Cyber-terrorism in a post-stuxnet world. *Orbis*, 59(1):111–128.
- Khatoun, R. and Zeadally, S. (2017). Cybersecurity and privacy solutions in smart cities. *IEEE Commun. Mag.*, 55(3):51–59.
- Khazagarov, A., Vorobeva, A., and Korzhuk, V. (2021). Preventing hidden information leaks using author attribution methods and neural networks. In *2021 29th Conference of Open Innovations Association (FRUCT)*, pages 177–184. IEEE.

- Kim, J., Sim, A., Kim, J., and Wu, K. (2020). Botnet detection using recurrent variational autoencoder. In *GLOBECOM 2020 - 2020 IEEE Global Communications Conference*, pages 1–6. IEEE.
- Kim, S., Jang, J., Kwon, O.-J., Kim, J.-Y., and Shin, D. (2022). Study on cyber attack damage assessment framework. *IEEE Access*, 10:59270–59276.
- Kizza, J. M. (2020). Cyber crimes and hackers. In *Texts in Computer Science*, pages 105–131. Springer International Publishing.
- Kleinmann, A., Amichay, O., Wool, A., Tenenbaum, D., Bar, O., and Lev, L. (2017). Stealthy deception attacks against SCADA systems. In *Computer Security*, pages 93–109. Springer International Publishing.
- Kong, H., Lu, L., Yu, J., Chen, Y., Kong, L., and Li, M. (2019). FingerPass. In *Proceedings of the Twentieth ACM International Symposium on Mobile Ad Hoc Networking and Computing*, pages 201–210. ACM.
- Kou, Y., Lu, C.-T., Sirwongwattana, S., and Huang, Y.-P. (2004). Survey of fraud detection techniques. In *IEEE International Conference on Networking, Sensing and Control, 2004*, pages 749–754 Vol.2. IEEE.
- Kravchik, M. and Shabtai, A. (2018). Detecting cyber attacks in industrial control systems using convolutional neural networks. In *Proceedings of the 2018 Workshop on Cyber-Physical Systems Security and PrivaCy*, pages 72–83. ACM.
- Kravchik, M. and Shabtai, A. (2021). Efficient cyber attack detection in industrial control systems using lightweight neural networks and PCA. *IEEE Trans. Dependable and Secure Comput.*, pages 1–1.
- Lashkari, A. H., Draper-Gil, G., Mamun, M. S. I., and Ghorbani, A. A. (2017). Characterization of tor traffic using time based features. In *ICISSp*, pages 253–262.
- Li, Y., Zhang, L., Lv, Z., and Wang, W. (2021). Detecting anomalies in intelligent vehicle charging and station power supply systems with multi-head attention models. *IEEE Transactions on Intelligent Transportation Systems*, 22(1):555–564.
- Liebers, J., Abdelaziz, M., Mecke, L., Saad, A., Auda, J., Gruenefeld, U., Alt, F., and Schneegass, S. (2021). Understanding user identification in virtual reality through behavioral biometrics and the effect of body normalization.

- In *Proceedings of the 2021 CHI Conference on Human Factors in Computing Systems*, pages 1–11.
- Lin, C., Hu, J., Sun, Y., Ma, F., Wang, L., and Wu, G. (2018). WiAU: An accurate device-free authentication system with ResNet. In *2018 15th Annual IEEE International Conference on Sensing, Communication, and Networking (SECON)*, pages 1–9. IEEE, IEEE.
- Lison, P. and Mavroeidis, V. (2017). Neural reputation models learned from passive DNS data. In *2017 IEEE International Conference on Big Data (Big Data)*, pages 3662–3671. IEEE, IEEE.
- Liu, X., Lu, H., and Nayak, A. (2021). A spam transformer model for sms spam detection. *IEEE Access*, 9:80253–80263.
- Lu, K.-D., Zeng, G.-Q., Luo, X., Weng, J., Luo, W., and Wu, Y. (2021). Evolutionary deep belief network for cyber-attack detection in industrial automation and control system. *IEEE Transactions on Industrial Informatics*, 17(11):7618–7627.
- Macas, M. and Chunming, W. (2019). Enhanced cyber-physical security through deep learning techniques. In *Proc. CPS Summer School Ph. D. Workshop*, pages 72–83.
- Macas, M. and Wu, C. (2019). An unsupervised framework for anomaly detection in a water treatment system. In *2019 18th IEEE International Conference On Machine Learning And Applications (ICMLA)*, pages 1298–1305. IEEE, IEEE.
- Macas, M., Wu, C., and Fuertes, W. (2022). A survey on deep learning for cybersecurity: Progress, challenges, and opportunities. *Computer Networks*, 212:109032.
- Madisetty, S. and Desarkar, M. S. (2018). A neural network-based ensemble approach for spam detection in twitter. *IEEE Trans. Comput. Soc. Syst.*, 5(4):973–984.
- Magazine, S. (2021). Hacker breaks into florida water treatment facility, changes chemical levels. <https://bit.ly/3ZTFTpX>. [Accessed: Jan 5, 2023].

- Makkar, A., Ghosh, U., and Sharma, P. K. (2021). Artificial intelligence and edge computing-enabled web spam detection for next generation IoT applications. *IEEE Sensors Journal*, 21(22):25352–25361.
- Makkar, A. and Kumar, N. (2020). An efficient deep learning-based scheme for web spam detection in IoT environment. *Future Gener. Comp. Sy.*, 108:467–487.
- Marcel, S., Nixon, M. S., and Li, S. Z., editors (2014). *Handbook of Biometric Anti-Spoofing*. Springer London.
- Marion, N. E. and Twede, J. (2020). *Cybercrime: An encyclopedia of digital crime*. ABC-CLIO.
- Martins, B. F., Gil, L. J. S., Román, J. F. R., Panach, J. I., Pastor, O., Hadad, M., and Rochwerger, B. (2022). A framework for conceptual characterization of ontologies and its application in the cybersecurity domain. *Software and Systems Modeling*, 21(4):1437–1464.
- Meidan, Y., Bohadana, M., Mathov, Y., Mirsky, Y., Shabtai, A., Breitenbacher, D., and Elovici, Y. (2018). N-BaIoT—Network-based detection of IoT botnet attacks using deep autoencoders. *IEEE Pervasive Comput.*, 17(3):12–22.
- Menotti, D., Chiachia, G., Pinto, A., Robson Schwartz, W., Pedrini, H., Xavier Falcao, A., and Rocha, A. (2015). Deep representations for iris, face, and fingerprint spoofing detection. *IEEE Trans.Inform.Forensic Secur.*, 10(4):864–879.
- Mirtsch, M., Kinne, J., and Blind, K. (2021). Exploring the adoption of the international information security management system standard ISO/IEC 27001: A web mining-based analysis. *IEEE Transactions on Engineering Management*, 68(1):87–100.
- Mladenović, M., Ošmjanski, V., and Stanković, S. V. (2021). Cyber-aggression, cyberbullying, and cyber-grooming. *ACM Computing Surveys*, 54(1):1–42.
- Morris, T. and Gao, W. (2014). Industrial control system traffic data sets for intrusion detection research. In *Progress in Pattern Recognition, Image Analysis, Computer Vision, and Applications*, pages 65–78. Springer International Publishing.

- Najar, A. A. and Naik, S. M. (2022). DDoS attack detection using MLP and random forest algorithms. *International Journal of Information Technology*, 14(5):2317–2327.
- Nast, C. (2016). Yandex. <https://www.wired.com/2016/03/inside-cunning-unprecedented-hack-ukraines-power-grid/>. [Accessed: Feb 5, 2023].
- Ng, A. (2018). How the equifax hack happened, and what still needs to be done. <https://cnet.co/3liX0T3>. [Accessed: Jan 5, 2023].
- Niu, X., Li, J., Sun, J., and Tomsovic, K. (2019). Dynamic detection of false data injection attack in smart grid using deep learning. In *2019 IEEE Power & Energy Society Innovative Smart Grid Technologies Conference (ISGT)*, pages 1–6. IEEE, IEEE.
- Otero, P. (2022). Criminal law and the risks posed by internet. an examination of spanish criminal law. https://doi.org/10.1007/978-3-030-95939-5_6.
- Pandit, S., Liu, J., Perdisci, R., and Ahamad, M. (2021). Applying deep learning to combat mass robocalls. In *2021 IEEE Security and Privacy Workshops (SPW)*, pages 63–70.
- Papoutsakis, M., Fysarakis, K., Spanoudakis, G., Ioannidis, S., and Koloutsou, K. (2021). Towards a collection of security and privacy patterns. *Applied Sciences*, 11(4):1396.
- Park, E., Cui, X., Nguyen, T. H. B., and Kim, H. (2019). Presentation attack detection using a tiny fully convolutional network. *IEEE Trans.Inform.Forensic Secur.*, 14(11):3016–3025.
- Peng, C., Wu, C., Gao, L., Zhang, J., Yau, K.-L. A., and Ji, Y. (2020). Blockchain for vehicular internet of things: Recent advances and open issues. *Sensors*, 20(18):5079.
- Pillai, A., Saraswat, V., and R., A. V. (2019). Smart wallets on blockchain—attacks and their costs. In *Communications in Computer and Information Science*, pages 649–660. Springer Singapore.
- Raghavendra, R., Avinash, M., Marcel, S., and Busch, C. (2015). Finger vein liveness detection using motion magnification. In *2015 IEEE 7th International*

- Conference on Biometrics Theory, Applications and Systems (BTAS)*, pages 1–7. IEEE, IEEE.
- Ranakoti, P., Yadav, S., Apurva, A., Tomer, S., and Roy, N. R. (2017). Deep web & online anonymity. In *2017 International Conference on Computing and Communication Technologies for Smart Nation (IC3TSN)*, pages 215–219. IEEE.
- Rath, S., Pal, D., Sharma, P. S., and Panigrahi, B. K. (2021). A cyber-secure distributed control architecture for autonomous AC microgrid. *IEEE Systems Journal*, 15(3):3324–3335.
- Ratha, N. K., Connell, J. H., and Bolle, R. M. (2001). Enhancing security and privacy in biometrics-based authentication systems. *IBM Systems Journal*, 40(3):614–634.
- Rescorla, E. (2018). The transport layer security (TLS) protocol version 1.3. *RFC*, 8446:1–160.
- Research, D. M. (2022). Global botnet detection market – industry trends and forecast to 2027. <https://www.databridgemarketresearch.com/reports/global-botnet-detection-market/>. [Accessed: Nov 20, 2022].
- Research, O. (2020). Global Cyber Physical System Market 2020 by Company, Regions, Type and Application, Forecast to 2025 | Orbis Research. [Accessed: Nov 5, 2022].
- Rezaei, S. and Liu, X. (2018). How to achieve high classification accuracy with just a few labels: A semi-supervised approach using sampled packets. <https://arxiv.org/abs/1812.09761>.
- Rezaei, S. and Liu, X. (2019). Deep learning for encrypted traffic classification: An overview. *IEEE Commun. Mag.*, 57(5):76–81.
- Rezaei, S. and Liu, X. (2020). Multitask learning for network traffic classification. In *2020 29th International Conference on Computer Communications and Networks (ICCCN)*, pages 1–9. IEEE.
- Rice, E. B. and AlMajali, A. (2014). Mitigating the risk of cyber attack on smart grid systems. *Procedia Computer Science*, 28:575–582.

- Rimmer, V., Preuveneers, D., Juarez, M., Van Goethem, T., and Joosen, W. (2017). Automated website fingerprinting through deep learning.
- Ron, M., Fuertes, W., Bonilla, M., Toulkeridis, T., and Diaz, J. (2018). Cybercrime in ecuador, an exploration, which allows to define national cybersecurity policies. In *2018 13th Iberian Conference on Information Systems and Technologies (CISTI)*. IEEE.
- Roy, P. K., Singh, J. P., and Banerjee, S. (2020). Deep learning to filter SMS spam. *Future Gener. Comp. Sy.*, 102:524–533.
- Schneider, K. P., Mather, B. A., Pal, B. C., Ten, C.-W., Shirek, G. J., Zhu, H., Fuller, J. C., Pereira, J. L. R., Ochoa, L. F., de Araujo, L. R., Dugan, R. C., Matthias, S., Paudyal, S., McDermott, T. E., and Kersting, W. (2018). Analytic considerations and design basis for the IEEE distribution test feeders. *IEEE Transactions on Power Systems*, 33(3):3181–3188.
- Seth, S. and Biswas, S. (2017). Multimodal spam classification using deep learning techniques. In *2017 13th International Conference on Signal-Image Technology & Internet-Based Systems (SITIS)*, pages 346–349. IEEE, IEEE.
- Shahjee, D. and Ware, N. (2022). Integrated network and security operation center: A systematic analysis. *IEEE Access*, 10:27881–27898.
- Shapira, T. and Shavitt, Y. (2019). FlowPic: Encrypted internet traffic classification is as easy as image recognition. In *IEEE INFOCOM 2019 - IEEE Conference on Computer Communications Workshops (INFOCOM WKSHPS)*, pages 680–687. IEEE.
- Sibai, F. N., Mohammad, N., and Muhammad, S. (2020). Probabilistic modeling and study of cybersecurity attacks in industrial control systems of plants. In *2020 IEEE Conference on Application, Information and Network Security (AINS)*, pages 58–63. IEEE.
- Siniosoglou, I., Radoglou-Grammatikis, P., Efstathopoulos, G., Fouliras, P., and Sarigiannidis, P. (2021). A unified deep learning anomaly detection and classification approach for smart grid environments. *IEEE Transactions on Network and Service Management*, 18(2):1137–1151.
- Siranjeevi, H., Venkatraman, S., and Krithivasan, K. (2020). A review on phishing—machine vision and learning approaches. <https://doi.org/10.1002/9781119682042.ch10>.

- Sirinam, P., Imani, M., Juarez, M., and Wright, M. (2018). Deep fingerprinting: Undermining website fingerprinting defenses with deep learning. In *Proceedings of the 2018 ACM SIGSAC Conference on Computer and Communications Security, CCS '18*, page 1928–1943, New York, NY, USA. Association for Computing Machinery.
- Solar, C. (2020). Cybersecurity and cyber defence in the emerging democracies. *Journal of Cyber Policy*, 5(3):392–412.
- Song, W., Shi, C., Xiao, Z., Duan, Z., Xu, Y., Zhang, M., and Tang, J. (2019). Autoint: Automatic feature interaction learning via self-attentive neural networks. In *Proceedings of the 28th ACM International Conference on Information and Knowledge Management, CIKM '19*, page 1161–1170, New York, NY, USA. Association for Computing Machinery.
- Sorkin, D. E. (2023). Spam statistics and facts. <https://spamlaws.com/spam-stats.html>. [Accessed: Jun 19, 2023].
- Souza, G. B., Santos, D. F., Pires, R. G., Marana, A. N., and Papa, J. P. (2017). Deep Boltzmann machines for robust fingerprint spoofing attack detection. In *2017 International Joint Conference on Neural Networks (IJCNN)*, pages 1863–1870. Ieee, IEEE.
- Spaulding, J. and Mohaisen, A. (2018). Defending internet of things against malicious domain names using d-FENS. In *2018 IEEE/ACM Symposium on Edge Computing (SEC)*, pages 387–392. IEEE, IEEE.
- Stellios, I., Kotzanikolaou, P., Psarakis, M., Alcaraz, C., and Lopez, J. (2018). A survey of IoT-enabled cyberattacks: Assessing attack paths to critical infrastructures and services. *IEEE Commun. Surv. Tutorials*, 20(4):3453–3495.
- Sun, B., Yang, W., Yan, M., Wu, D., Zhu, Y., and Bai, Z. (2020). An encrypted traffic classification method combining graph convolutional network and autoencoder. In *2020 IEEE 39th International Performance Computing and Communications Conference (IPCCC)*, pages 1–8. IEEE.
- Syed, R. (2020). Cybersecurity vulnerability management: A conceptual ontology and cyber intelligence alert system. *Information & Management*, 57(6):103334.

- Symantec, T. H. T. (2020). Threat landscape trends - q2 2020. <https://symantec-enterprise-blogs.security.com/blogs/threat-intelligence/threat-landscape-trends-q2-2020>. [Accessed: Jan 5, 2023].
- Team, M. (2017). Customer guidance for WannaCrypt attacks. <https://blogs.technet.microsoft.com/msrc/2017/05/12/customer-guidance-for-wannacrypt-attacks/>. [Accessed: Jan 5, 2023].
- The Tor Project, I. (2023). Tor - browse privately. explore freely. <https://www.torproject.org/>. [Accessed: Feb 5, 2023].
- Tøndel, I. A., Line, M. B., and Jaatun, M. G. (2014). Information security incident management: Current practice as reported in the literature. *Computers & Security*, 45:42–57.
- Tran, D., Mac, H., Tong, V., Tran, H. A., and Nguyen, L. G. (2018). A LSTM based framework for handling multiclass imbalance in DGA botnet detection. *Neurocomputing*, 275:2401–2413.
- Trub, L., Doyle, K. M., Hubert, Z. M., Parker, V., and Starks, T. J. (2022). Sexting to sex: Testing an attachment based model of connections between texting behavior and sex among heterosexually active women. *Computers in Human Behavior*, 128:107097.
- van Wyk, F., Wang, Y., Khojandi, A., and Masoud, N. (2020). Real-time sensor anomaly detection and identification in automated vehicles. *IEEE Trans. Intell. Transport. Syst.*, 21(3):1264–1276.
- Vaswani, A., Shazeer, N., Parmar, N., Uszkoreit, J., Jones, L., Gomez, A. N., Kaiser, Ł., and Polosukhin, I. (2017). Attention is all you need. *Advances in neural information processing systems*, 30.
- Ventures, C. (2020). Cybercrime damages \$6 trillion by 2021. <https://cybersecurityventures.com/hackerpocalypse-cybercrime-report-2016/>. [Accessed: Jan 5, 2023].
- Vinayakumar, R., Alazab, M., Srinivasan, S., Pham, Q.-V., Padannayil, S. K., and Simran, K. (2020). A visualized botnet detection system based deep learning for the internet of things networks of smart cities. *IEEE Transactions on Industry Applications*, 56(4):4436–4456.

- von Solms, R. and van Niekerk, J. (2013). From information security to cyber security. *Computers & Security*, 38:97–102.
- Wang, J., Shi, D., Li, Y., Chen, J., Ding, H., and Duan, X. (2019a). Distributed framework for detecting PMU data manipulation attacks with deep autoencoders. *IEEE Trans. Smart Grid*, 10(4):4401–4410.
- Wang, P., Wang, Z., Ye, F., and Chen, X. (2021). Bytesgan: A semi-supervised generative adversarial network for encrypted traffic classification in sdn edge gateway. *Computer Networks*, 200:108535.
- Wang, W., Zhu, M., Zeng, X., Ye, X., and Sheng, Y. (2017). Malware traffic classification using convolutional neural network for representation learning. In *2017 International Conference on Information Networking (ICOIN)*, pages 712–717. IEEE.
- Wang, Y., Chen, D., Zhang, C., Chen, X., Huang, B., and Cheng, X. (2019b). Wide and recurrent neural networks for detection of false data injection in smart grids. In *International Conference on Wireless Algorithms, Systems, and Applications*, pages 335–345. Springer.
- Warren, M. and Leitch, S. (2016). The syrian electronic army—a hacktivist group. *Journal of Information, Communication and Ethics in Society*, 14(2):200–212.
- Watin-Augouard, M. (2021). The boundary between cybercrime and cyberwar: An uncertain no-man's land. <https://doi.org/10.1002/9781119885092.ch4>.
- Wazen, S., Thibault, C., Jerome, F., and Isabelle, C. (2016). Https websites dataset. <http://betternet.lhs.loria.fr/datasets/https/index.html>, [Accessed: May 25, 2021].
- Whonix, I. (2023). Whonix - superior internet privacy. <https://www.whonix.org/>. [Accessed: Feb 5, 2023].
- Wilson, C., Sheridan, L., and Garratt-Reed, D. (2021). What is cyberstalking? a review of measurements. *Journal of Interpersonal Violence*, 37(11-12):NP9763–NP9783.

- Wojcicki, N. M. (2019). Phishing attacks: Preying on human psychology to beat the system and developing cybersecurity protections to reduce the risks. *World Libraries*, 23(1).
- Woodbridge, J., Anderson, H. S., Ahuja, A., and Grant, D. (2016). Predicting domain generation algorithms with long short-term memory networks. <https://arxiv.org/abs/1611.00791>.
- Wu, T., Liu, S., Zhang, J., and Xiang, Y. (2017). Twitter spam detection based on deep learning. In *Proceedings of the Australasian Computer Science Week Multiconference*, pages 1–8. ACM.
- Xie, X., Wang, B., Wan, T., and Tang, W. (2020). Multivariate abnormal detection for industrial control systems using 1D CNN and GRU. *IEEE Access*, 8:88348–88359.
- Xu, S., Lai, S., and Li, Y. (2018). A deep learning based framework for cloud masquerade attack detection. In *2018 IEEE 37th International Performance Computing and Communications Conference (IPCCC)*, pages 1–2. IEEE, IEEE.
- Xu, Y., Yan, X., Wu, Y., Hu, Y., Liang, W., and Zhang, J. (2021). Hierarchical bidirectional RNN for safety-enhanced b5g heterogeneous networks. *IEEE Transactions on Network Science and Engineering*, 8(4):2946–2957.
- Yandex, L. (2022). Yandex. <https://yandex.com/>. [Accessed: Feb 5, 2023].
- Yang, C., Harkreader, R., and Gu, G. (2013). Empirical evaluation and new design for fighting evolving twitter spammers. *IEEE Trans.Inform.Forensic Secur.*, 8(8):1280–1293.
- Yang, L., Liu, G., Dai, Y., Wang, J., and Zhai, J. (2020). Detecting stealthy domain generation algorithms using heterogeneous deep neural network framework. *IEEE Access*, 8:82876–82889.
- Yu, C.-Y., Chang, C. K., and Zhang, W. (2020). An edge computing based situation enabled crowdsourcing blacklisting system for efficient identification of scammer phone numbers. In *2020 International Conference on Computational Science and Computational Intelligence (CSCI)*, pages 776–781. IEEE.
- Yue, C., Wang, L., Wang, D., Duo, R., and Nie, X. (2021). An ensemble intrusion detection method for train ethernet consist network based on CNN and RNN. *IEEE Access*, 9:59527–59539.

Zhang, Y., Wang, J., and Chen, B. (2021). Detecting false data injection attacks in smart grids: A semi-supervised deep learning approach. *IEEE Transactions on Smart Grid*, 12(1):623–634.

Zwiese, A., Munde, A., Busch, C., and Daum, H. (2000). BioIS study. comparative study of biometric identification systems. In *Proceedings IEEE 34th Annual 2000 International Carnahan Conference on Security Technology* (Cat. No.00CH37083), pages 60–63. IEEE, IEEE.

Ciberseguridad: del ciber-crimen a los ataques ciber-físicos

La ciberseguridad es un conjunto de tecnologías y métodos destinados a proteger las redes informáticas, los sistemas finales, los programas y los datos de ataques, accesos no autorizados, cambios o daños. Los mecanismos de defensa cibernética existen a nivel de host, red, aplicación y datos. Una plétora de herramientas, como firewalls, software antivirus, sistemas de detección y prevención de intrusos (IDS/IPS), gestión unificada de amenazas (UTM), gestión de eventos de seguridad (SIEM) funcionan sigilosamente para evitar ataques y detectar brechas de seguridad. Sin embargo, los adversarios aún tienen ventaja porque solo necesitan encontrar una vulnerabilidad en los sistemas.

A medida que aumenta la cantidad de sistemas conectados a Internet, los ataques cibernéticos también aumentan en tamaño y sofisticación. Los ataques cibernéticos son ahora el crimen de mayor crecimiento a escala global. Además, los ataques se vuelven más mutables y alcanzan sus objetivos más rápido que nunca. Las organizaciones enfrentan una necesidad urgente de aumentar y mejorar su ciberseguridad debido al crecimiento continuo de la cantidad de dispositivos, redes e interfaces de usuario para usuarios finales, combinado con las crecientes cantidades de datos que se transmiten a través de Internet debido a los avances en la computación en la nube y/o la niebla/nebulización, Internet de las cosas (IoT), Industria 4.0/5.0 y las redes 5G/6G.

Este libro tiene como objetivo general el proporcionar a los lectores conocimientos teóricos y prácticos, así como herramientas que le permitan desarrollar habilidades, destrezas y aptitudes, y la aplicación de las mejores prácticas dentro de la empresa y la industria para incrementar los niveles de seguridad de la información. Además, durante su desarrollo se identifican las limitaciones de diferentes trabajos revisados en la literatura y presenta una visión de los desafíos actuales del área, brindando información valiosa y buenas prácticas para los investigadores y desarrolladores que trabajan en problemas relacionados. Esperamos que este libro se convierta en una guía para desarrolladores/investigadores, profesionales y público en general interesados en prevenir y combatir a los posibles ataques de los cibercriminales y, en consecuencia, incrementar la madurez de ciberseguridad.

La obra que usted, estimado lector, tiene en sus manos está cimentada en al menos una década de actividad docente, actividad profesional e investigativa de sus autores en esta delicada área de conocimiento. En esencia, se presenta una fenomenal producción que contribuirá tanto en entrenar y concienciar a las personas, así como en formar profesionales y especialistas de ciberseguridad para el Ecuador y el mundo.

Finalmente, parafraseando con Lao Tsé, quien acertadamente señaló que la gratitud es la memoria del corazón, deseamos agradecer profundamente a todos quienes apoyaron para la concreción de este libro, a las autoridades de la Universidad, a los estudiantes de grado y posgrado, a las empresas y personas vulnerables que inspiraron la escritura de este libro.

Los autores



ESPE
UNIVERSIDAD DE LAS FUERZAS ARMADAS
INNOVACIÓN PARA LA EXCELENCIA